LENGUAJE DE PROGRAMACIÓN 2

Pruebas de seguridad y gestión de acceso

Actividad autónoma - Sesión 10 | PharmaSoft

Estudiante
James Christopher Tequen Oncoy

Docente
Benjamin David Reyna Barreto

Fecha de ejecución
17/10/2026 - America/Lima

Informe y evidencias en un solo documento

28 casos de seguridad de la actividad autónoma aprobados. Ejecución real con PharmaBackend, Swagger, navegador y Oracle.

El informe de seguridad C1-C3 ocupa tres páginas. A continuación se incorpora el anexo con todas las evidencias y comprobaciones de la misma actividad.

Repositorio: Solicitud de incorporación #1. El requisito de commits en días distintos permanece pendiente.

Informe de seguridad

PharmaBackend · Actividad autónoma · Sesión 10

Estudiante: James Christopher Tequen Oncoy
Curso: Lenguaje de Programación 2
Docente: Benjamin David Reyna Barreto
Fecha de ejecución: 17 de octubre de 2026

C1. Resumen de resultados

Grupo	Casos	Pasan	Fallan
Autenticación	5	5	0
Token	6	6	0
Permisos	5	5	0
Usuarios	3	3	0
CORS	1	1	0
Contraseña, roles y estado	8	8	0
Total	**28**	**28**	**0**

Se ejecutaron **28 casos** mediante 62 peticiones o comprobaciones registradas: los 16 casos base, cuatro propios de grupos distintos y B-01 a B-08.

Los casos propios son A-05 (credenciales vacías), T-06 (Authorization ausente), P-05 (unión de permisos de supervisor) y U-03 (administración de usuarios por vendedor). Las respuestas distinguen la falta de autenticación del rechazo por permisos.

Entorno y trazabilidad

Oracle 23 en Docker; API principal en localhost:8081; Swagger UI; SPA existente servida en localhost:4200. Para T-03 se inició el mismo JAR en 8082 con otra clave. Esa instancia también emitió el JWT de T-04 con duración de un minuto; se utilizó después de su vencimiento real.

La matriz contiene las peticiones, códigos, mensajes y enlaces a capturas nombradas por caso. El anexo conserva las capturas originales de Swagger, la pestaña Red, consultas Oracle y el registro del cambio de contraseña. Los datos de negocio son nombres y productos normales.

C2. Hallazgos y verificación

No hubo casos funcionales fallidos en la ejecución final. Por ello no corresponde elaborar fichas de fallos con severidad, causa y corrección. Las respuestas de rechazo esperadas forman parte de los casos que pasan.

Resultados de los endpoints construidos

Operación	Reglas comprobadas y resultado
PUT /auth/password	204 al cambiar; 400 por formato o longitud; 409 por contraseña actual incorrecta o nueva idéntica. La cuenta se toma de Authentication.getName(). BCrypt verifica y codifica; la respuesta no contiene contraseña.
PUT /usuarios/{id}/roles	200 al reemplazar roles; 400 por conjunto vacío; 404 por usuario o rol inexistente; 409 si el administrador intenta quitarse ADMIN. Un vendedor recibe 403.
PATCH /usuarios/{id}/estado	200 al desactivar y reactivar; 404 si el usuario no existe; 409 ante autodesactivación del administrador; 403 sin permiso. La cuenta desactivada pierde acceso con su token previo y su login devuelve el mensaje genérico.

Comprobaciones de persistencia y registro

U-02 creó la cuenta de María Huamán con una única relación VENDEDOR. La consulta a usuarios y usuario_roles confirmó un hash BCrypt con prefijo $2a$10$; el DTO no expone password. B-05 dejó exactamente dos relaciones para vendedor: ALMACENERO y VENDEDOR. Las consultas se ejecutaron directamente en Oracle mediante JDBC y se incluyen con sus resultados; son reproducibles en SQL Developer.

B-01 confirmó un registro INFO “Contraseña actualizada: usuario=vendedor”; se verificó que las contraseñas enviadas no aparezcan en el log. Tras las pruebas se restituyeron la contraseña y los roles originales del vendedor; la cuenta maria creada en U-02 permanece registrada.

Límites y estado de la entrega

Las evidencias corresponden al entorno local de clase. C-01 registró el OPTIONS y el GET reales del navegador con respuesta 200 y el origen permitido localhost:4200. La colección exportada deja vacías todas las variables de tokens.

Versionamiento: rama feature/seguridad-pruebas-Tequen, creada desde feature/dev-TEQUEN, la rama de trabajo disponible. No existía la rama de práctica indicada. Los commits llevan su fecha real del 17/10/2026; **queda pendiente el requisito de commits en días distintos**. El repositorio utiliza main en lugar de master. La rama está publicada y el PR #1 está abierto hacia main: https://github.com/LeonardoTA/PharmaBackend/pull/1. El criterio completo de versionamiento no se considera cumplido.

C3. Análisis de seguridad

1. Respuesta genérica del login

El mismo mensaje “Usuario o contraseña incorrectos” evita que la respuesta distinga una cuenta inexistente, una contraseña equivocada y una cuenta deshabilitada. Un mensaje diferente permitiría enumerar usuarios válidos o conocer su estado para dirigir intentos contra ellos. GlobalExceptionHandler.handleAuthentication aplica la respuesta común a AuthenticationException; A-02 y A-03 comprobaron la igualdad del mensaje. Esto reduce la información expuesta por el texto; no demuestra igualdad de tiempos de respuesta.

2. Token anterior después del cambio de contraseña

El JWT conserva una firma y una fecha de expiración válidas: AuthServiceImpl.cambiarPassword modifica el hash BCrypt, pero no revoca los tokens emitidos. JwtAuthenticationFilter.doFilterInternal comprueba firma y expiración, luego consulta usuario, estado y permisos; no compara la contraseña ni una versión de credencial. B-01 confirmó que el token anterior sigue funcionando. Una solución es guardar tokenVersion en usuarios e incluirla en el JWT: al cambiar la contraseña se incrementa la versión y el filtro rechaza tokens con una versión anterior.

3. Publicación accidental del secreto

Quien obtiene la clave HMAC puede firmar un JWT que suplante el sub de un usuario existente, incluso admin. Aunque el filtro recarga los permisos desde la base y no confía en las authorities del payload para autorizar, suplantar un administrador sigue siendo crítico. Se debe rotar inmediatamente la clave, retirar la anterior de todas las instancias, revisar accesos, reemplazar credenciales comprometidas y retirar el secreto del repositorio y su historial. JwtService recibe la clave desde JWT_SECRET; T-03 confirmó que otra clave rechaza el token anterior.

4. Protección de reportes con @PreAuthorize

La anotación del ReporteController liga el permiso REPORTES_VER al controlador y sus métodos, de modo que cambiar una URL no elimina esa protección si la anotación permanece. SecurityConfig mantiene además la autenticación general. P-03 comprobó el rechazo para vendedor y almacén. La desventaja es que las reglas quedan distribuidas entre la configuración y las anotaciones, lo que dificulta revisar toda la política. También depende de @EnableMethodSecurity y de que la invocación pase por el proxy de Spring; una llamada interna puede no ser interceptada.

Referencias al código verificado

Paquete pe.edu.upeu.PharmaBackend: controller/AuthController y ReporteController; service/impl/AuthServiceImpl y UsuarioServiceImpl; security/JwtAuthenticationFilter, JwtService, UsuarioDetailsService y PermisosPorRol; config/SecurityConfig; exception/GlobalExceptionHandler. Los casos correspondientes y los resultados completos se encuentran en la matriz y en el anexo.

ANEXO INTEGRADO

Evidencias de las pruebas

Las páginas siguientes forman parte de este mismo entregable. Cada captura procede de las pruebas reales ya ejecutadas; se conservan el método, la URL, el encabezado de autenticación cuando corresponde, el estado y la respuesta observados.

Las fichas se identifican por los mismos códigos de la matriz. Los datos de clientes, productos y usuarios mantienen sus valores normales. Los códigos HTTP se muestran como evidencia técnica; los mensajes de negocio no contienen prefijos numéricos.

Las capturas extensas continúan en páginas consecutivas, sin eliminar datos. Los JWT visibles son temporales y pertenecen a las cuentas locales de clase. Las variables de tokens de la colección Postman exportada están vacías.

También se incorporan las consultas Oracle y sus resultados, el payload decodificado, el registro de cambio de contraseña, y la comprobación de CORS desde el navegador.

Archivos del repositorio: matriz en docs/matriz-seguridad-s10.md; colección en postman/PharmaSoft-S10-Seguridad.json; capturas originales en docs/evidencias-seguridad/.

Resultado: 28 casos pasan, ninguno falla. El informe C1-C3 se encuentra en las páginas 2 a 4.

Login admin

Usuario / token: Público / Ausente

Petición: POST http://localhost:8081/api/v1/auth/login

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - Usuario admin; roles ADMIN; respuesta sin contraseña

POST /api/v1/auth/login

Execute | Clear

Responses

```
curl -X 'POST' \
  'http://localhost:8081/api/v1/auth/login' \
  -H 'accept: */*' \
  -H 'Content-Type: application/json' \
  -d '{
  "username": "admin",
  "password": "Admin2026*"
}'
```

Request URL

```
http://localhost:8081/api/v1/auth/login
```

Server response

Code | Details

200

Response body


```
{
  "token": "eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJhZG1pbiIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0VTQ1JJQklSIiwiQ0FUQUxPR09fTEVFUiIsIkNMSUVOVEVTX0VTQ1JJQklSIiwiQ0xJRU5URVNfTEVFUiIsIlJFUE9SVEVTX1ZFUiIsIlJPTEVfQURNSU4iLCJVU1VBUklPU19BRE1JTklTVFJBUiIsIlZFTlRBU19MRUVSIiwiVkVOVEFTX1JFR0lTVFJBUiJdLCJpYXQiOjE3OTIyNTY1MDgsImV4cCI6MTc5MjI2MDEwOH0.KivqHKTW_b7-mwSbWwb5Y7v1HPTbVd5GDOEgZ-jR95d-K2MLWyFlaY3WVVIpgwxW",
  "tipo": "Bearer",
  "expiraEnSegundos": 3600,
  "username": "admin",
  "nombreCompleto": "Rosa Elena Mendoza Ticona",
  "roles": [
    "ADMIN"
  ],
  "permisos": [
    "CATALOGO_ESCRIBIR",
    "CATALOGO_LEER",
    "CLIENTES_ESCRIBIR",
    "CLIENTES_LEER",
    "REPORTES_VER",
    "USUARIOS_ADMINISTRAR",
    "VENTAS_LEER",
    "VENTAS_REGISTRAR"
  ]
}
```


Response headers

```
cache-control: no-cache,no-store,max-age=0,must-revalidate
connection: keep-alive
content-type: application/json
date: Sat,17 Oct 2026 17:01:48 GMT
expires: 0
keep-alive: timeout=60
pragma: no-cache
transfer-encoding: chunked
vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers
x-content-type-options: nosniff
x-frame-options: DENY
x-xss-protection: 0
```

Responses

A-01_01_swagger.png

Login vendedor

Usuario / token: Público / Ausente

Petición: POST http://localhost:8081/api/v1/auth/login

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - Usuario vendedor; roles VENDEDOR; respuesta sin contraseña

POST /api/v1/auth/login

Execute Clear

Responses

```
curl -X 'POST' \
  'http://localhost:8081/api/v1/auth/login' \
  -H 'accept: */*' \
  -H 'Content-Type: application/json' \
  -d '{
  "username": "vendedor",
  "password": "Vendedor2026*"
}'
```

Request URL

```
http://localhost:8081/api/v1/auth/login
```

Server response

Code Details

200

Response body


```
{
  "token": "eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJ2ZW5kZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTElFTlRFU19FU0NSSUJJUiIsIkNMSUVOVEVTX0xFRVIiLCJST0xFX1ZFTkRFRE9SIiwiVkVOVEFTX0xFRVIiLCJWRU5UQVNfUkVHSVNUUkFSIl0sImlhdCI6MTc5MjI1NjUxNywiZXhwIjoxNzkyMjYwMTE3fQ.Sn6jA3preOsJTj_Im-eTdF-dYD4TrQq08zWDCZdFsEB3UtacOYiOOJku73iMb7G2",
  "tipo": "Bearer",
  "expiraEnSegundos": 3600,
  "username": "vendedor",
  "nombreCompleto": "Lucia Ramos Cutipa",
  "roles": [
    "VENDEDOR"
  ],
  "permisos": [
    "CATALOGO_LEER",
    "CLIENTES_ESCRIBIR",
    "CLIENTES_LEER",
    "VENTAS_LEER",
    "VENTAS_REGISTRAR"
  ]
}
```


Response headers

```
cache-control: no-cache,no-store,max-age=0,must-revalidate
connection: keep-alive
content-type: application/json
date: Sat,17 Oct 2026 17:01:57 GMT
expires: 0
keep-alive: timeout=60
pragma: no-cache
transfer-encoding: chunked
vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers
x-content-type-options: nosniff
x-frame-options: DENY
x-xss-protection: 0
```

Responses

A-01_02_swagger.png

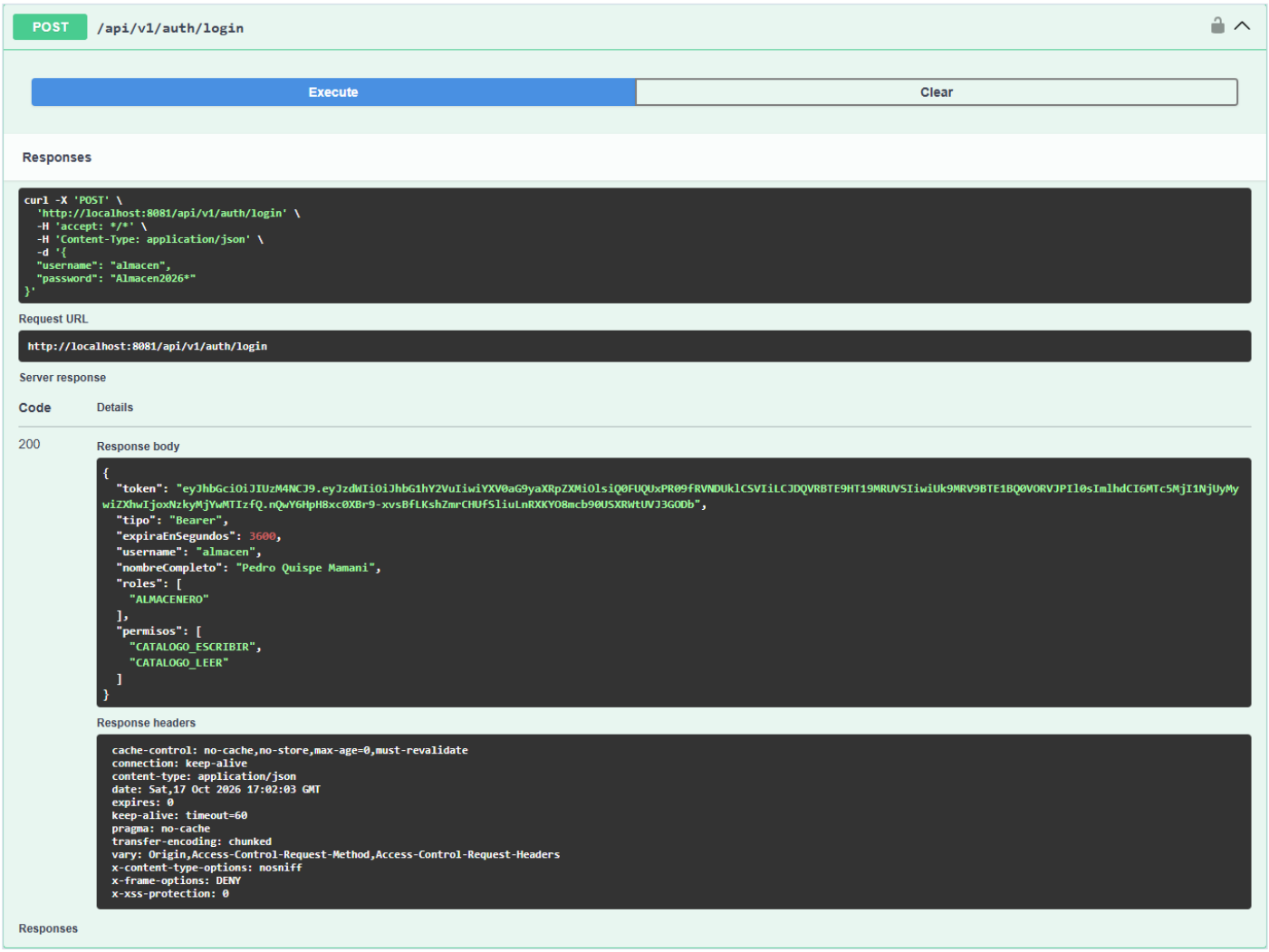
Login almacen

Usuario / token: Público / Ausente

Petición: POST http://localhost:8081/api/v1/auth/login

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - Usuario almacen; roles ALMACENERO; respuesta sin contraseña



A-01_03_swagger.png

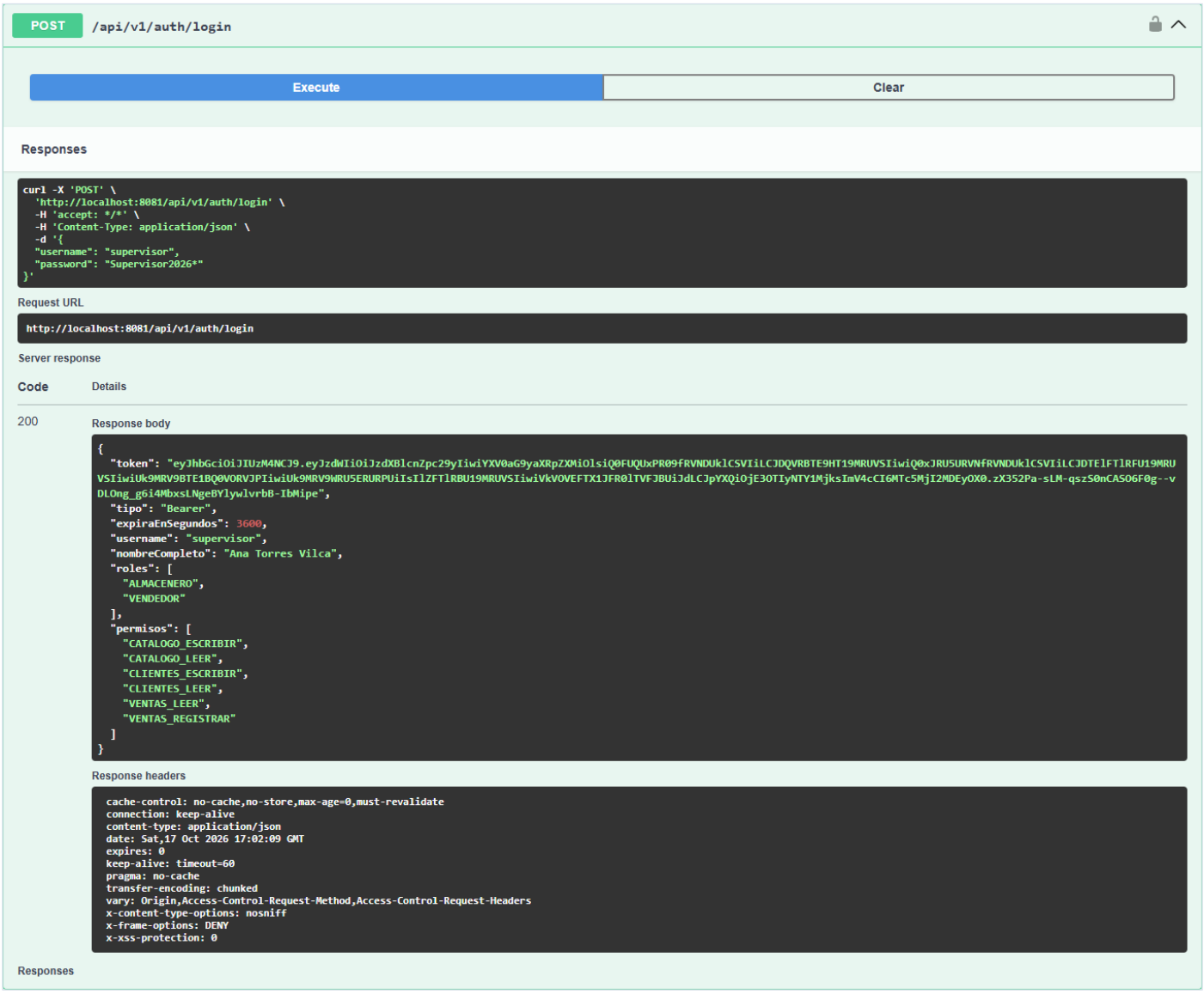
Login supervisor

Usuario / token: Público / Ausente

Petición: POST http://localhost:8081/api/v1/auth/login

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - Usuario supervisor; roles ALMACENERO, VENDEDOR; respuesta sin contraseña



A-01_04_swagger.png

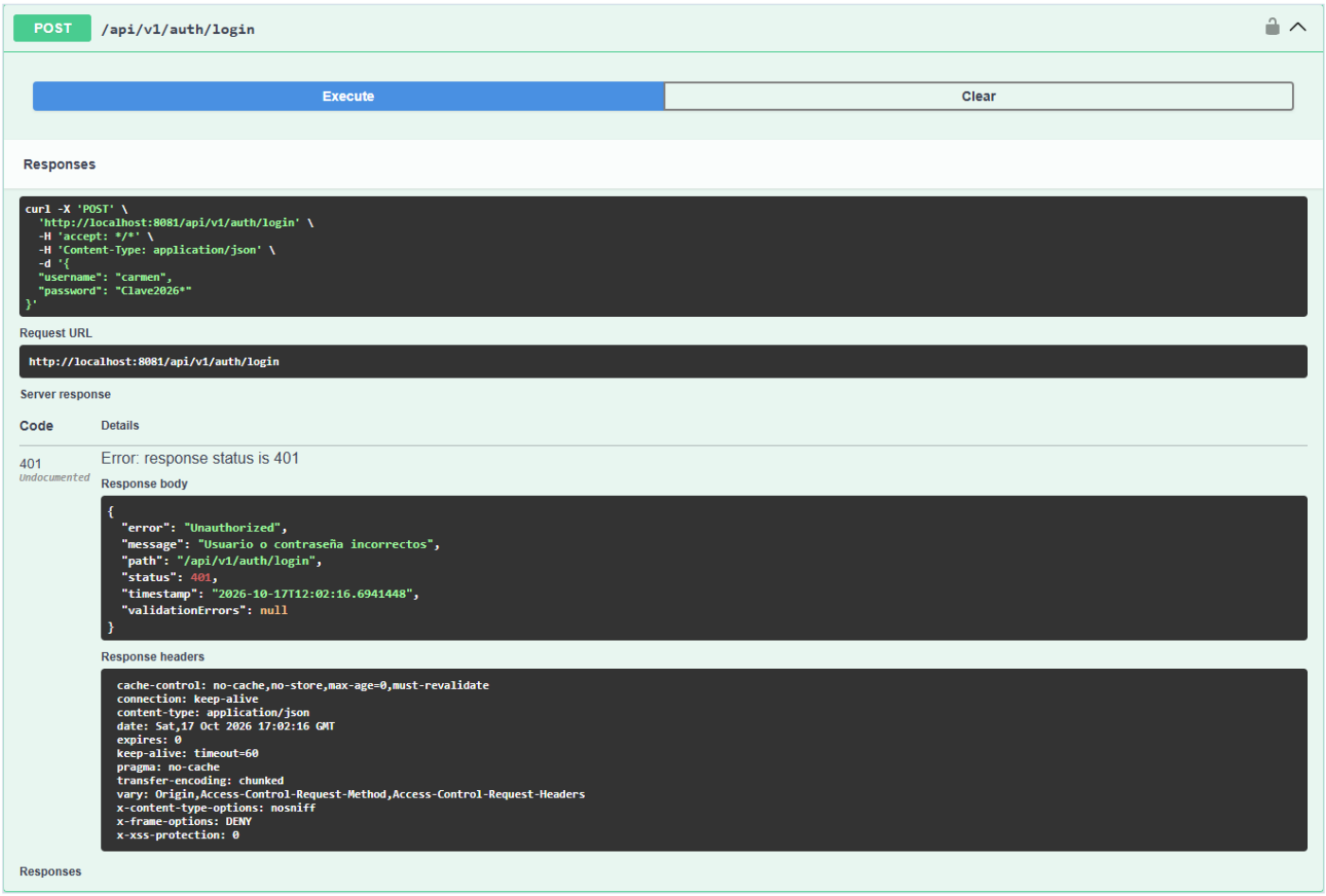
Usuario inexistente

Usuario / token: Público / Ausente

Petición: POST http://localhost:8081/api/v1/auth/login

Esperado: 401 - Usuario o contraseña incorrectos

Obtenido: 401 - Usuario o contraseña incorrectos



A-02_01_swagger.png

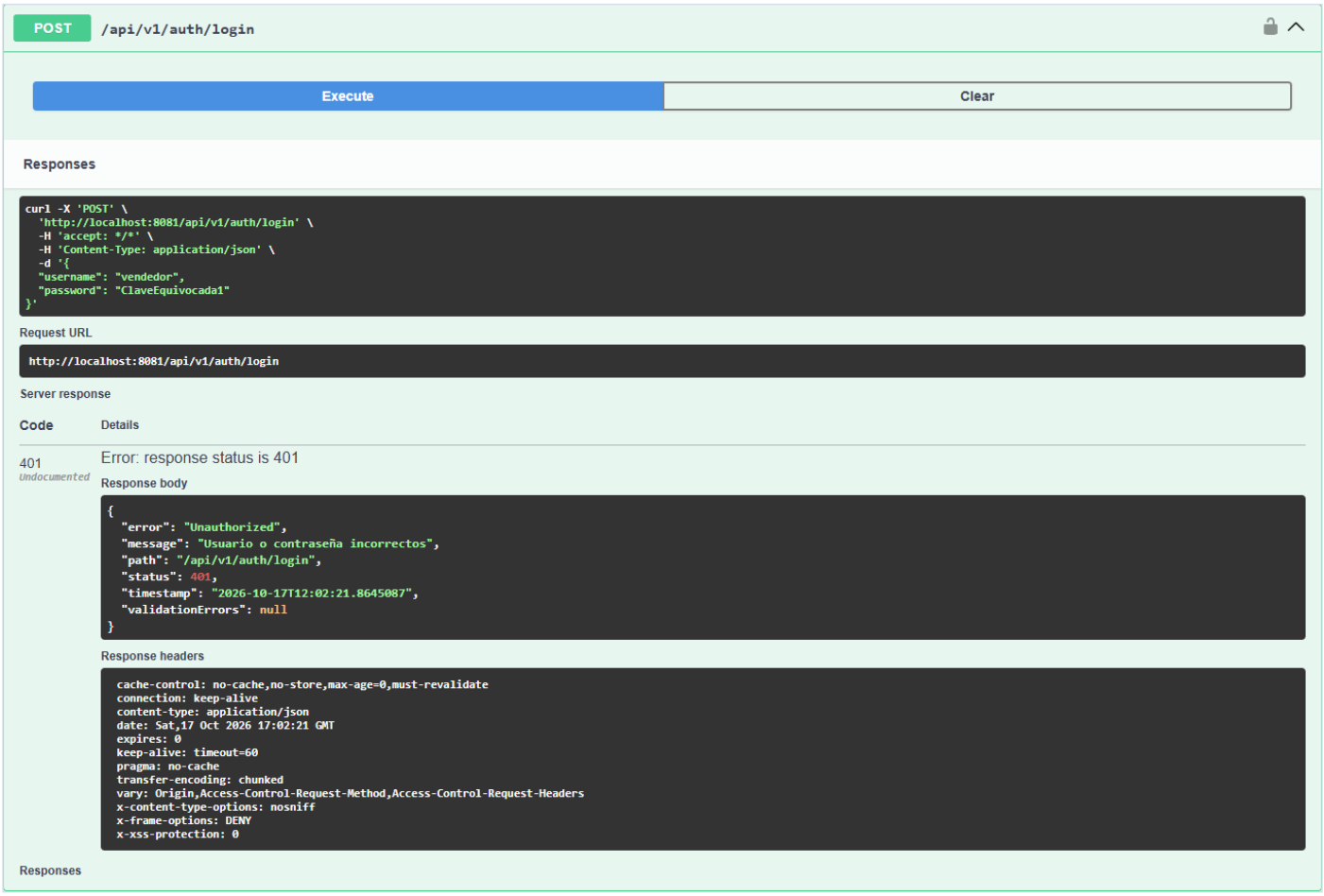
Contraseña incorrecta

Usuario / token: Público / Ausente

Petición: POST http://localhost:8081/api/v1/auth/login

Esperado: 401 - Usuario o contraseña incorrectos

Obtenido: 401 - Usuario o contraseña incorrectos



A-02_02_swagger.png

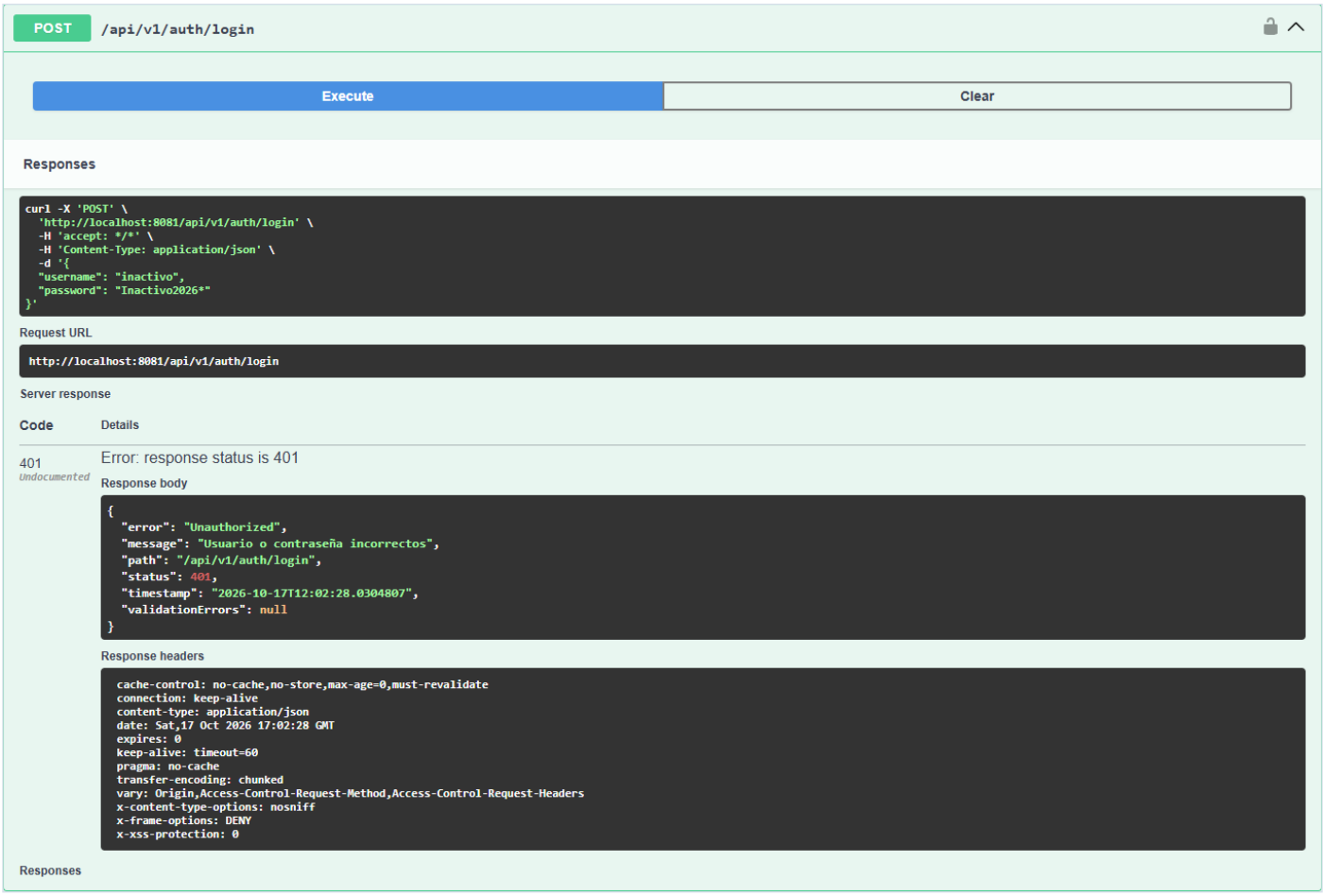
Cuenta inactiva

Usuario / token: Público / Ausente

Petición: POST http://localhost:8081/api/v1/auth/login

Esperado: 401 - Usuario o contraseña incorrectos

Obtenido: 401 - Usuario o contraseña incorrectos



A-03_01_swagger.png

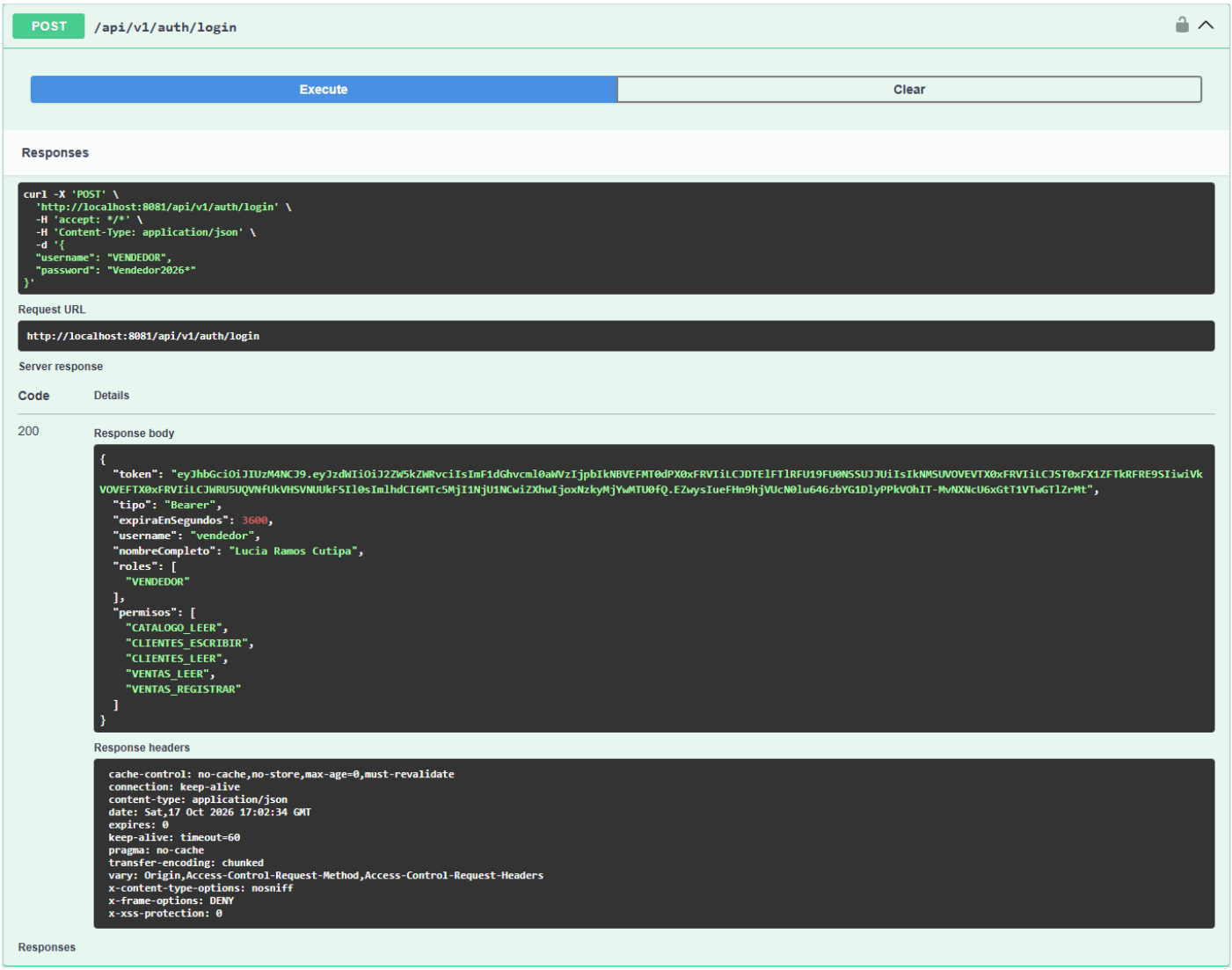
Usuario en mayúsculas

Usuario / token: Público / Ausente

Petición: POST http://localhost:8081/api/v1/auth/login

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - Usuario vendedor; roles VENDEDOR; respuesta sin contraseña



A-04_01_swagger.png

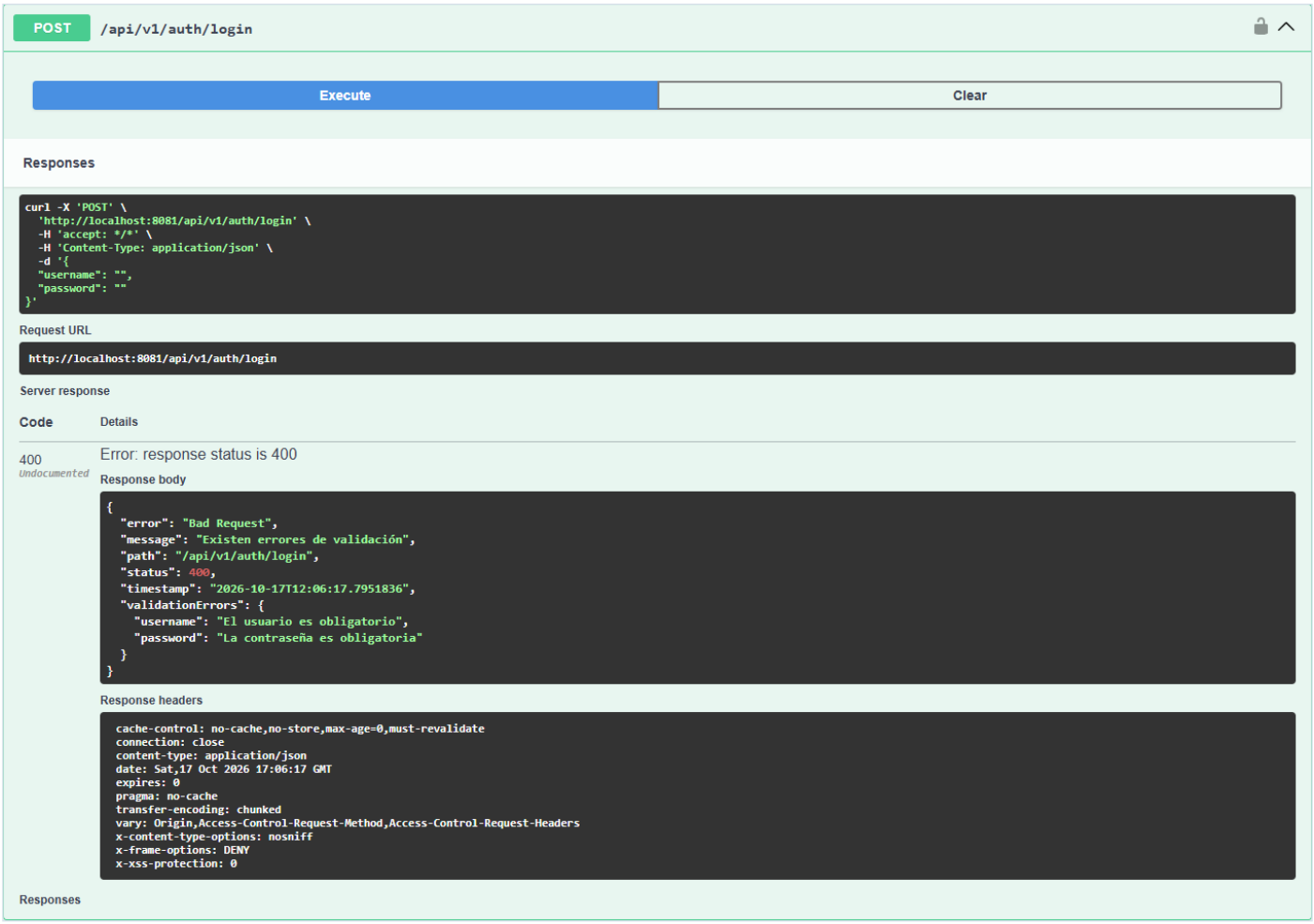
Propio: login vacío

Usuario / token: Público / Ausente

Petición: POST http://localhost:8081/api/v1/auth/login

Esperado: 400 - obligatorio

Obtenido: 400 - Existen errores de validación / El usuario es obligatorio; La contraseña es obligatoria



A-05_01_swagger.png

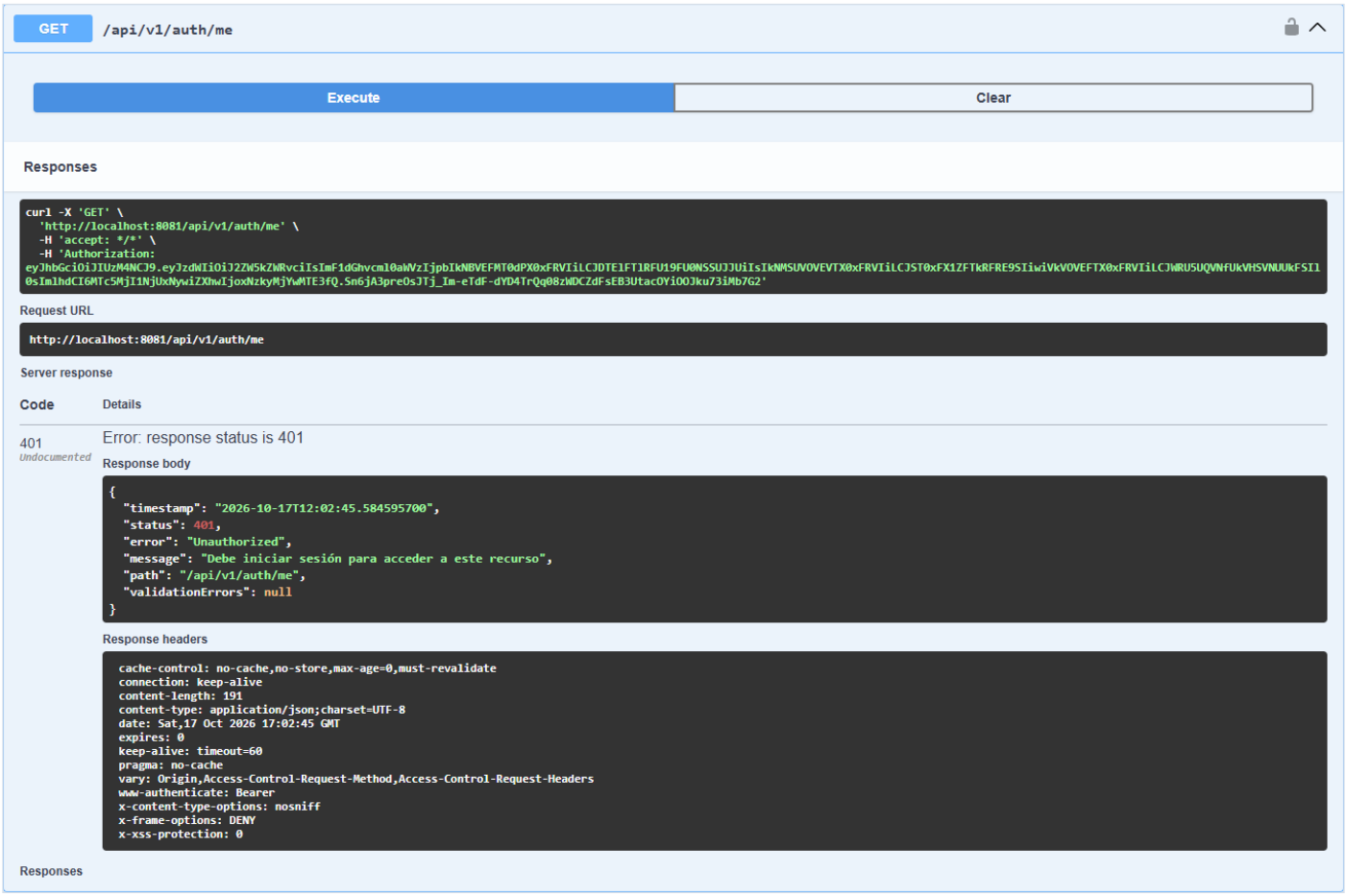
Token sin Bearer

Usuario / token: vendedor / Sin prefijo Bearer

Petición: GET http://localhost:8081/api/v1/auth/me

Esperado: 401 - Debe iniciar sesión

Obtenido: 401 - Debe iniciar sesión para acceder a este recurso



T-01_01_swagger.png

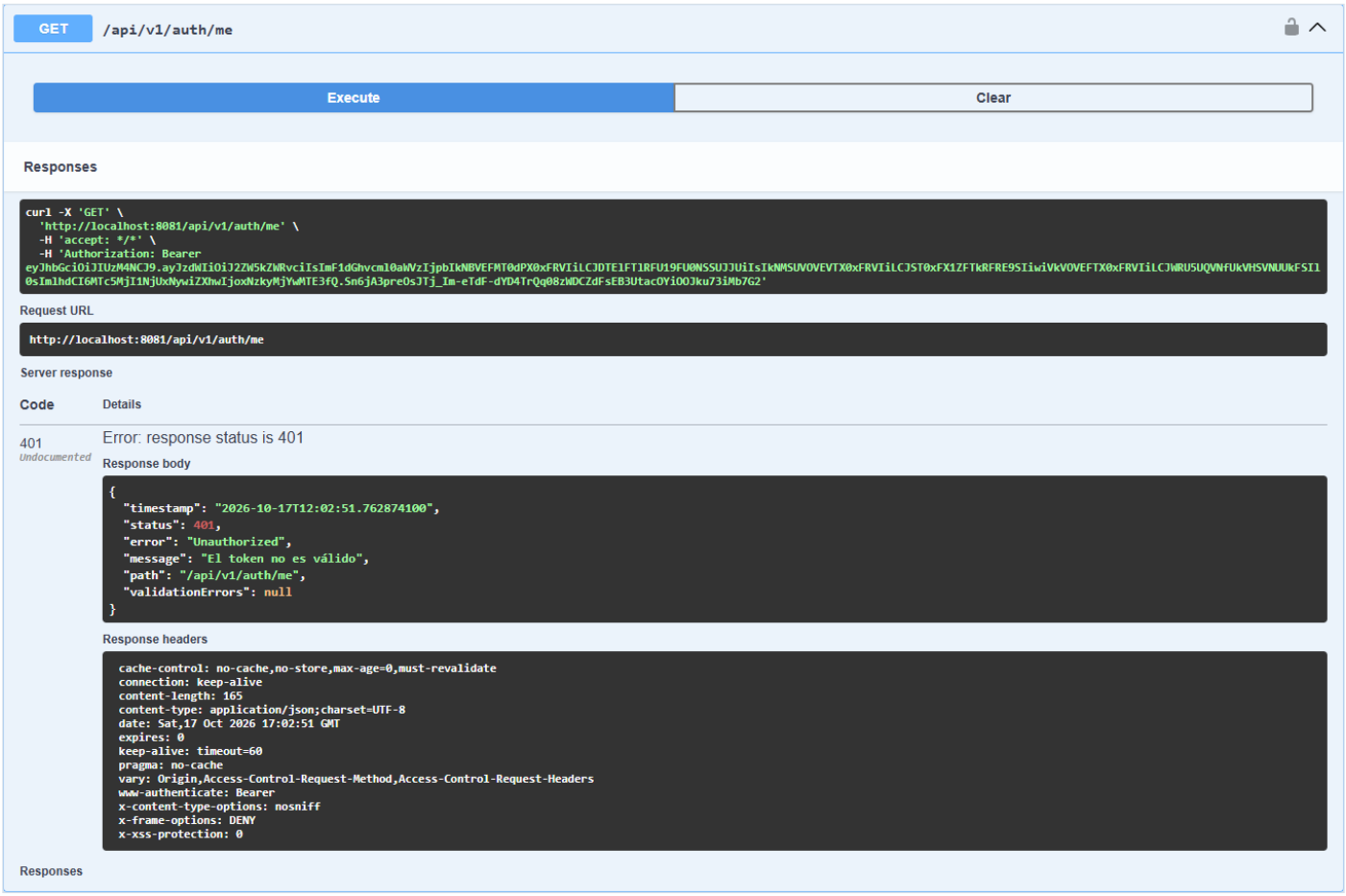
Payload alterado

Usuario / token: vendedor / Bearer

Petición: GET http://localhost:8081/api/v1/auth/me

Esperado: 401 - El token no es válido

Obtenido: 401 - El token no es válido



T-02_01_swagger.png

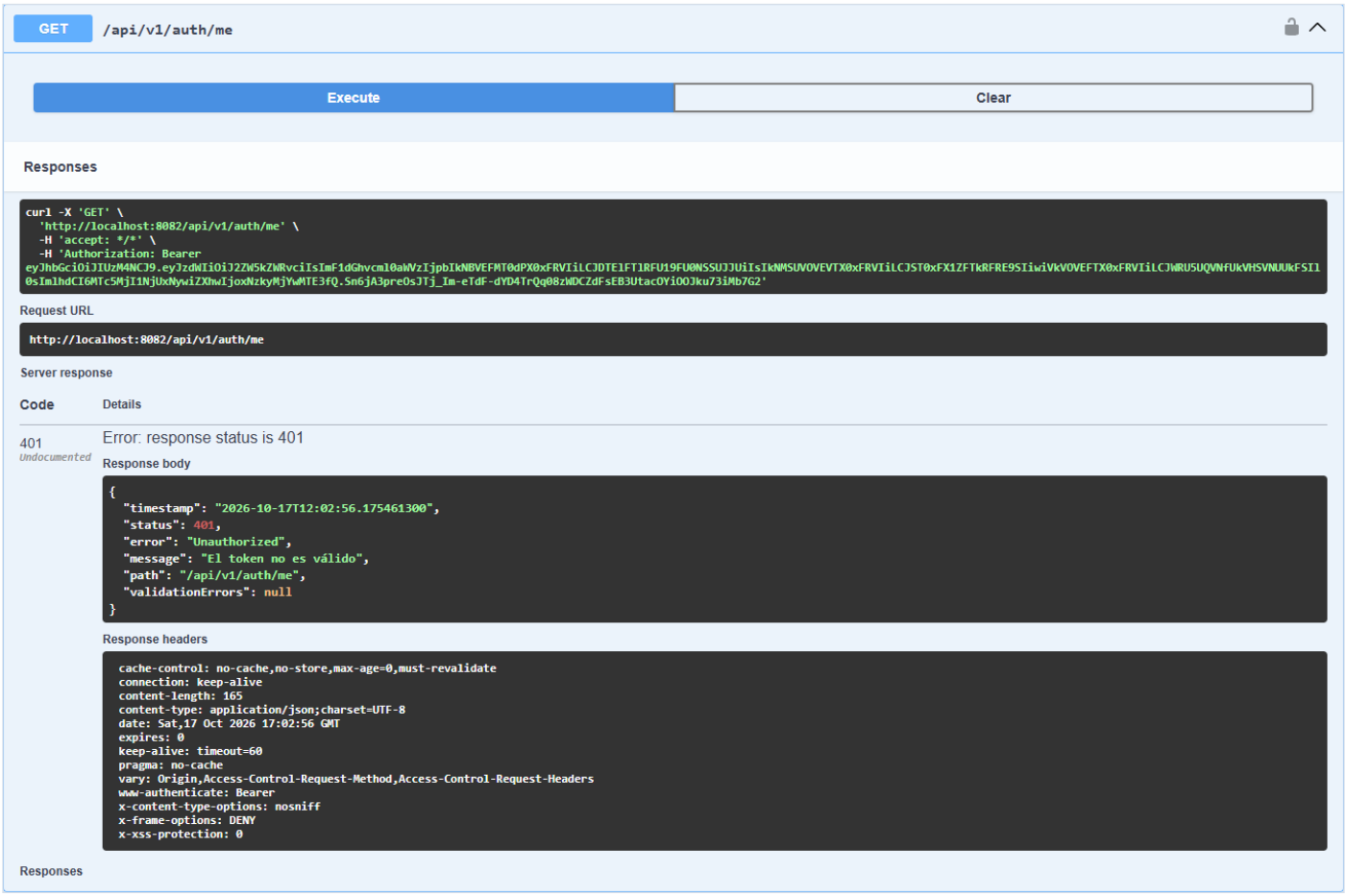
Firma de otra clave

Usuario / token: vendedor / Bearer

Petición: GET http://localhost:8082/api/v1/auth/me

Esperado: 401 - El token no es válido

Obtenido: 401 - El token no es válido



T-03_01_swagger.png

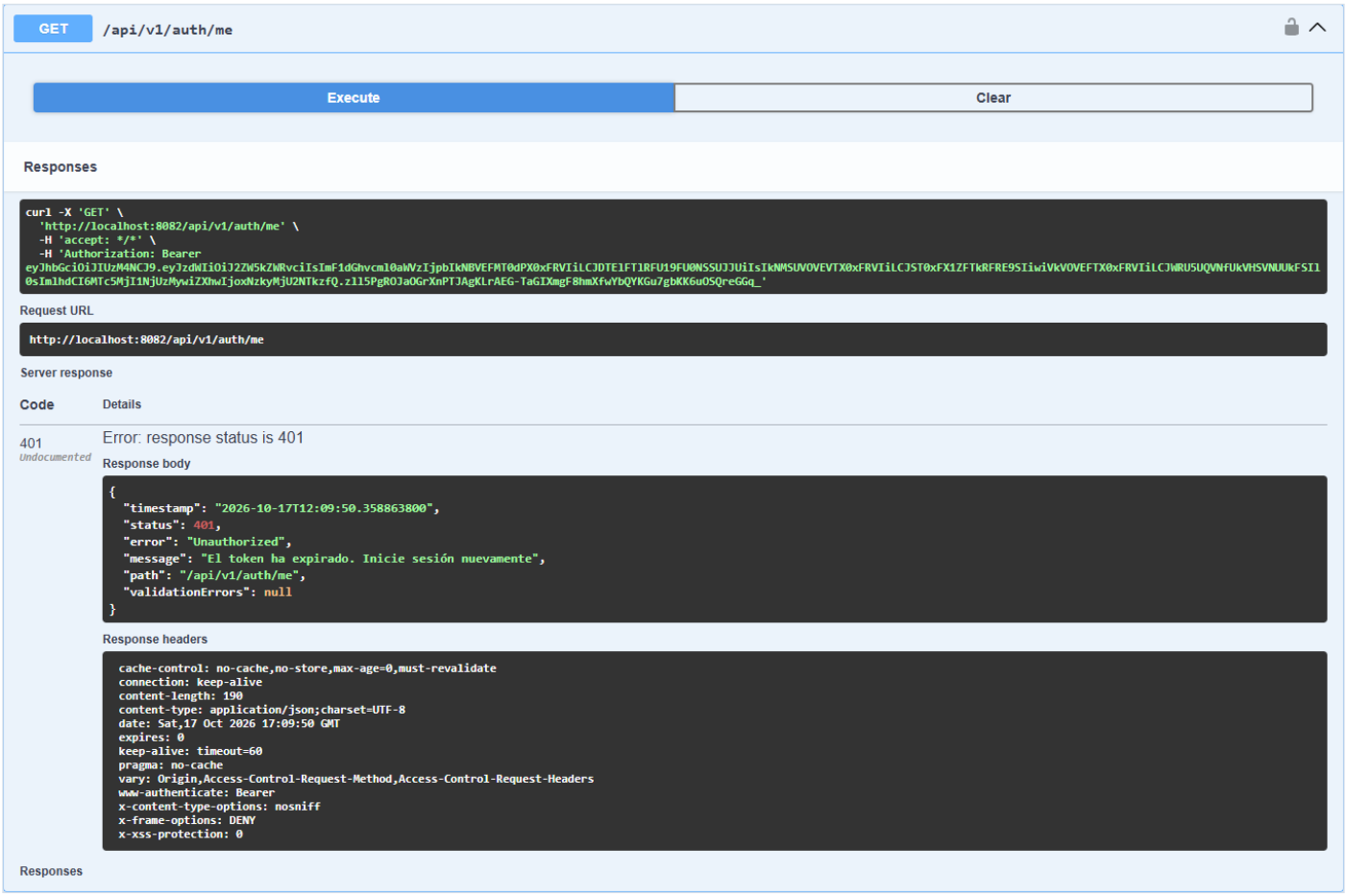
Token vencido tras un minuto real

Usuario / token: vendedor / Bearer

Petición: GET http://localhost:8082/api/v1/auth/me

Esperado: 401 - El token ha expirado

Obtenido: 401 - El token ha expirado. Inicie sesión nuevamente



T-04_01_swagger.png

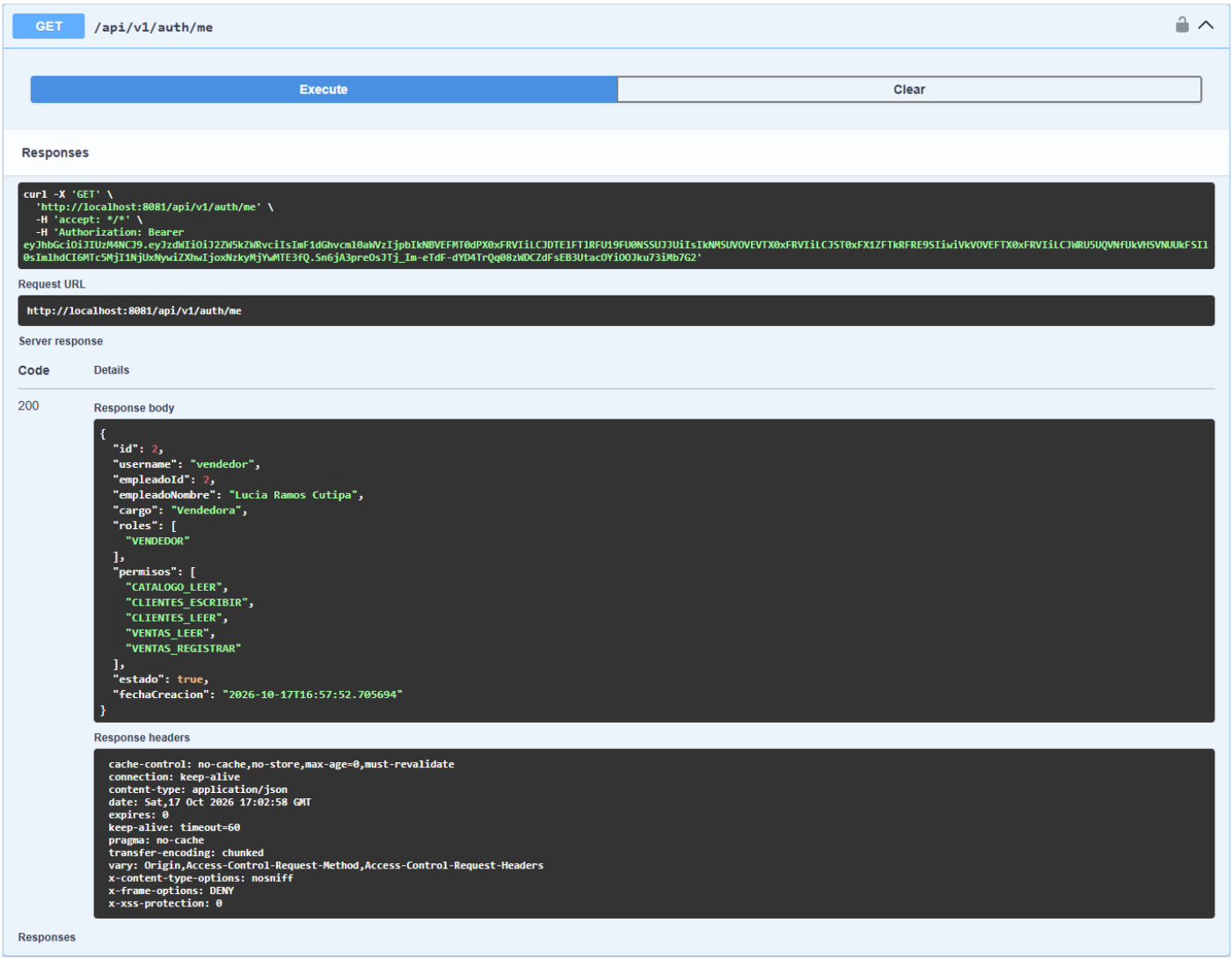
Identidad y claims comprobados

Usuario / token: vendedor / Bearer

Petición: GET http://localhost:8081/api/v1/auth/me

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - Usuario vendedor; roles VENDEDOR; respuesta sin contraseña



T-05_01_swagger.png

Contenido del payload JWT

Origen: decodificación del JWT emitido por la API.

{
"sub": "vendedor",
"authorities": [
"CATALOGO_LEER",
"CLIENTES_ESCRIBIR",
"CLIENTES_LEER",
"ROLE_VENDEDOR",
"VENTAS_LEER",
"VENTAS_REGISTRAR"
],
"iat": 1792256517,
"exp": 1792260117
}

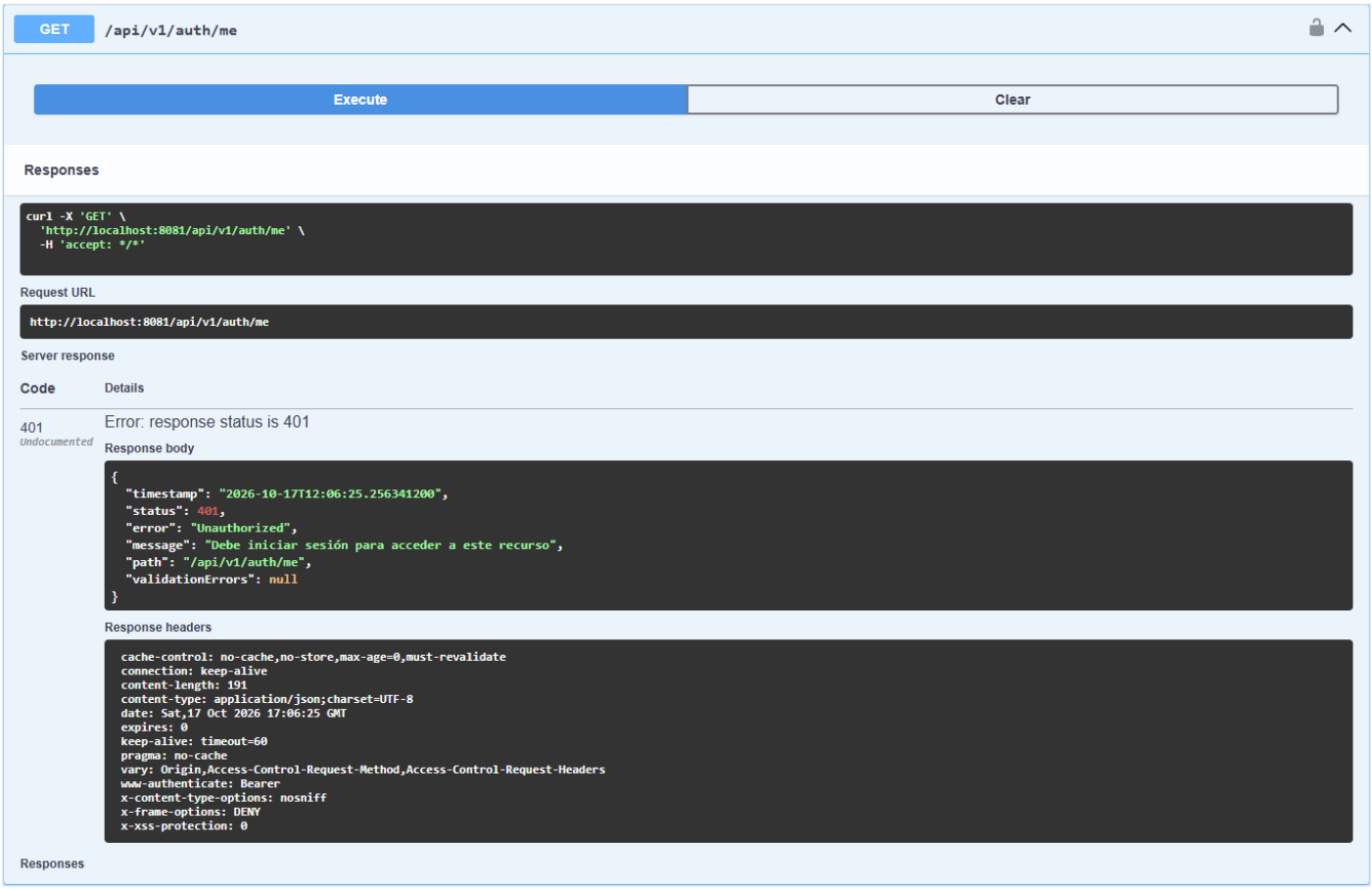
Propio: sin Authorization

Usuario / token: Anónimo / Ausente

Petición: GET http://localhost:8081/api/v1/auth/me

Esperado: 401 - Debe iniciar sesión

Obtenido: 401 - Debe iniciar sesión para acceder a este recurso



T-06_01_swagger.png

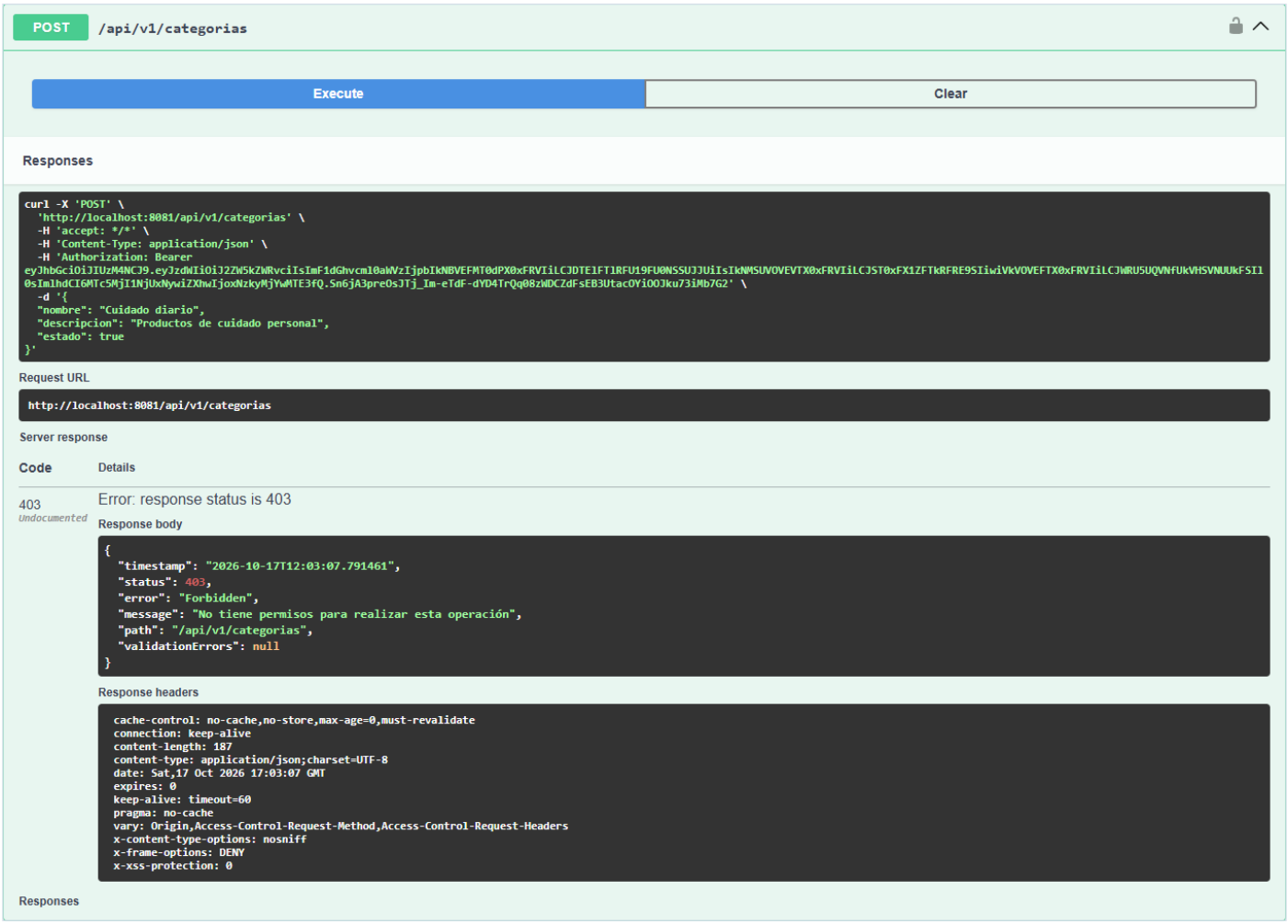
Vendedor POST categorías

Usuario / token: vendedor / Bearer

Petición: POST http://localhost:8081/api/v1/categorias

Esperado: 403 - No tiene permisos

Obtenido: 403 - No tiene permisos para realizar esta operación



P-01_01_swagger.png

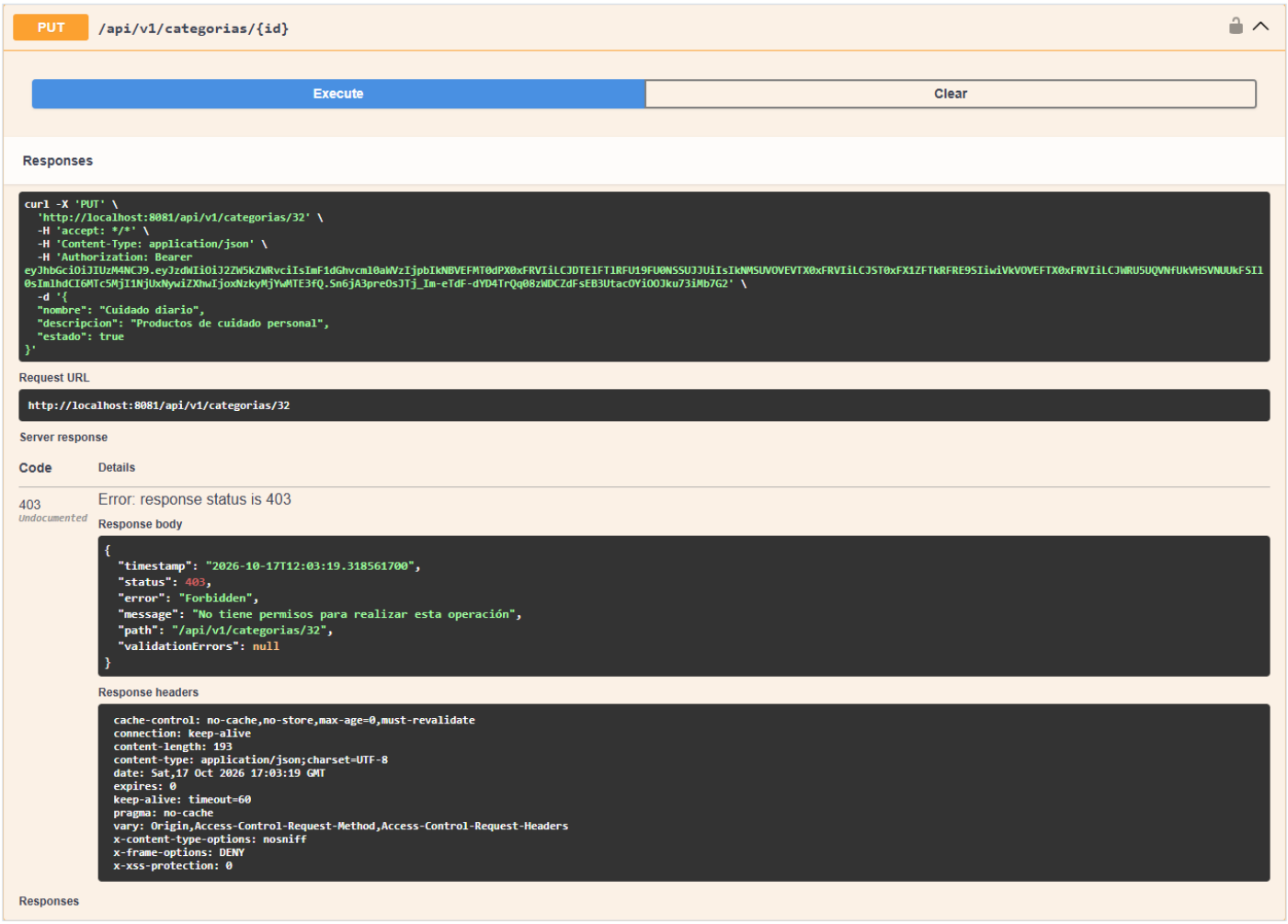
Vendedor PUT categorías

Usuario / token: vendedor / Bearer

Petición: PUT http://localhost:8081/api/v1/categorias/32

Esperado: 403 - No tiene permisos

Obtenido: 403 - No tiene permisos para realizar esta operación



P-01_02_swagger.png

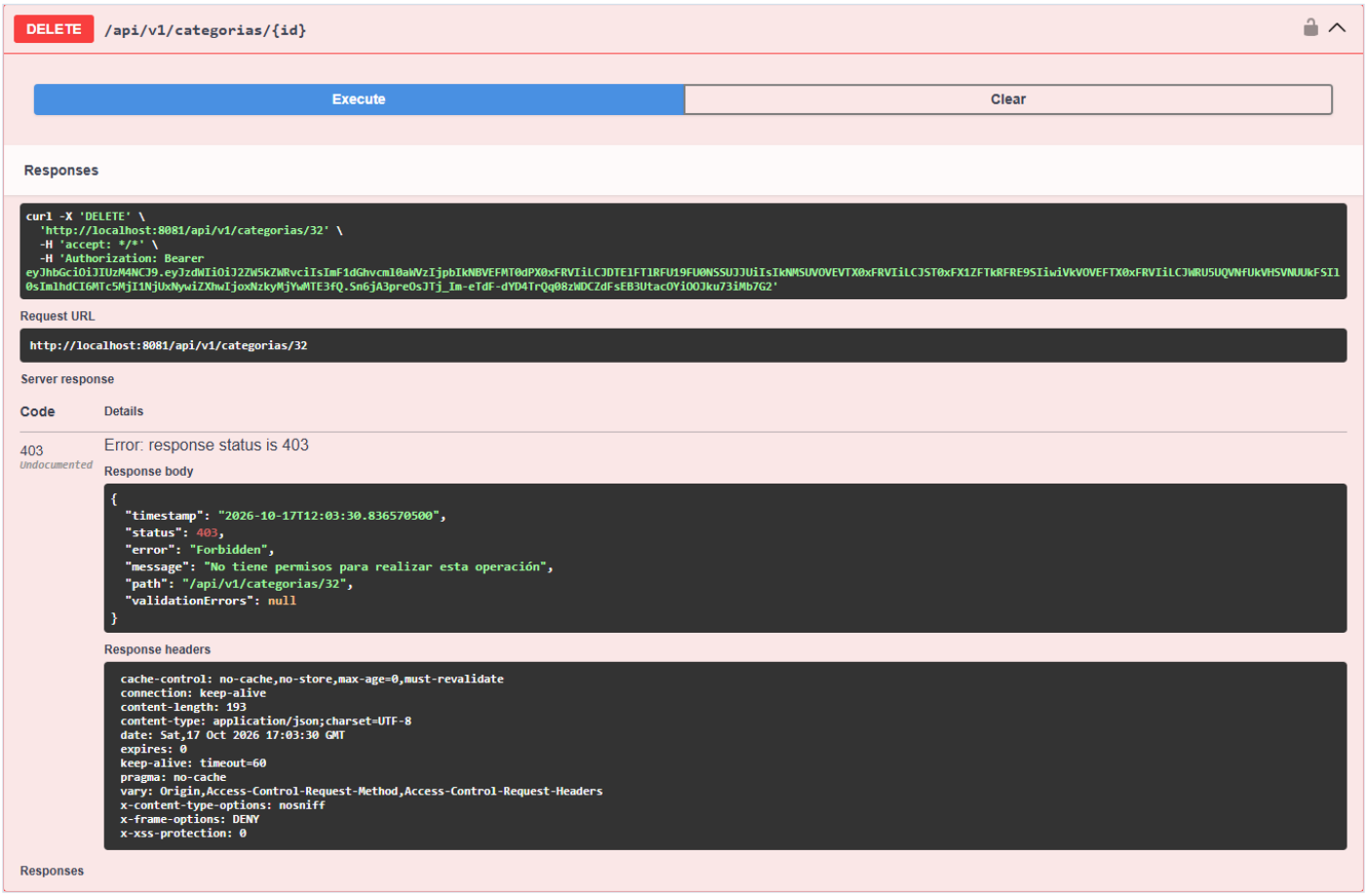
Vendedor DELETE categorías

Usuario / token: vendedor / Bearer

Petición: DELETE http://localhost:8081/api/v1/categorias/32

Esperado: 403 - No tiene permisos

Obtenido: 403 - No tiene permisos para realizar esta operación



P-01_03_swagger.png

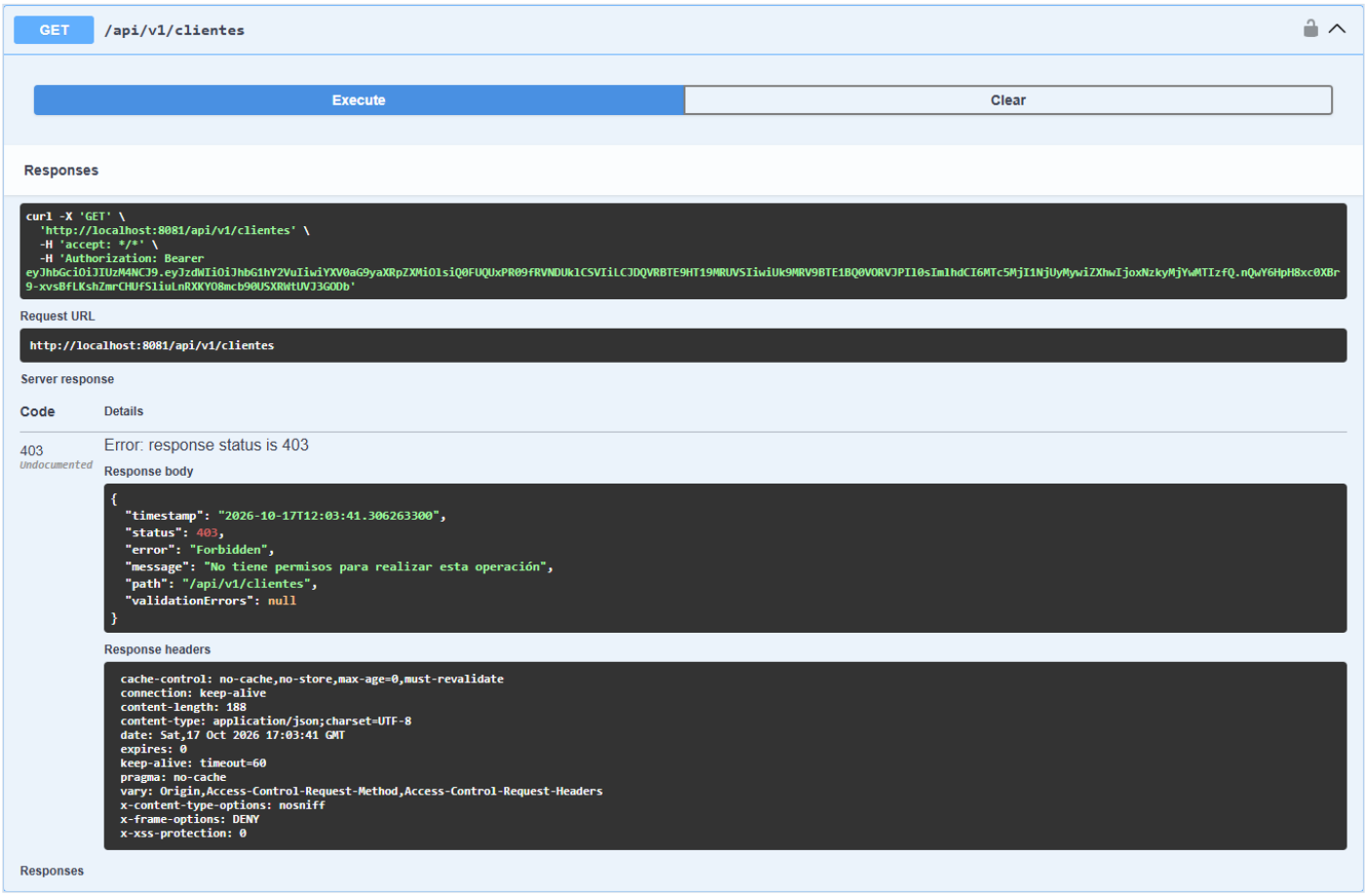
Almacén consulta clientes

Usuario / token: almacen / Bearer

Petición: GET http://localhost:8081/api/v1/clientes

Esperado: 403 - No tiene permisos

Obtenido: 403 - No tiene permisos para realizar esta operación



P-02_01_swagger.png

Almacén registra venta

Usuario / token: almacen / Bearer

Petición: POST http://localhost:8081/api/v1/ventas

Esperado: 403 - No tiene permisos

Obtenido: 403 - No tiene permisos para realizar esta operación

POST /api/v1/ventas

Execute | Clear

Responses

```
curl -X 'POST' \
  'http://localhost:8081/api/v1/ventas' \
  -H 'accept: */*' \
  -H 'Content-Type: application/json' \
  -H 'Authorization: Bearer
eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJhbG1hY2VuIiwiYXV0aG9yaXRpZXMiOlsiQ0FUQUxPR09fRVNDUklCSVIiLCJDQVRBTE9HT19MRUVSIiwiUk9MRV9BTE1BQ0VORVJPI10sImlhdCI6MTc5MjI1NjUyMywiZXhwIjoxNzkyMjYwMTIzfQ.nQwY6HpH8xc0XBr
9-xvsBflKshZmrCHUfSliuLnRXKYO8mcb90USXRWtUVJ3GODb' \
  -d '{
  "clienteId": 10,
  "detalles": [
    {
      "productoId": 17,
      "cantidad": 1
    }
  ]
}'
```

Request URL

```
http://localhost:8081/api/v1/ventas
```

Server response

Code	Details
403 *Undocumented*	Error: response status is 403

Response body

```
{
  "timestamp": "2026-10-17T12:03:50.787012900",
  "status": 403,
  "error": "Forbidden",
  "message": "No tiene permisos para realizar esta operación",
  "path": "/api/v1/ventas",
  "validationErrors": null
}
```

Response headers

```
cache-control: no-cache,no-store,max-age=0,must-revalidate
connection: keep-alive
content-length: 186
content-type: application/json;charset=UTF-8
date: Sat,17 Oct 2026 17:03:50 GMT
expires: 0
keep-alive: timeout=60
pragma: no-cache
vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers
x-content-type-options: nosniff
x-frame-options: DENY
x-xss-protection: 0
```

Responses

P-02_02_swagger.png

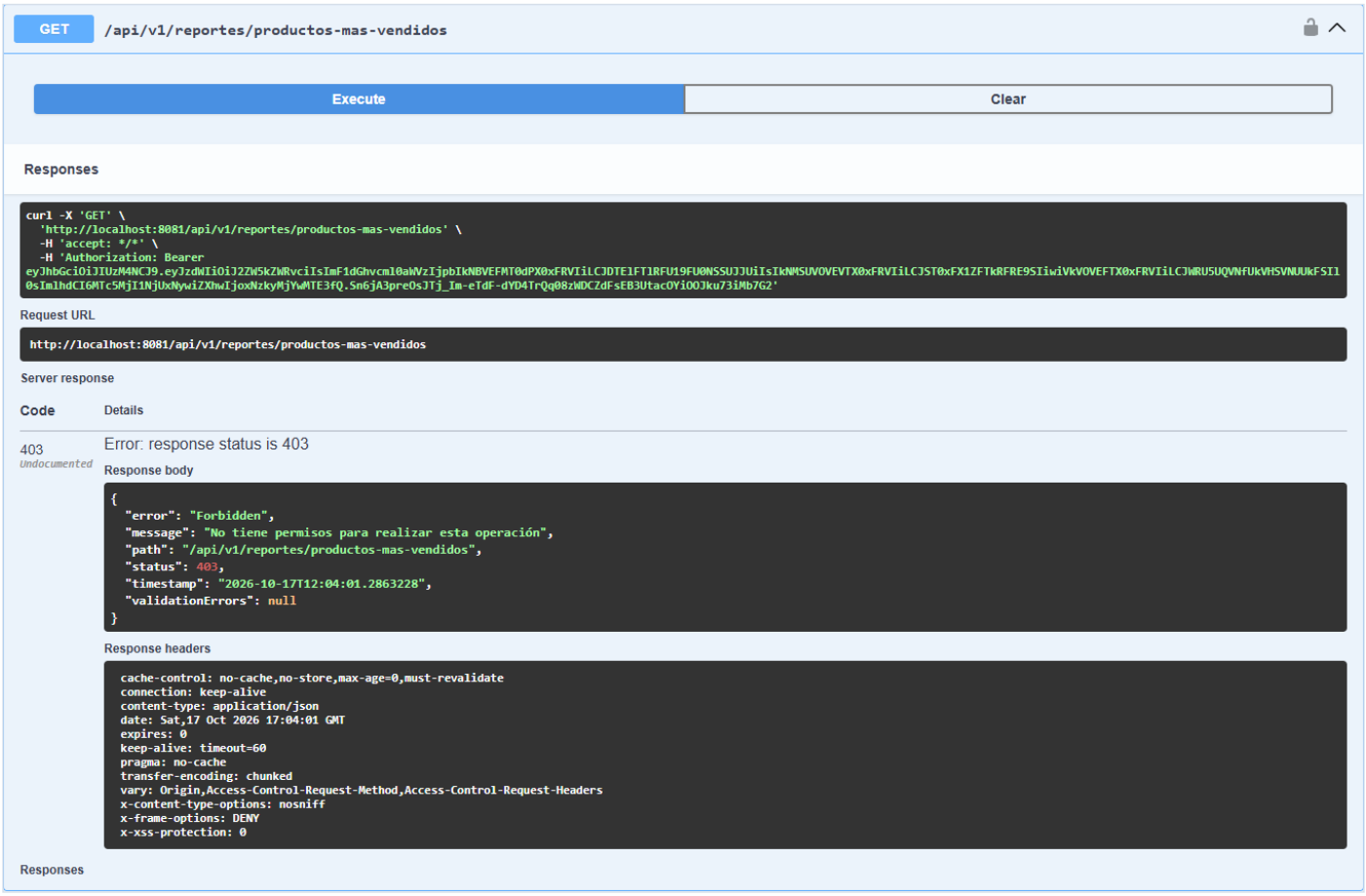
Reporte restringido vendedor

Usuario / token: vendedor / Bearer

Petición: GET http://localhost:8081/api/v1/reportes/productos-mas-vendidos

Esperado: 403 - No tiene permisos

Obtenido: 403 - No tiene permisos para realizar esta operación



P-03_01_swagger.png

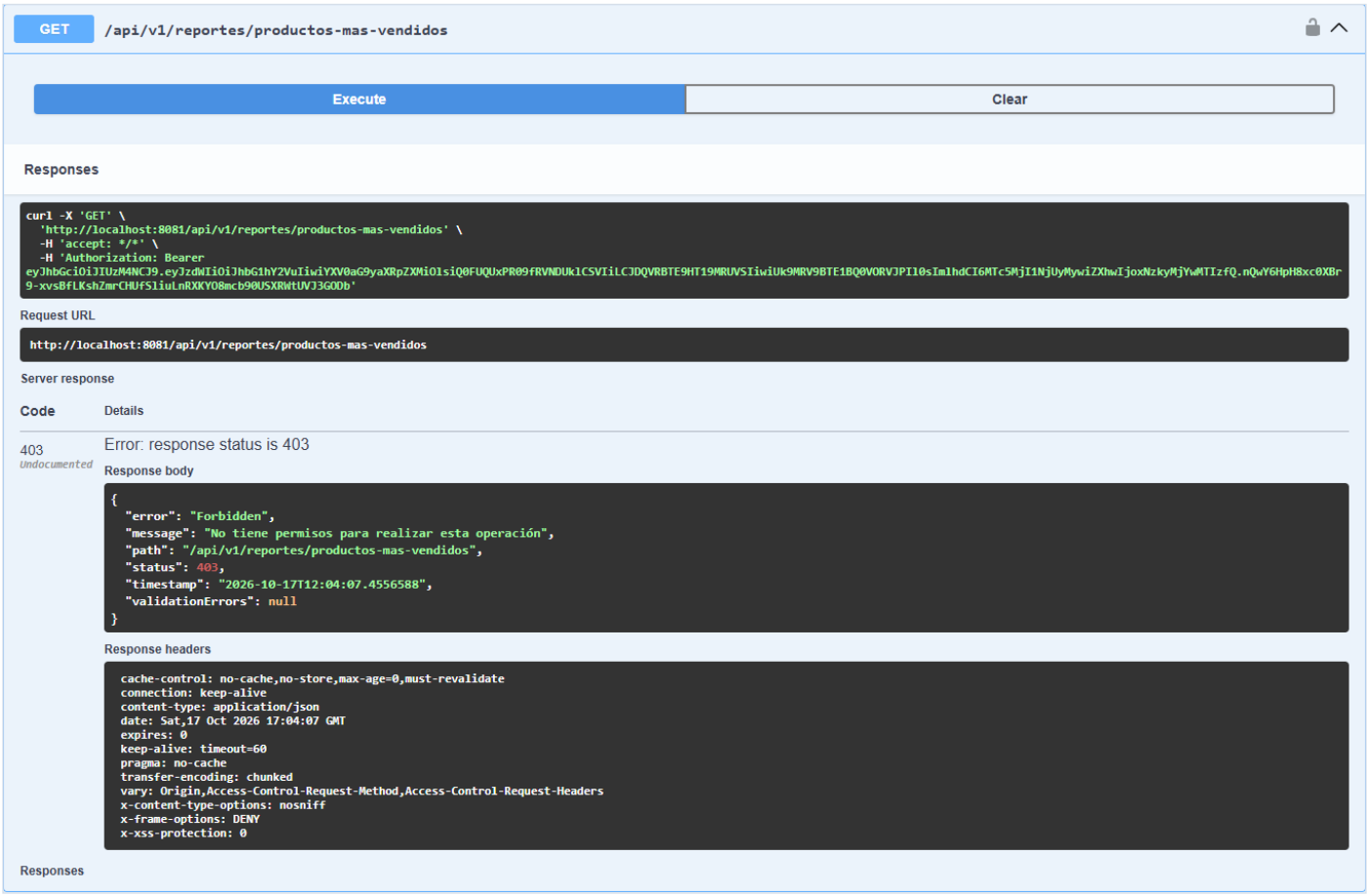
Reporte restringido almacen

Usuario / token: almacen / Bearer

Petición: GET http://localhost:8081/api/v1/reportes/productos-mas-vendidos

Esperado: 403 - No tiene permisos

Obtenido: 403 - No tiene permisos para realizar esta operación



P-03_02_swagger.png

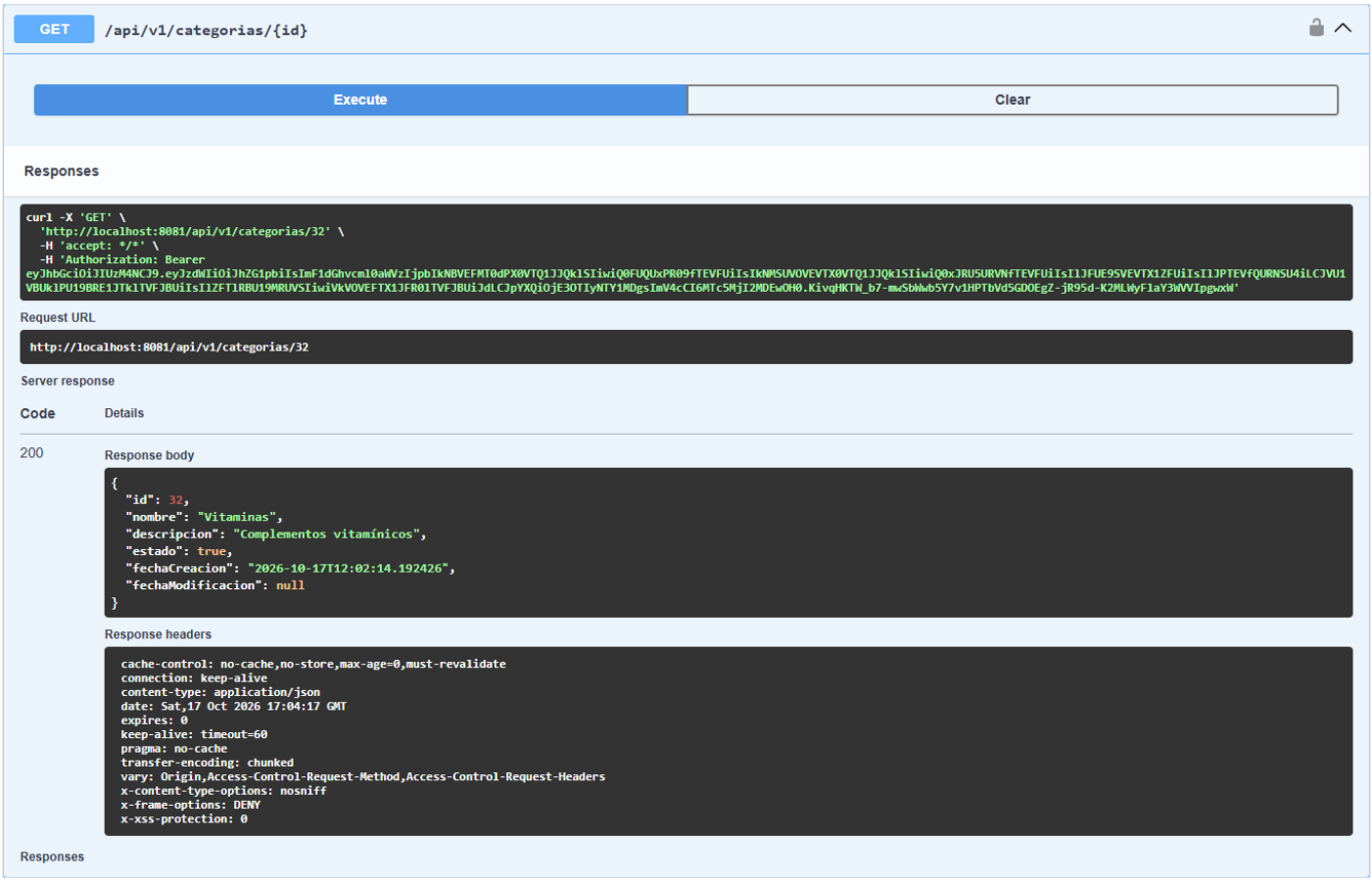
Admin categorias

Usuario / token: admin / Bearer

Petición: GET http://localhost:8081/api/v1/categorias/32

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - JSON correcto del módulo solicitado



P-04_01_swagger.png

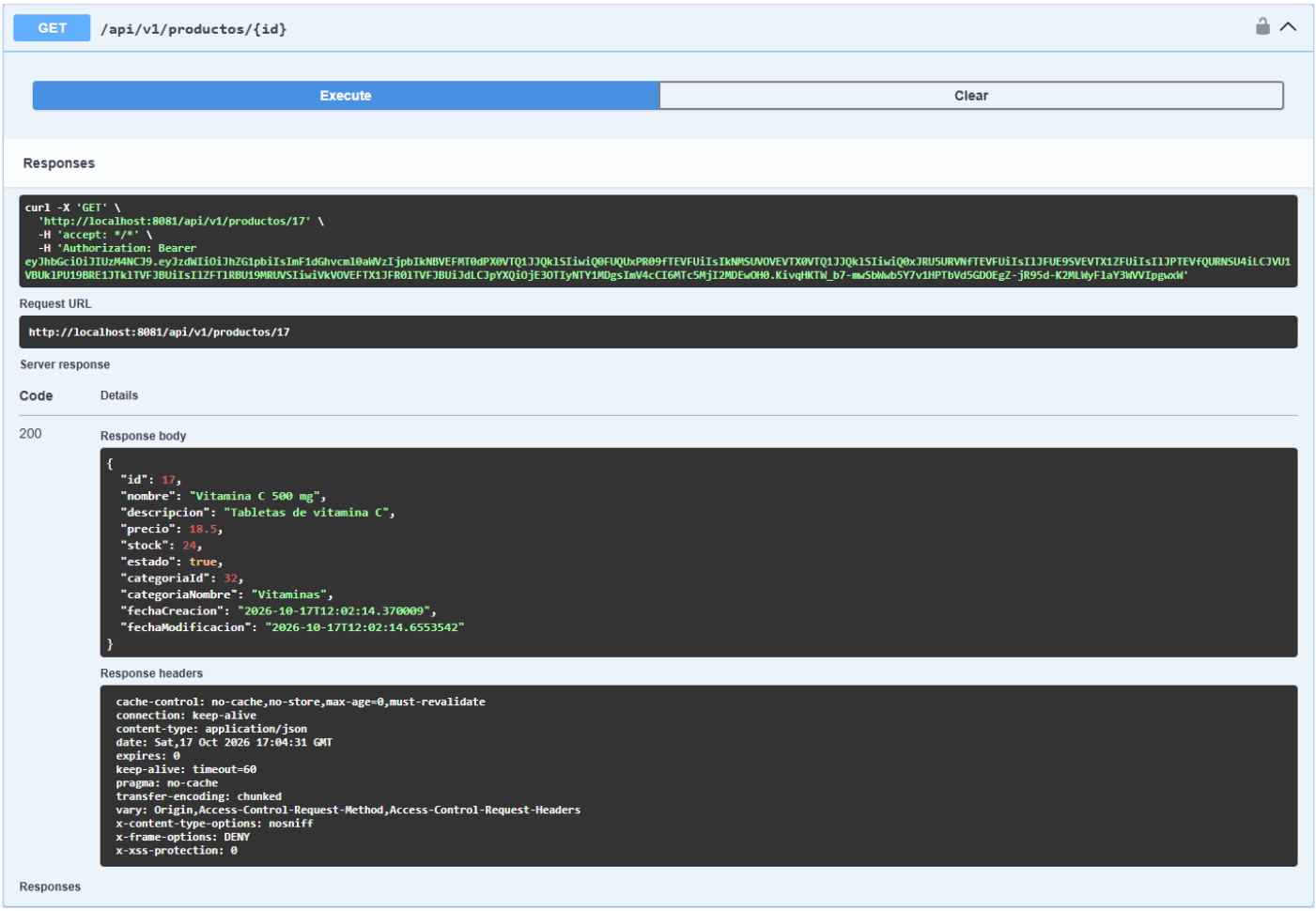
Admin productos

Usuario / token: admin / Bearer

Petición: GET http://localhost:8081/api/v1/productos/17

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - JSON correcto del módulo solicitado



P-04_02_swagger.png

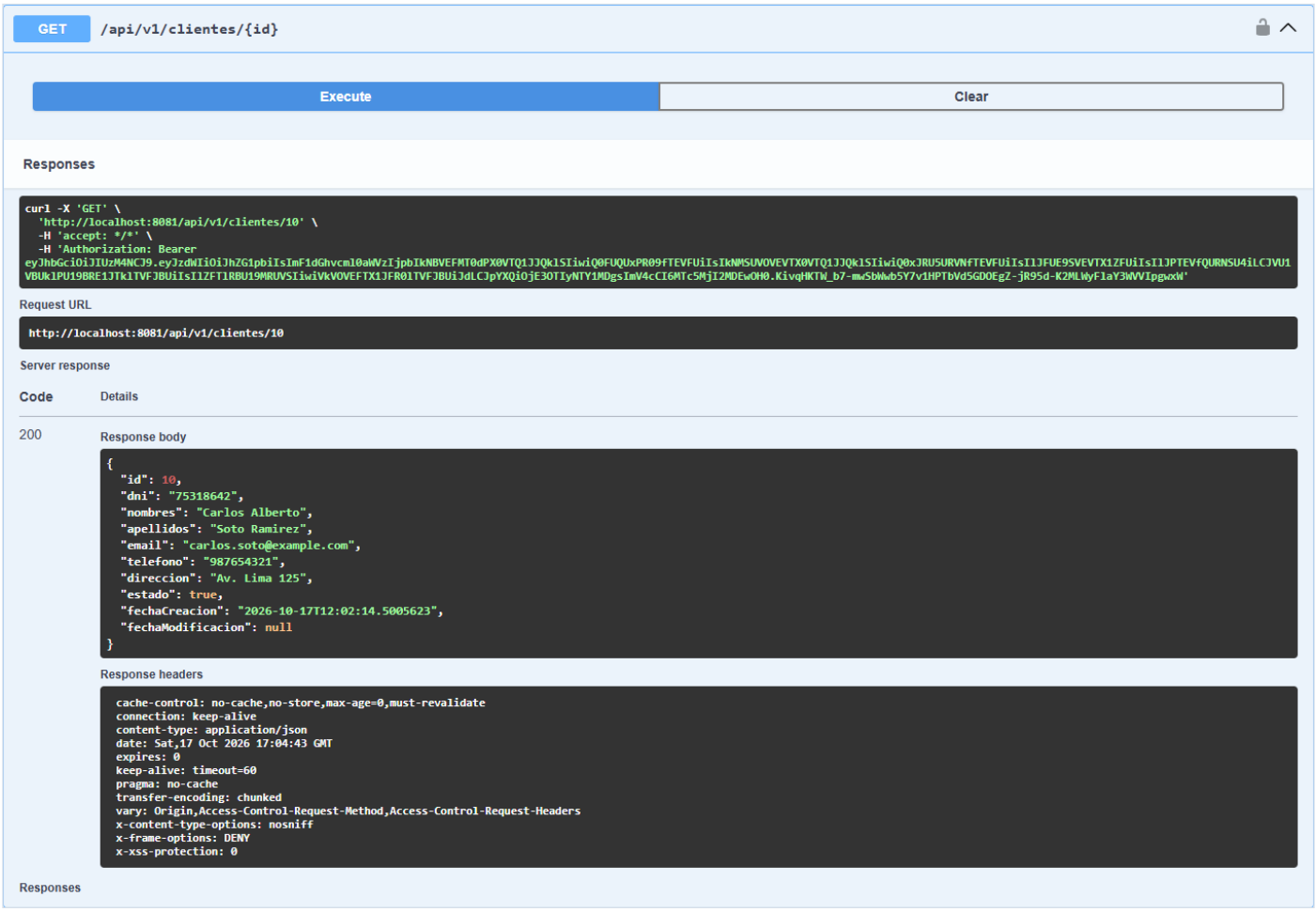
Admin clientes

Usuario / token: admin / Bearer

Petición: GET http://localhost:8081/api/v1/clientes/10

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - JSON correcto del módulo solicitado



P-04_03_swagger.png

Admin ventas

Usuario / token: admin / Bearer

Petición: GET http://localhost:8081/api/v1/ventas/16

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - JSON correcto del módulo solicitado

GET /api/v1/ventas/{id}

Execute Clear

Responses

```
curl -X 'GET' \
  'http://localhost:8081/api/v1/ventas/16' \
  -H 'accept: */*' \
  -H 'Authorization: Bearer
eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJhZG1pbiIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0VTQ1JJQk1SIiwiQ0FUQUxPR09fTEVFUiIsIkNMSUVOVEVTX0VTQ1JJQk1SIiwiQ0xJRU5URVNfTEVFUiIsIlJFUE9SVEVTX1ZFUiIsIlJPTEVfQURNSU4iLCJVU1
VBUklPU19BRE1JTklfIlZFT1RBU19MRUVSIiwiVkVOVEFTX1JFR01TVFJBUiJdLCJpYXQiOjE3OTIyNTY1MDgsImV4cCI6MTc5MjI2MDEwOH0.KivqHKTW_b7-mw5bWwb5Y7v1HPTbVd5GDOEgZ-jR95d-K2MLWyFlaY3WVVIpgwxW'
```

Request URL

```
http://localhost:8081/api/v1/ventas/16
```

Server response

Code	Details
200	Response body


```
{
  "id": 16,
  "fechaRegistro": "2026-10-17T12:02:14.617523",
  "clienteId": 10,
  "clienteNombre": "Carlos Alberto Soto Ramirez",
  "estado": "REGISTRADA",
  "total": 18.5,
  "detalles": [
    {
      "productoId": 17,
      "productoNombre": "Vitamina C 500 mg",
      "cantidad": 1,
      "precio": 18.5,
      "subtotal": 18.5
    }
  ]
}
```


Response headers

```
cache-control: no-cache,no-store,max-age=0,must-revalidate
connection: keep-alive
content-type: application/json
date: Sat,17 Oct 2026 17:04:54 GMT
expires: 0
keep-alive: timeout=60
pragma: no-cache
transfer-encoding: chunked
vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers
x-content-type-options: nosniff
x-frame-options: DENY
x-xss-protection: 0
```

Responses

P-04_04_swagger.png

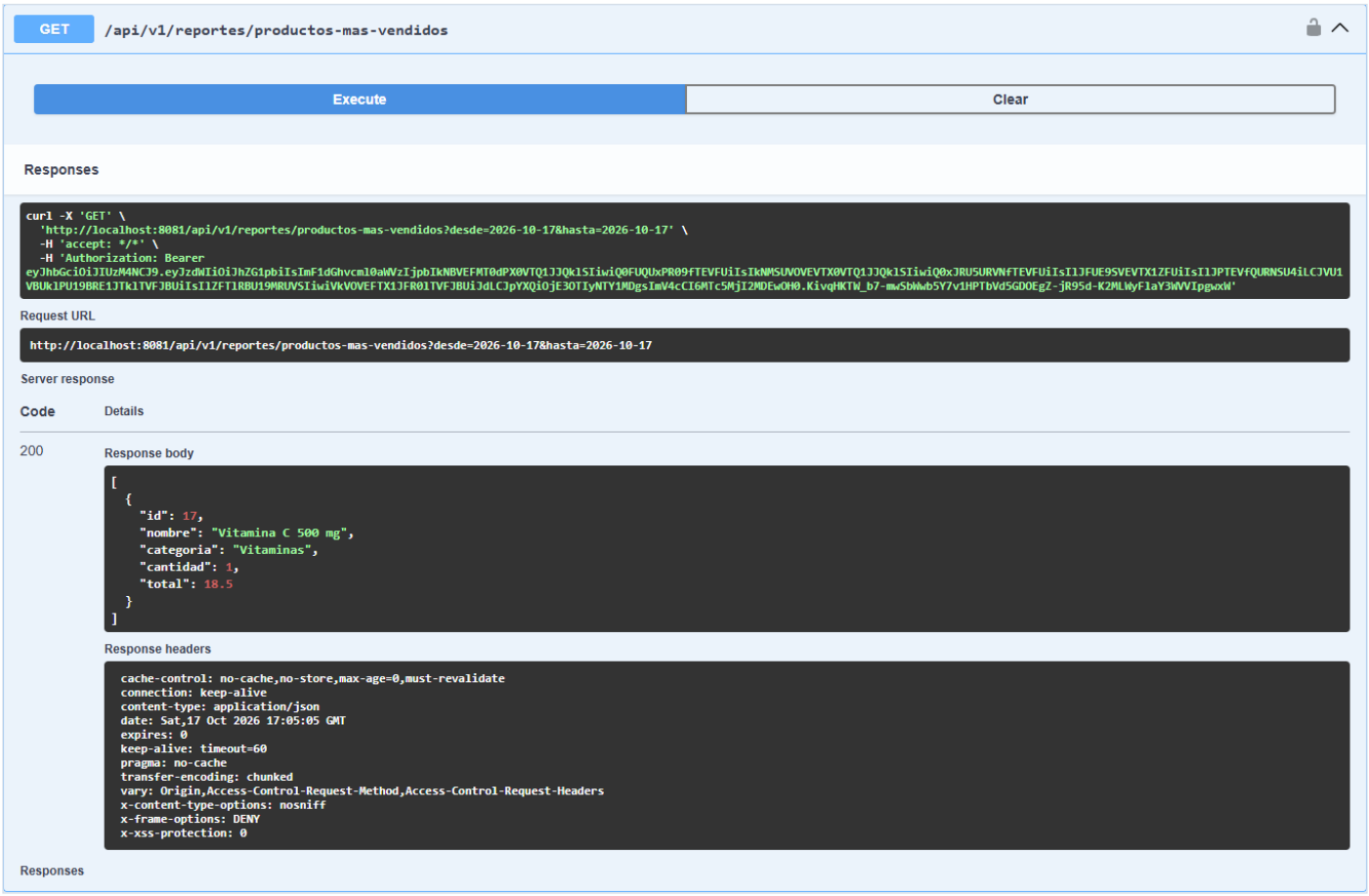
Admin reportes

Usuario / token: admin / Bearer

Petición: GET http://localhost:8081/api/v1/reportes/productos-mas-vendidos?desde=2026-10-17&hasta=2026-10-17

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - JSON correcto del módulo solicitado



P-04_05_swagger.png

Admin usuarios

Usuario / token: admin / Bearer

Petición: GET http://localhost:8081/api/v1/usuarios

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - JSON correcto del módulo solicitado

GET /api/v1/usuarios

Execute Clear

Responses

```
curl -X 'GET' \
  'http://localhost:8081/api/v1/usuarios' \
  -H 'accept: */*' \
  -H 'Authorization: Bearer
eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJhZG1pbiIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0VTQ1JJQk1SIiwiQ0FUQUxPR09fTEVFUiIsIkNMSUVOVEVTX0VTQ1JJQk1SIiwiQ0xJRU5URVNfTEVFUiIsIlJFUE9SVEVTX1ZFUiIsIlJPTEVfQURNSU4iLCJVU1
VBUk1PU19BRE1JTk1TVFJBUiIsIlZFT1RBU19MRUVSIiwiVkVOVEFTX1JFR01TVFJBUiJdLCJpYXQiOjE3OTIyNTY1MDgsImV4cCI6MTc5MjI2MDEwOH0.KivqHKTW_b7-mw5bWwb5Y7v1HPTbVd5GDOEgZ-jR95d-K2MLWyFlaY3WVVIpgwxW'
```

Request URL

```
http://localhost:8081/api/v1/usuarios
```

Server response

Code	Details
200	Response body


```
[
  {
    "id": 1,
    "username": "admin",
    "empleadoId": 1,
    "empleadoNombre": "Rosa Elena Mendoza Ticona",
    "cargo": "Administradora",
    "roles": [
      "ADMIN"
    ],
    "permisos": [
      "CATALOGO_ESCRIBIR",
      "CATALOGO_LEER",
      "CLIENTES_ESCRIBIR",
      "CLIENTES_LEER",
      "REPORTES_VER",
      "USUARIOS_ADMINISTRAR",
      "VENTAS_LEER",
      "VENTAS_REGISTRAR"
    ],
    "estado": true,
    "fechaCreacion": "2026-10-17T16:57:52.697778"
  },
  {
    "id": 3,
    "username": "almacen",
    "empleadoId": 3,
    "empleadoNombre": "Pedro Quispe Mamani",
    "cargo": "Almacenero",
    "roles": [
      "ALMACENERO"
    ],
    "permisos": [
      "CATALOGO_ESCRIBIR",
      "CATALOGO_LEER"
    ],
    "estado": true,
    "fechaCreacion": "2026-10-17T16:57:52.71207"
  },
  {
    "id": 5,
    "username": "inactivo",
    "empleadoId": 5,
    "empleadoNombre": "Jorge Apaza Huanca",
    "cargo": "Vendedor",
    "roles": [
      "VENDEDOR"
    ],
    "permisos": [
      "CATALOGO_LEER",
      "CLIENTES_ESCRIBIR",
      "CLIENTES_LEER",
      "VENTAS_LEER",
      "VENTAS_REGISTRAR"
    ],
    "estado": false,
    "fechaCreacion": "2026-10-17T16:57:52.724752"
  },
  {
    "id": 4,
    "username": "supervisor",
    "empleadoId": 4,
    "empleadoNombre": "Ana Torres Vilca",
    "cargo": "Jefa de tienda",
    "roles": [
      "ALMACENERO"
```

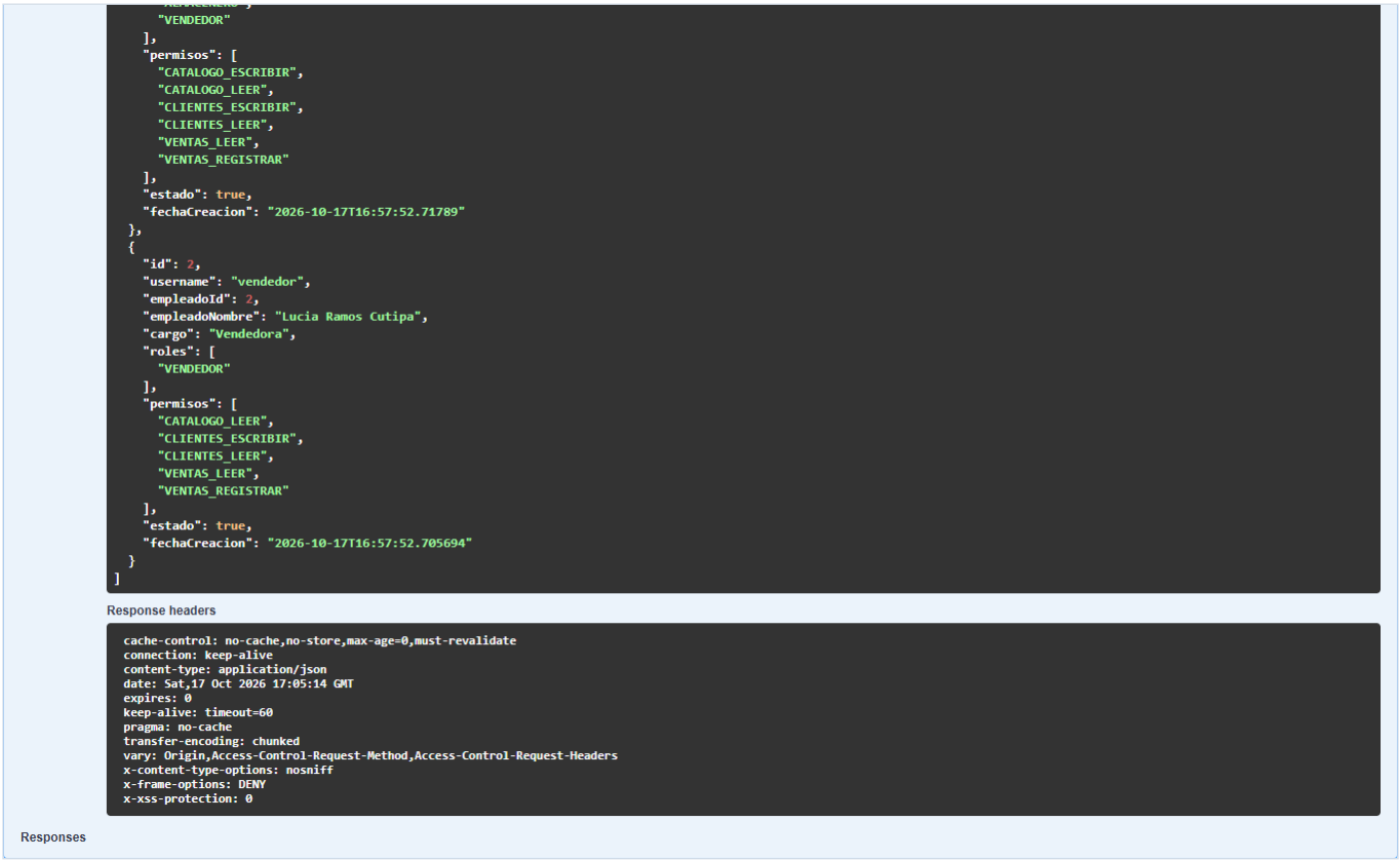

P-04_06_swagger.png - fragmento 1

Admin usuarios

Usuario / token: admin / Bearer

Petición: GET http://localhost:8081/api/v1/usuarios

Continuación de la misma captura original; la petición y el resultado corresponden a la ficha anterior.



P-04_06_swagger.png - fragmento 2

Admin empleados

Usuario / token: admin / Bearer

Petición: GET http://localhost:8081/api/v1/empleados

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - JSON correcto del módulo solicitado

GET /api/v1/empleados

Execute Clear

Responses

```
curl -X 'GET' \
  'http://localhost:8081/api/v1/empleados' \
  -H 'accept: */*' \
  -H 'Authorization: Bearer
eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJhZG1pbiIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0VTQ1JJQk1SIiwiQ0FUQUxPR09fTEVFUiIsIkNMSUVOVEVTX0VTQ1JJQk1SIiwiQ0xJRU5URVNfTEVFUiIsIlJFUE9SVEVTX1ZFUiIsIlJPTEVfQURNSU4iLCJVU1
VBUk1PU19BRE1JTk1VTFJBUiIsIlZFT1RBU19MRUVSIiwiVkVOVEFTX1JFR01TVFJBUiJdLCJpYXQiOjE3OTIyNTY1MDgsImV4cCI6MTc5MjI2MDEwOH0.KivqHKTW_b7-mw5bWwb5Y7v1HPTbVd5GDOEgZ-jR95d-K2MLWyFlaY3WVVIpgwxW'
```

Request URL

```
http://localhost:8081/api/v1/empleados
```

Server response

Code	Details
200	Response body


```
[
  {
    "id": 5,
    "dni": "44556677",
    "nombres": "Jorge",
    "apellidos": "Apaza Huanca",
    "cargo": "Vendedor",
    "email": "japaza@pharmasoft.pe",
    "telefono": null,
    "estado": true,
    "tieneUsuario": true
  },
  {
    "id": 6,
    "dni": "45667788",
    "nombres": "Maria",
    "apellidos": "Huaman Torres",
    "cargo": "Cajera",
    "email": "mhuaman@pharmasoft.pe",
    "telefono": null,
    "estado": true,
    "tieneUsuario": false
  },
  {
    "id": 1,
    "dni": "40112233",
    "nombres": "Rosa Elena",
    "apellidos": "Mendoza Ticona",
    "cargo": "Administradora",
    "email": "rmendoza@pharmasoft.pe",
    "telefono": "951000111",
    "estado": true,
    "tieneUsuario": true
  },
  {
    "id": 3,
    "dni": "42334455",
    "nombres": "Pedro",
    "apellidos": "Quispe Mamani",
    "cargo": "Almacenero",
    "email": "pquispe@pharmasoft.pe",
    "telefono": null,
    "estado": true,
    "tieneUsuario": true
  },
  {
    "id": 2,
    "dni": "41223344",
    "nombres": "Lucia",
    "apellidos": "Ramos Cutipa",
    "cargo": "Vendedora",
    "email": "lramos@pharmasoft.pe",
    "telefono": "951000222",
    "estado": true,
    "tieneUsuario": true
  },
  {
    "id": 4,
    "dni": "43445566",
    "nombres": "Ana",
    "apellidos": "Torres Vilca",
    "cargo": "Jefa de tienda",
    "email": "atorres@pharmasoft.pe",
    "telefono": "951000444",
    "estado": true,
```

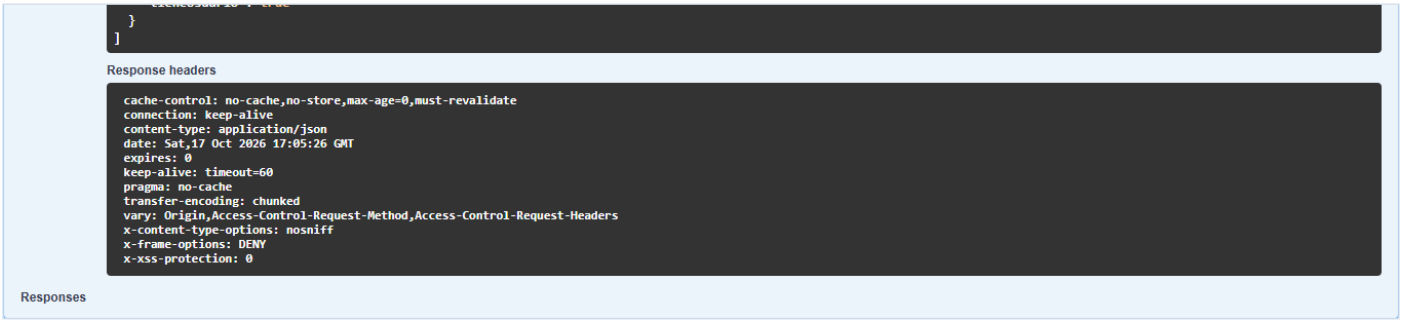

P-04_07_swagger.png - fragmento 1

Admin empleados

Usuario / token: admin / Bearer

Petición: GET http://localhost:8081/api/v1/empleados

Continuación de la misma captura original; la petición y el resultado corresponden a la ficha anterior.



P-04_07_swagger.png - fragmento 2

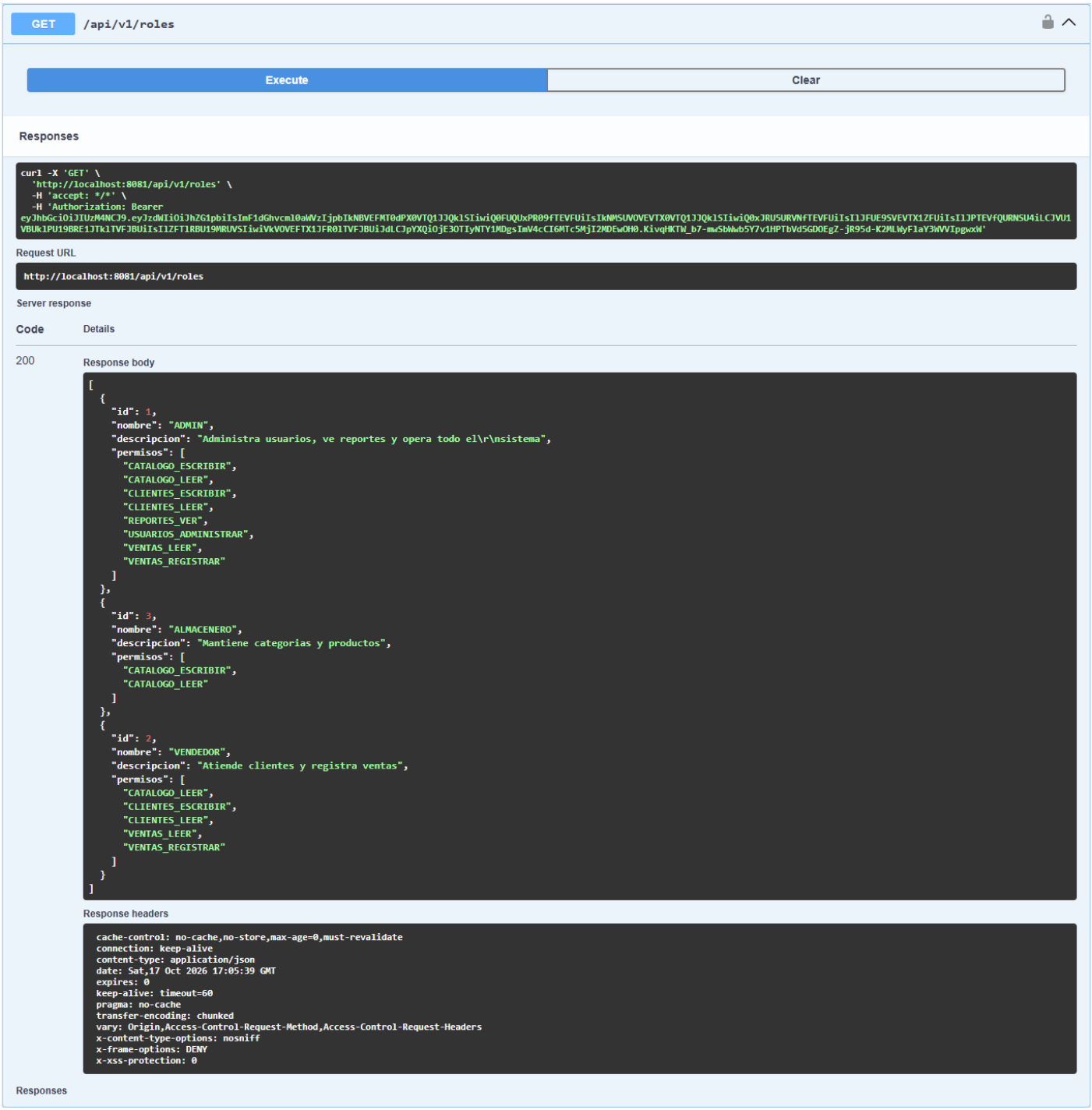
Admin roles

Usuario / token: admin / Bearer

Petición: GET http://localhost:8081/api/v1/roles

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - JSON correcto del módulo solicitado



P-04_08_swagger.png

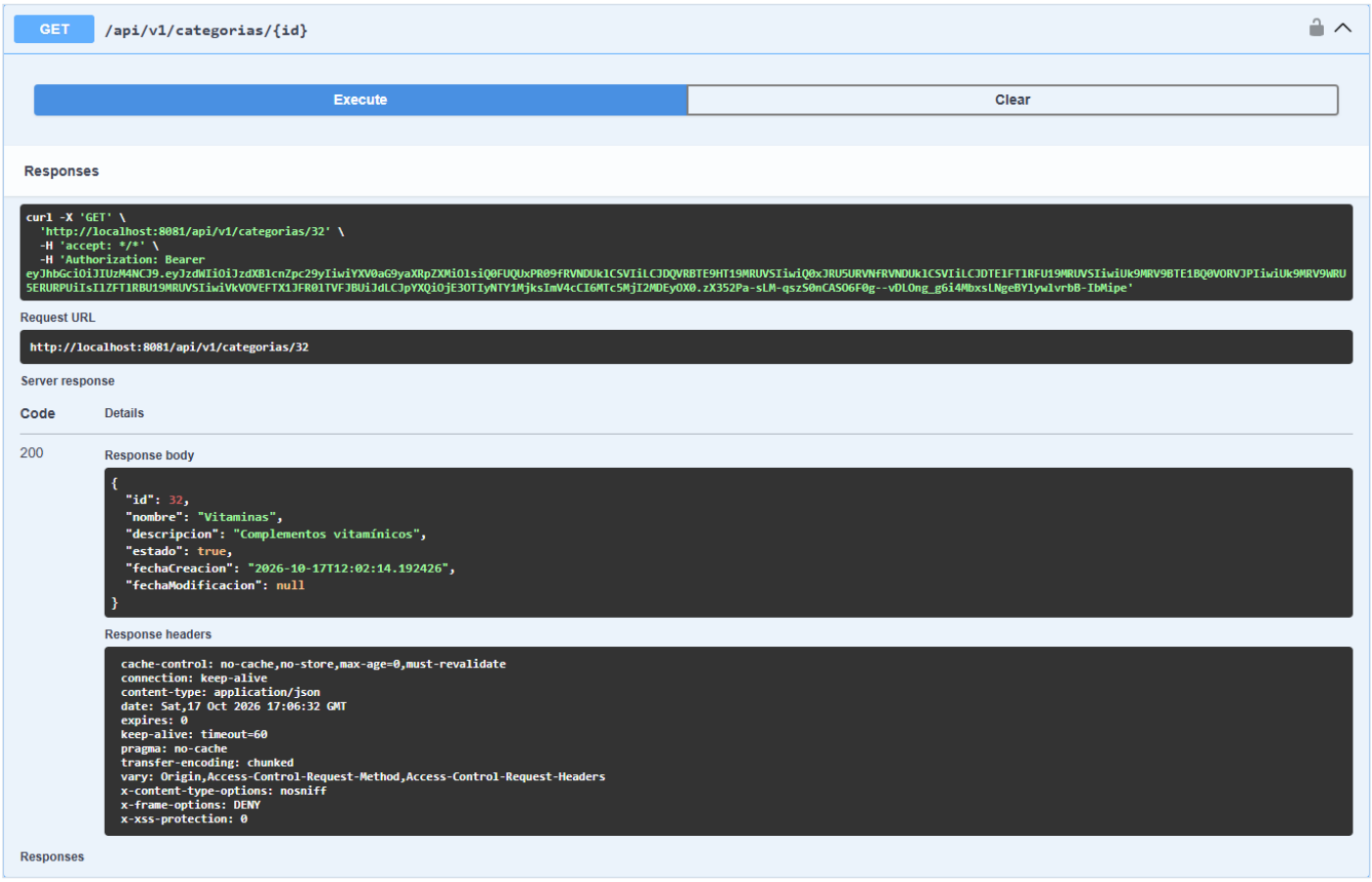
Propio: unión de permisos supervisor

Usuario / token: supervisor / Bearer

Petición: GET http://localhost:8081/api/v1/categorias/32

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - JSON correcto del módulo solicitado



P-05_01_swagger.png

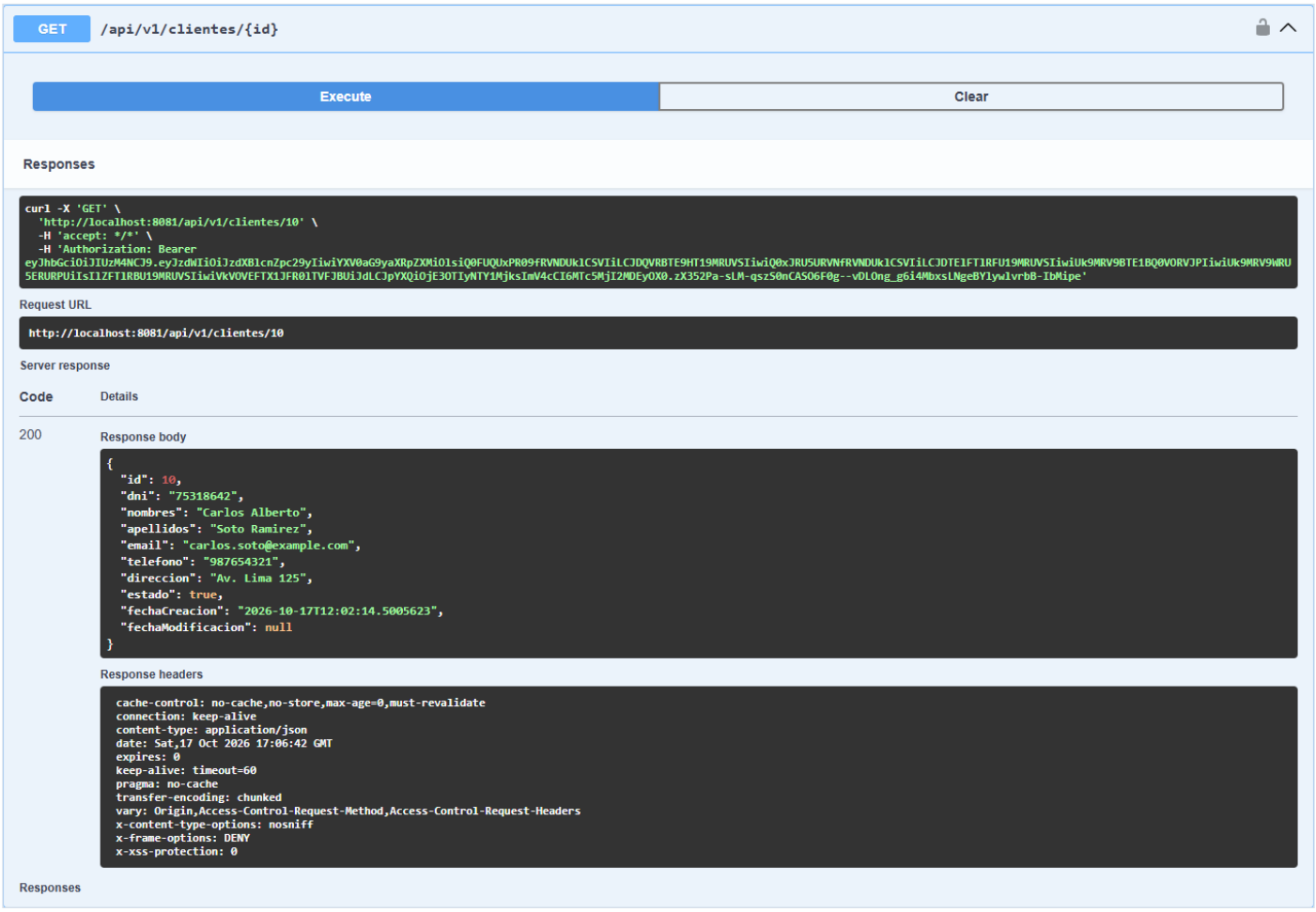
Propio: unión de permisos supervisor

Usuario / token: supervisor / Bearer

Petición: GET http://localhost:8081/api/v1/clientes/10

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - JSON correcto del módulo solicitado



P-05_02_swagger.png

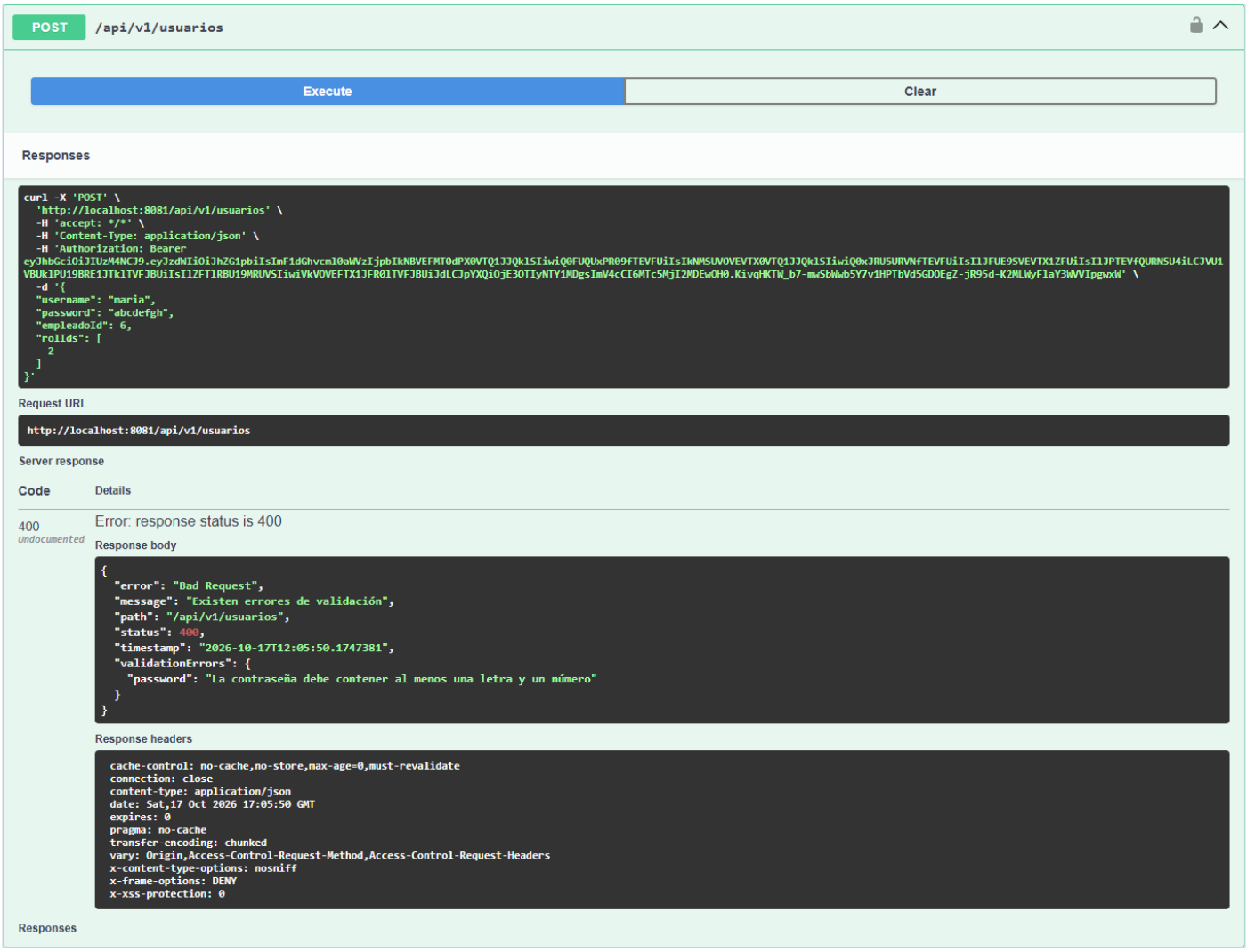
Contraseña sin número

Usuario / token: admin / Bearer

Petición: POST http://localhost:8081/api/v1/usuarios

Esperado: 400 - número

Obtenido: 400 - Existen errores de validación / La contraseña debe contener al menos una letra y un número



U-01_01_swagger.png

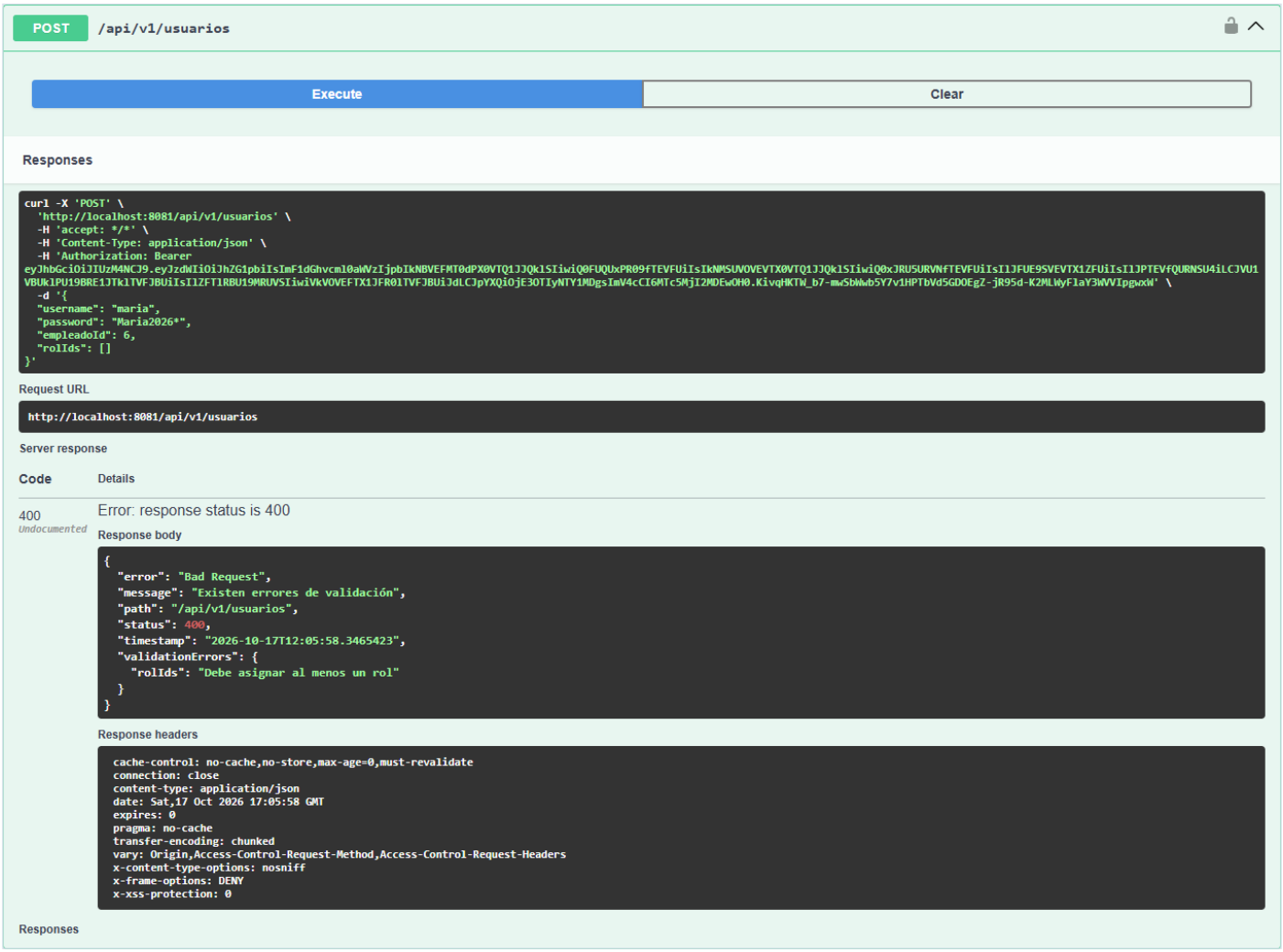
Roles vacíos al crear

Usuario / token: admin / Bearer

Petición: POST http://localhost:8081/api/v1/usuarios

Esperado: 400 - Debe asignar

Obtenido: 400 - Existen errores de validación / Debe asignar al menos un rol



U-01_02_swagger.png

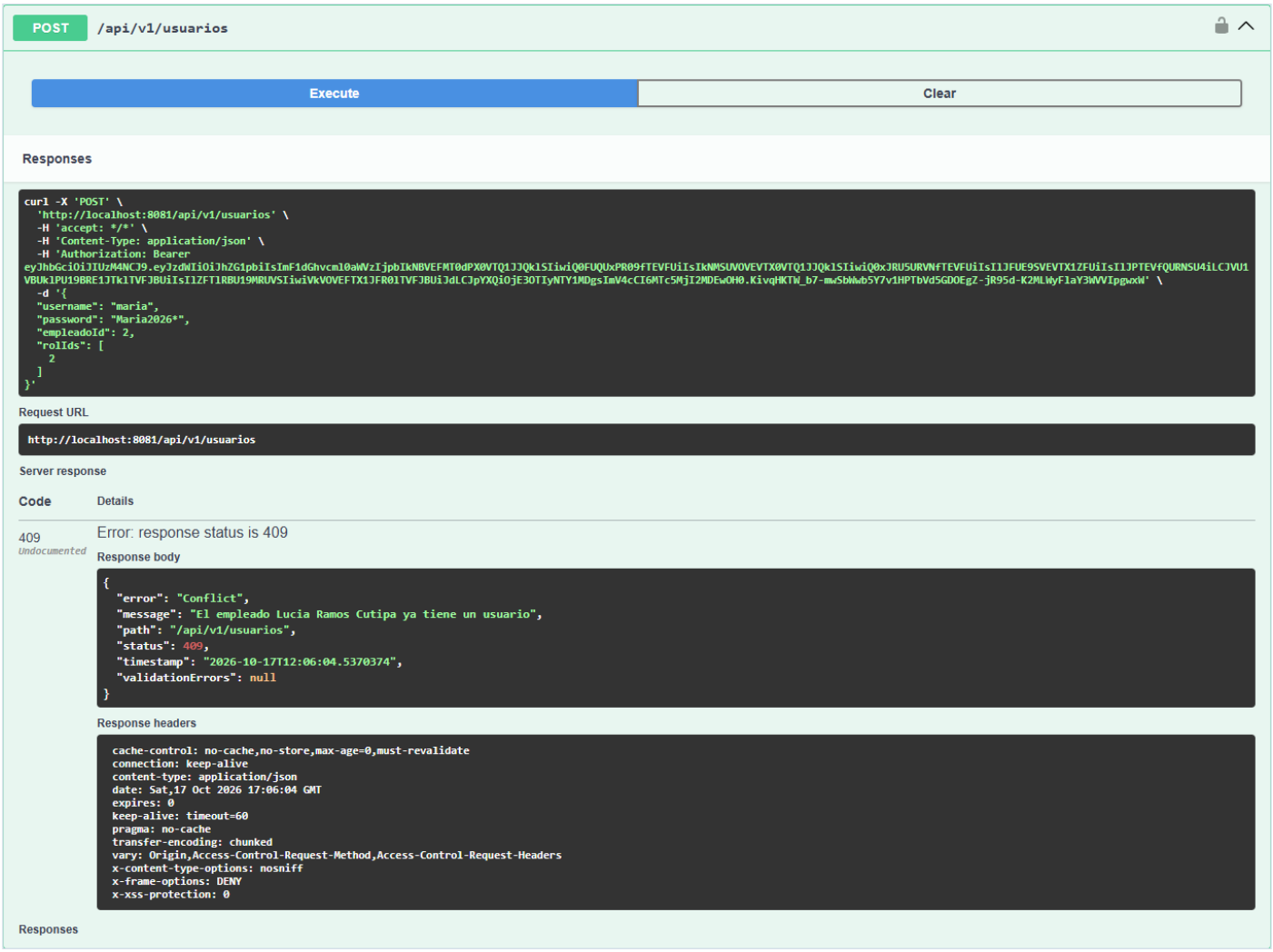
Empleado con cuenta

Usuario / token: admin / Bearer

Petición: POST http://localhost:8081/api/v1/usuarios

Esperado: 409 - ya tiene un usuario

Obtenido: 409 - El empleado Lucia Ramos Cutipa ya tiene un usuario



U-02_01_swagger.png

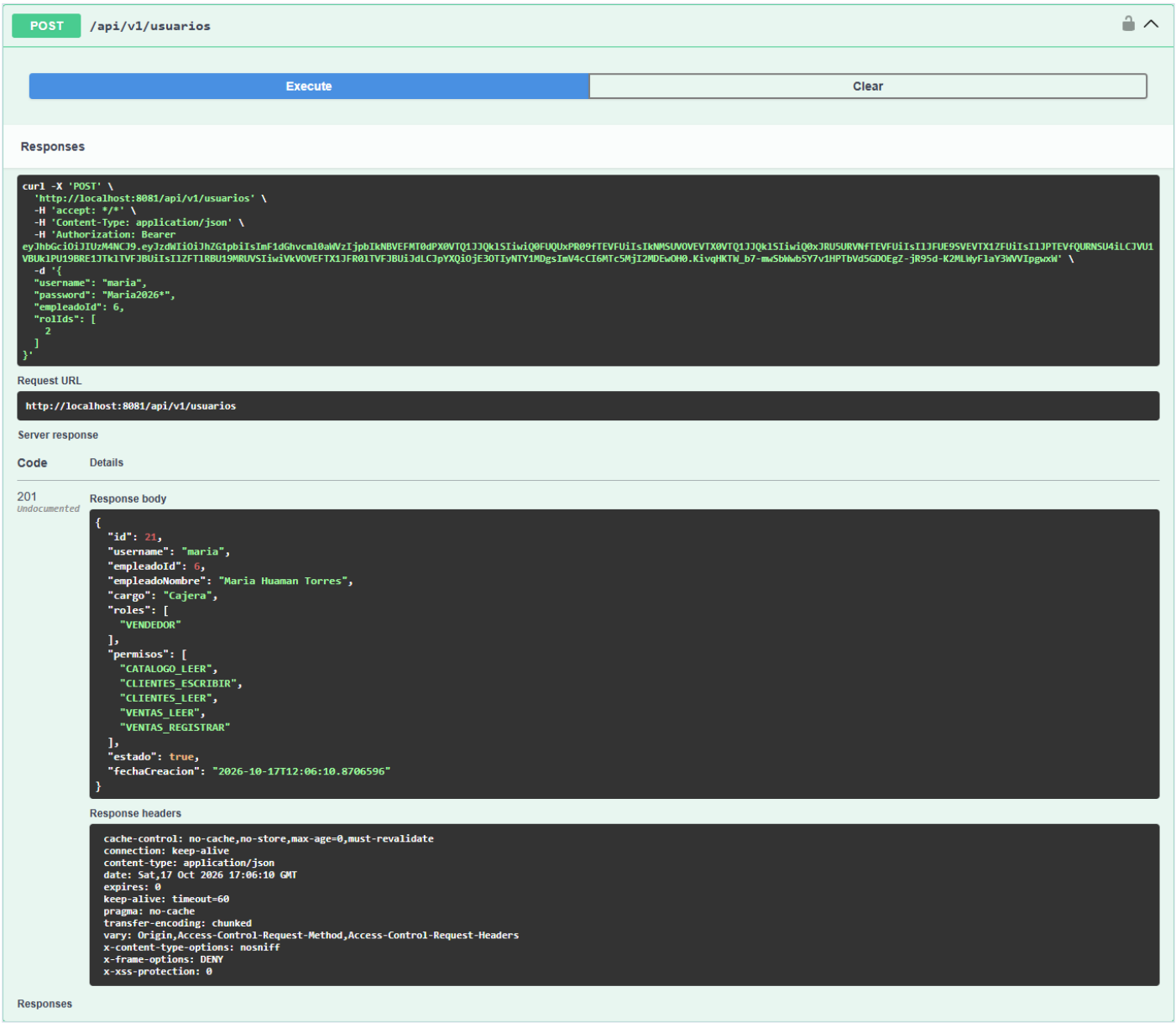
Alta de María Huamán

Usuario / token: admin / Bearer

Petición: POST http://localhost:8081/api/v1/usuarios

Esperado: 201 - Respuesta JSON correcta

Obtenido: 201 - Usuario maria; roles VENDEDOR; respuesta sin contraseña



U-02_02_swagger.png

Persistencia de la cuenta y hash BCrypt

Origen: consulta directa a Oracle mediante JDBC, reproducible en SQL Developer.

SELECT u.username,u.password,r.nombre AS rol FROM usuarios u JOIN usuario_roles ur ON ur.usuario_id=u.id JOIN roles r ON r.id=ur.rol_id WHERE u.username='maria'

USERNAME | PASSWORD | ROL

maria | $2a$10$N0gZdM17KKt7uynqos285OM6NXNLLGlekn1l1bmj.F6/qMErgfLQu | VENDEDOR

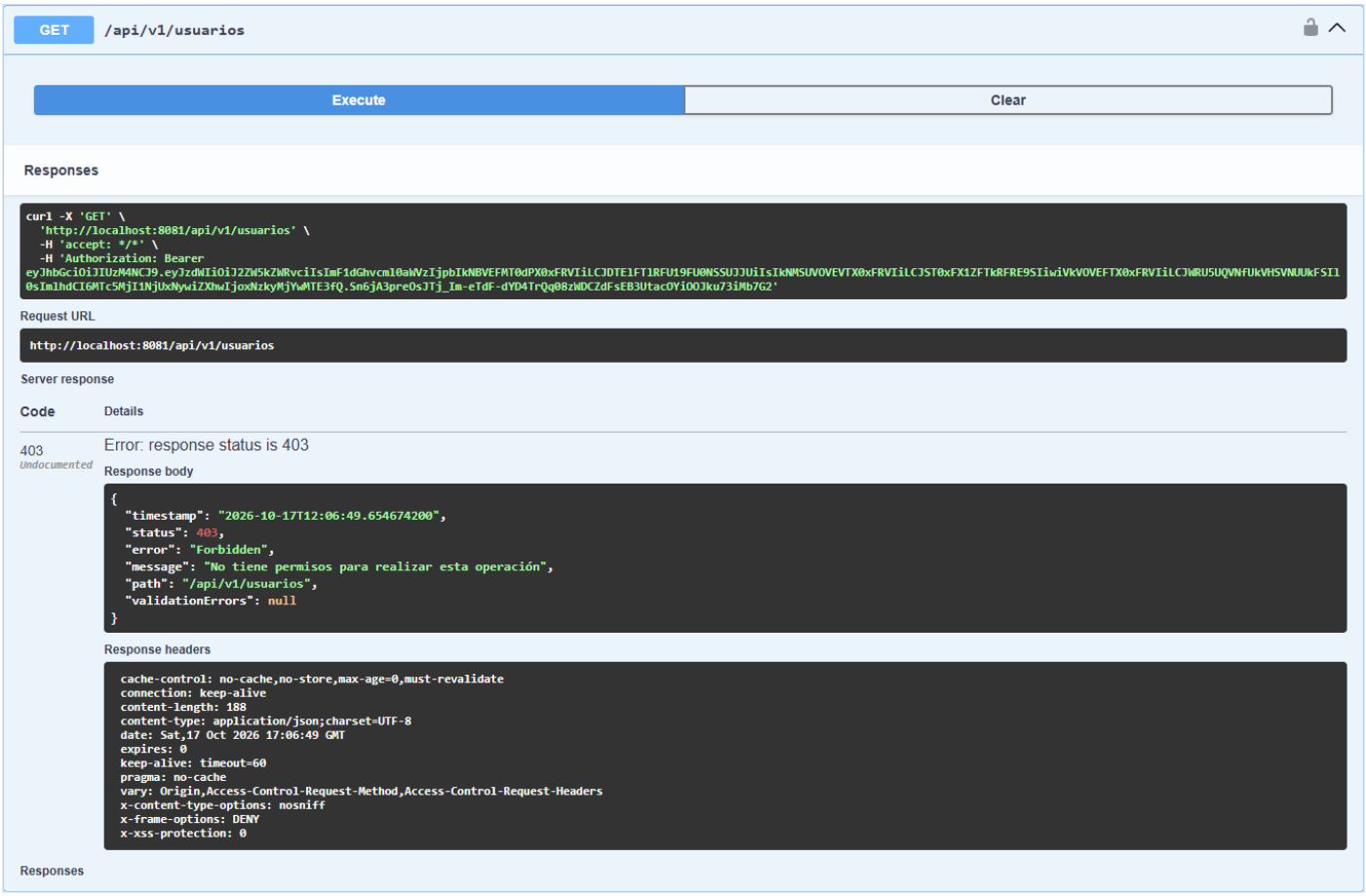
Propio: vendedor administra usuarios

Usuario / token: vendedor / Bearer

Petición: GET http://localhost:8081/api/v1/usuarios

Esperado: 403 - No tiene permisos

Obtenido: 403 - No tiene permisos para realizar esta operación



U-03_01_swagger.png

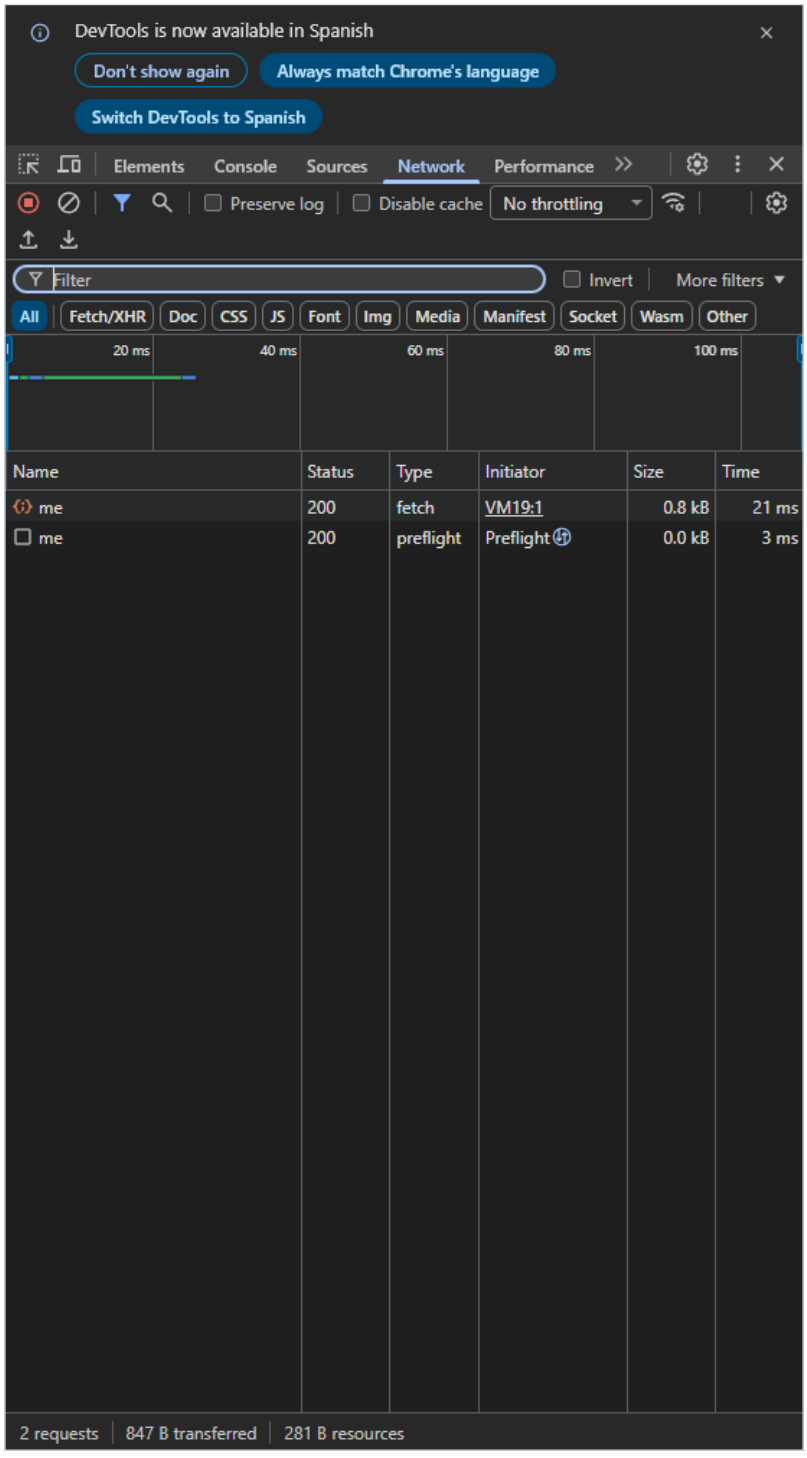
Preflight desde SPA localhost:4200

Usuario / token: vendedor / Bearer

Petición: OPTIONS + GET http://localhost:8081/api/v1/auth/me

Esperado: 200 - Preflight 200 y petición real 200 sin error CORS

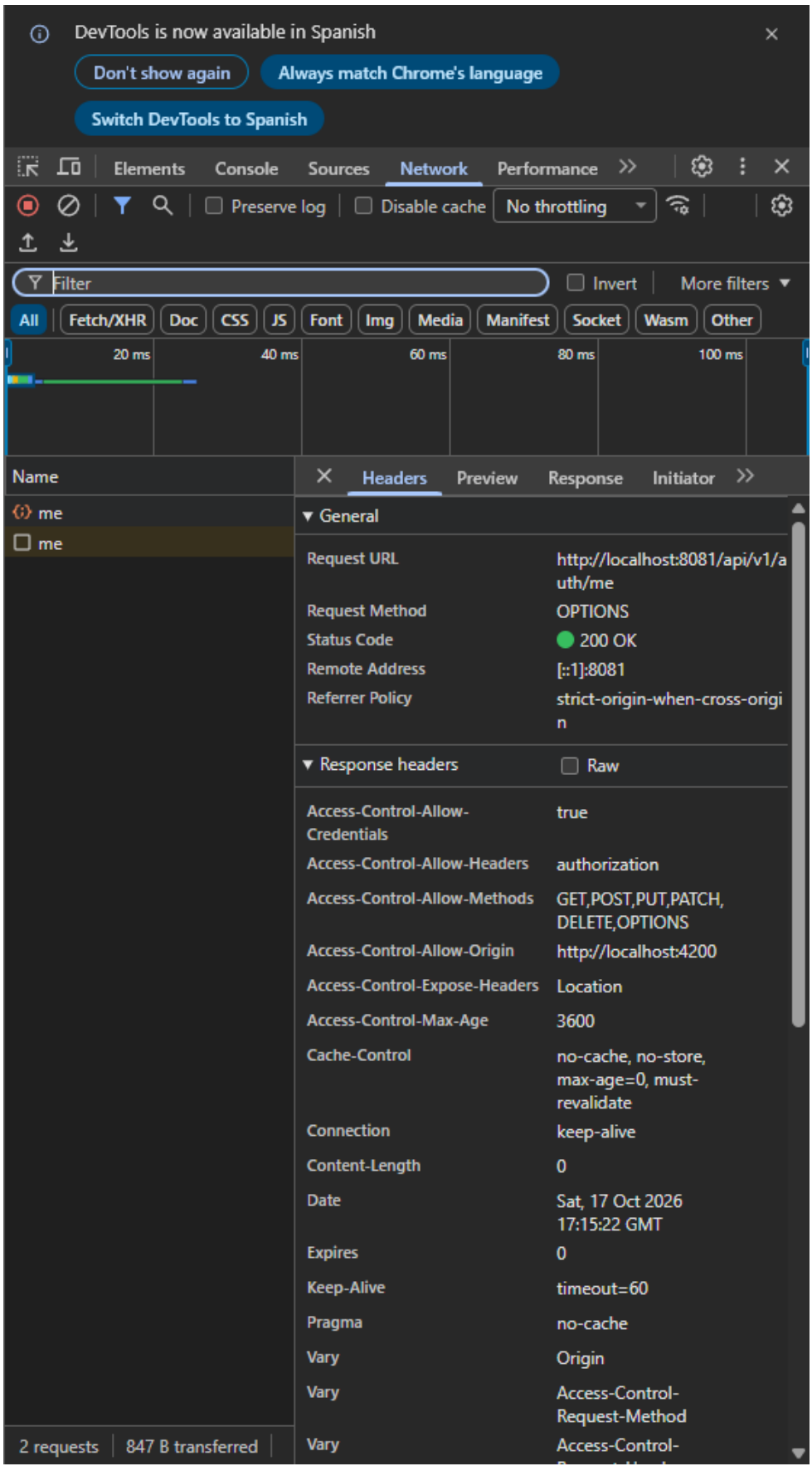
Obtenido: 200 - OPTIONS 200 y GET 200 desde localhost:4200, sin bloqueo CORS



C-01_01_red.png

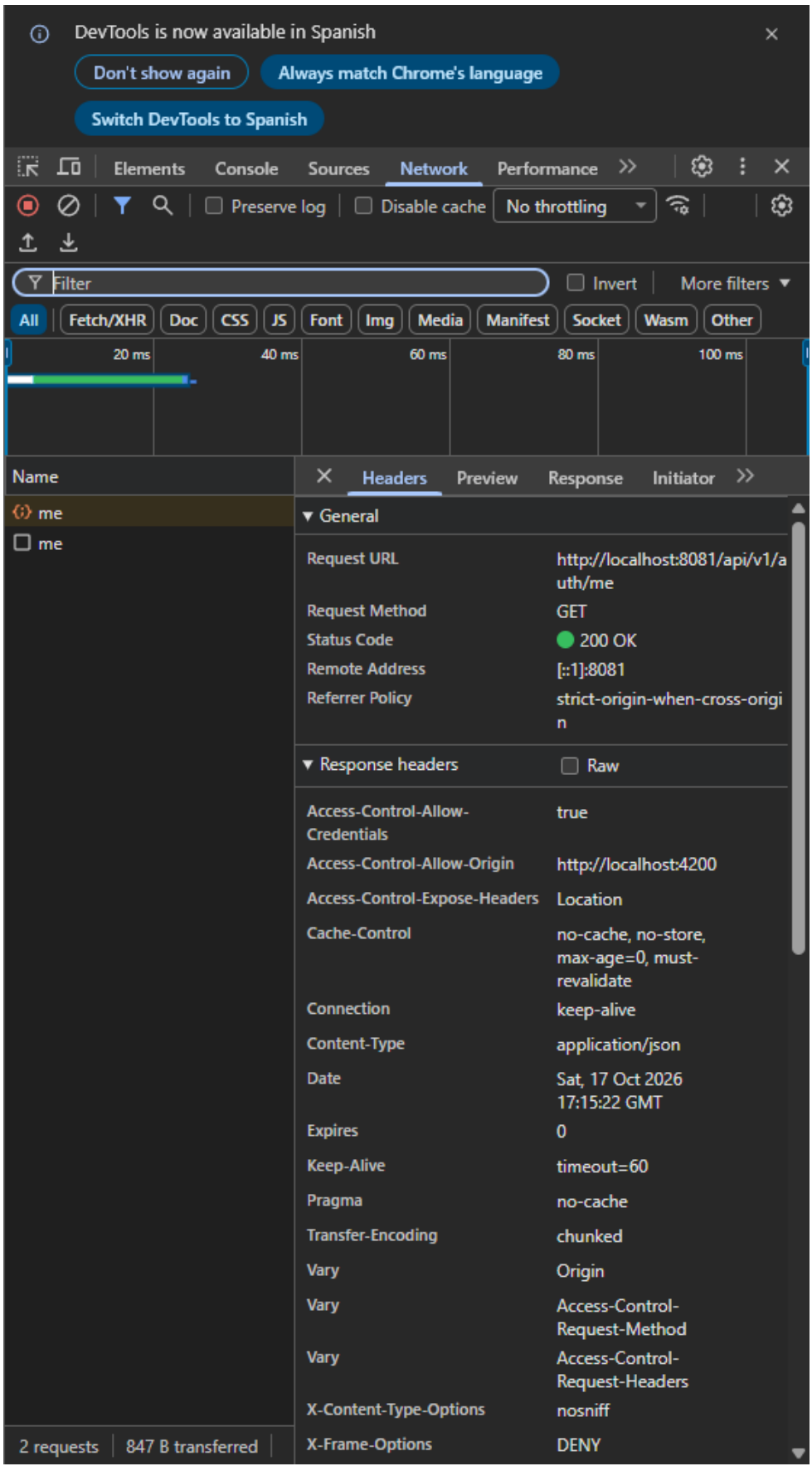
Respuesta OPTIONS del preflight

Captura real de DevTools desde el origen localhost:4200; corresponde al mismo caso C-01.



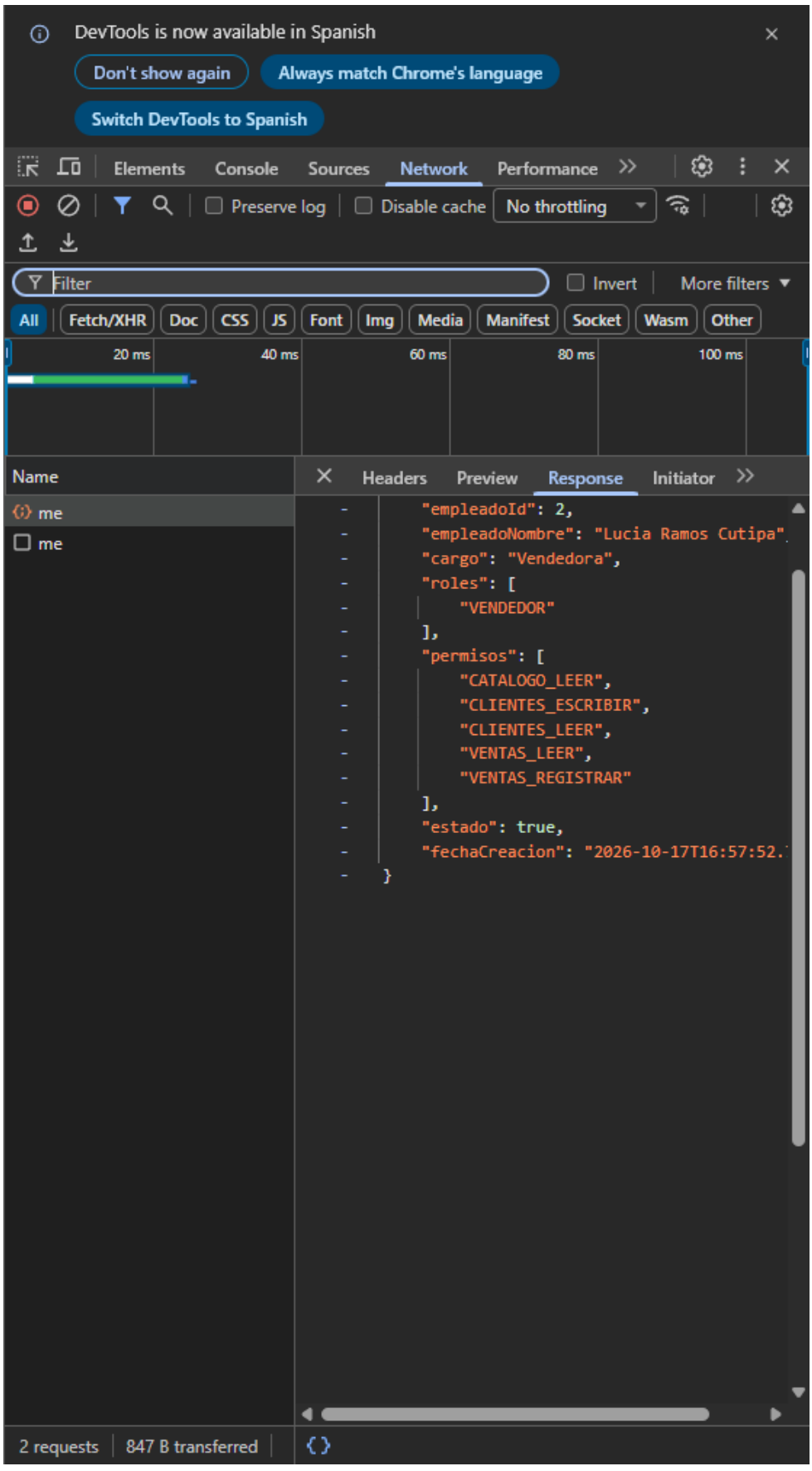
Encabezados de la petición GET

Captura real de DevTools desde el origen localhost:4200; corresponde al mismo caso C-01.



Respuesta de la petición GET

Captura real de DevTools desde el origen localhost:4200; corresponde al mismo caso C-01.



Registro del navegador

El navegador generó OPTIONS por el encabezado Authorization. El preflight respondió 200 y el GET respondió 200, sin bloqueo CORS.

Encabezados reales de la respuesta OPTIONS:

Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: authorization
Access-Control-Allow-Methods: GET,POST,PUT,PATCH,DELETE,OPTIONS
Access-Control-Allow-Origin: http://localhost:4200
Access-Control-Expose-Headers: Location
Access-Control-Max-Age: 3600
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Connection: keep-alive
Content-Length: 0
Date: Sat, 17 Oct 2026 17:15:22 GMT
Expires: 0
Keep-Alive: timeout=60
Pragma: no-cache
Vary: Origin Access-Control-Request-Method Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
X-XSS-Protection: 0

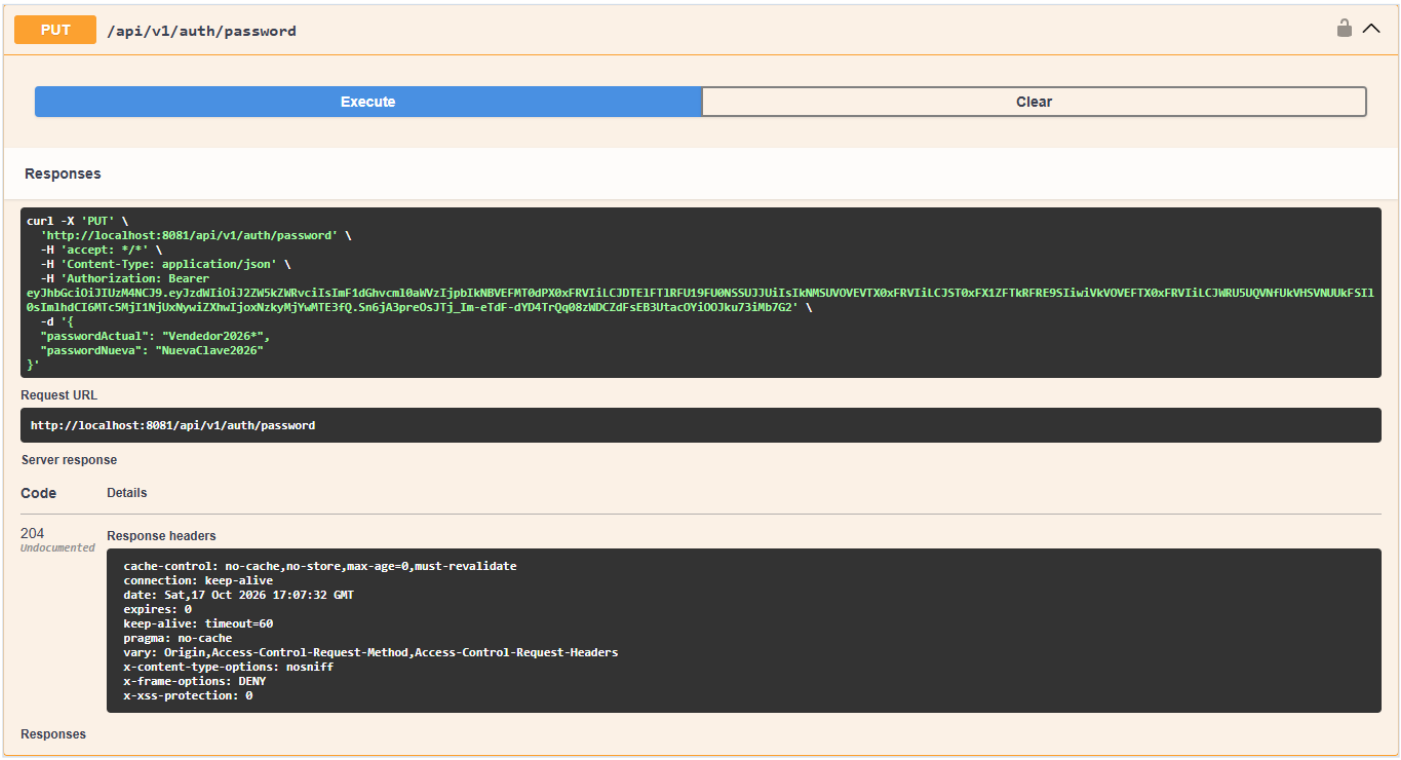
Cambio correcto de contraseña

Usuario / token: vendedor / Bearer

Petición: PUT http://localhost:8081/api/v1/auth/password

Esperado: 204 - Sin contenido

Obtenido: 204 - Sin contenido



B-01_01_swagger.png

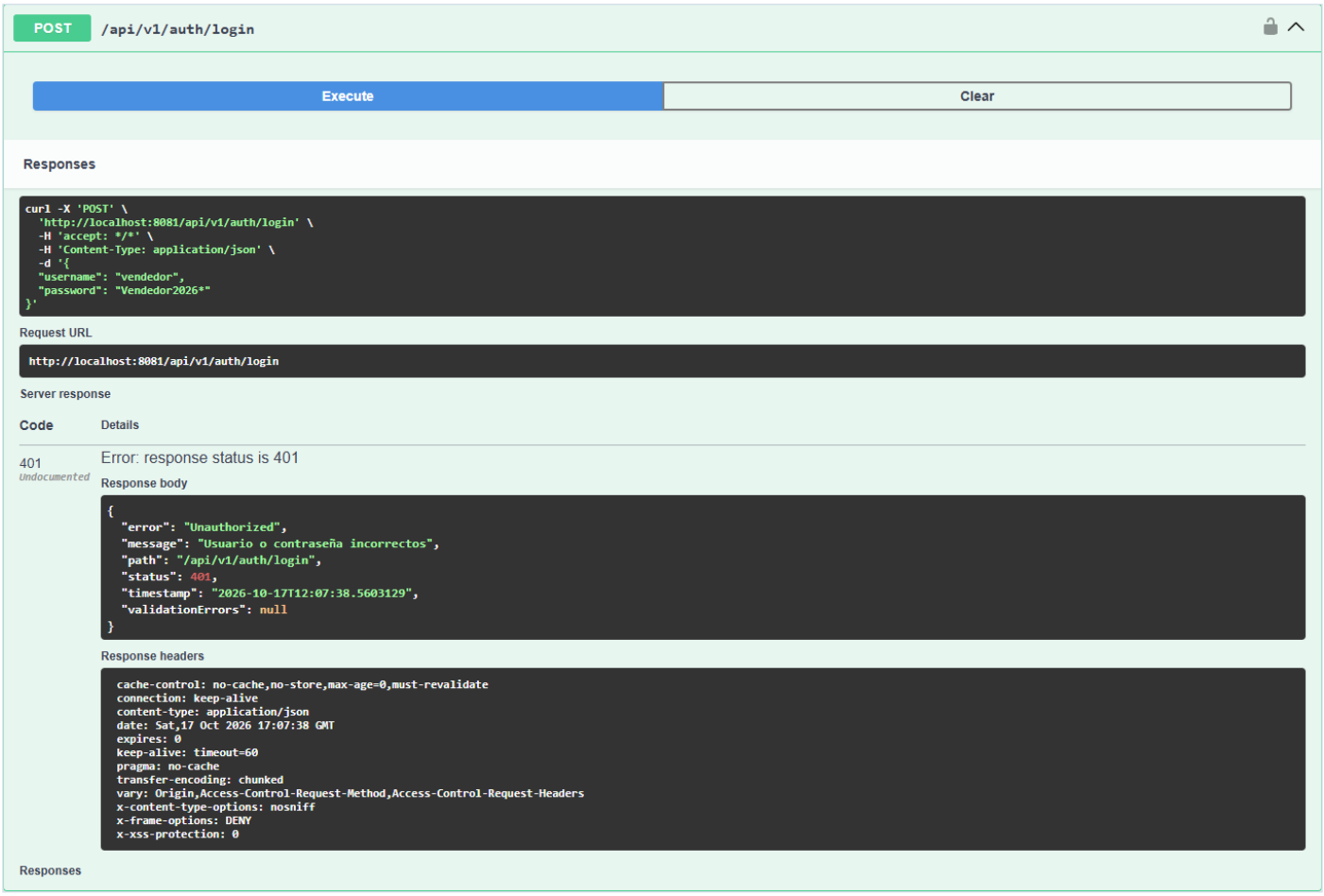
La contraseña anterior falla

Usuario / token: Público / Ausente

Petición: POST http://localhost:8081/api/v1/auth/login

Esperado: 401 - Usuario o contraseña incorrectos

Obtenido: 401 - Usuario o contraseña incorrectos



B-01_02_swagger.png

B-01 - PASA

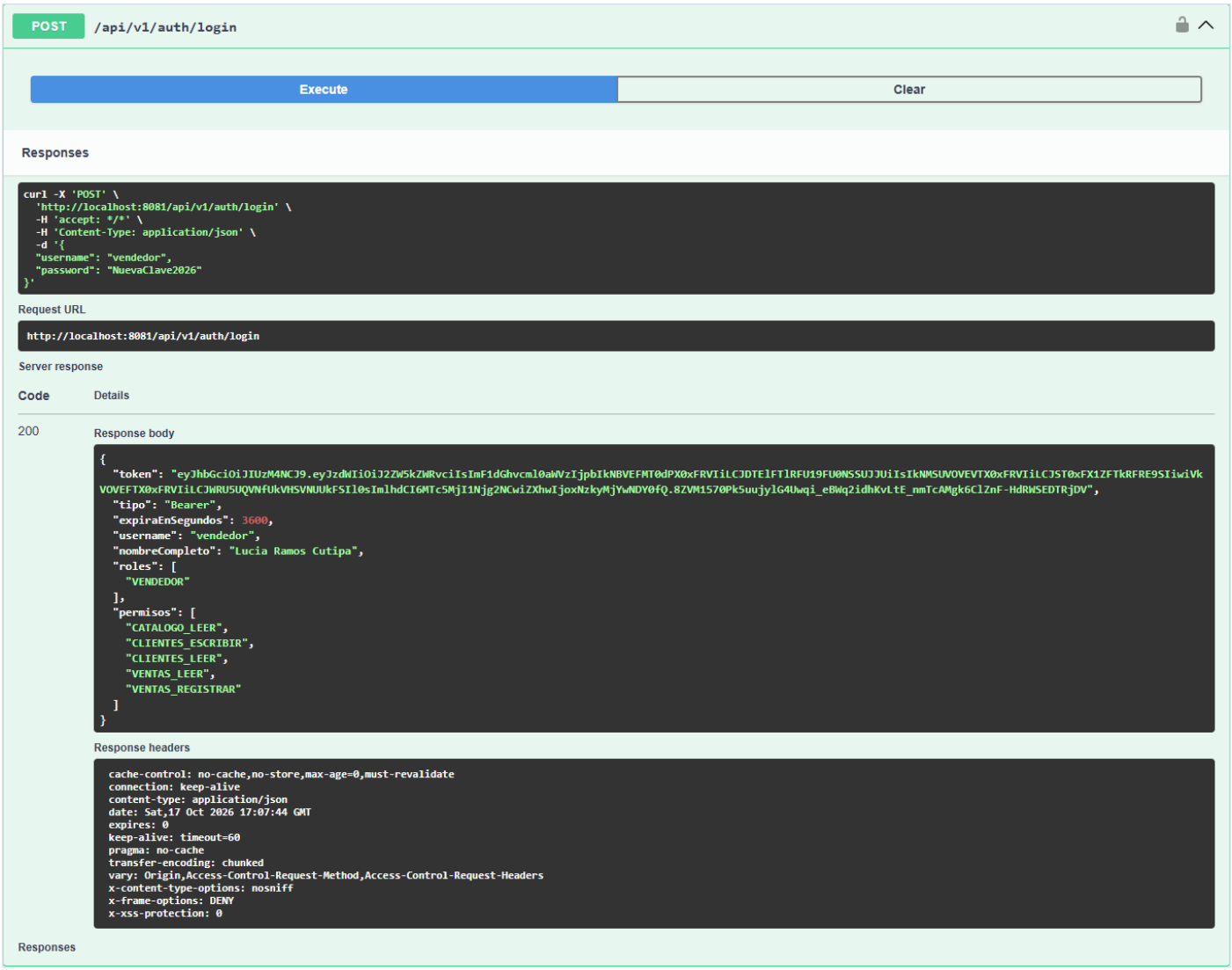
Nueva contraseña permite login

Usuario / token: Público / Ausente

Petición: POST http://localhost:8081/api/v1/auth/login

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - Usuario vendedor; roles VENDEDOR; respuesta sin contraseña



B-01_03_swagger.png

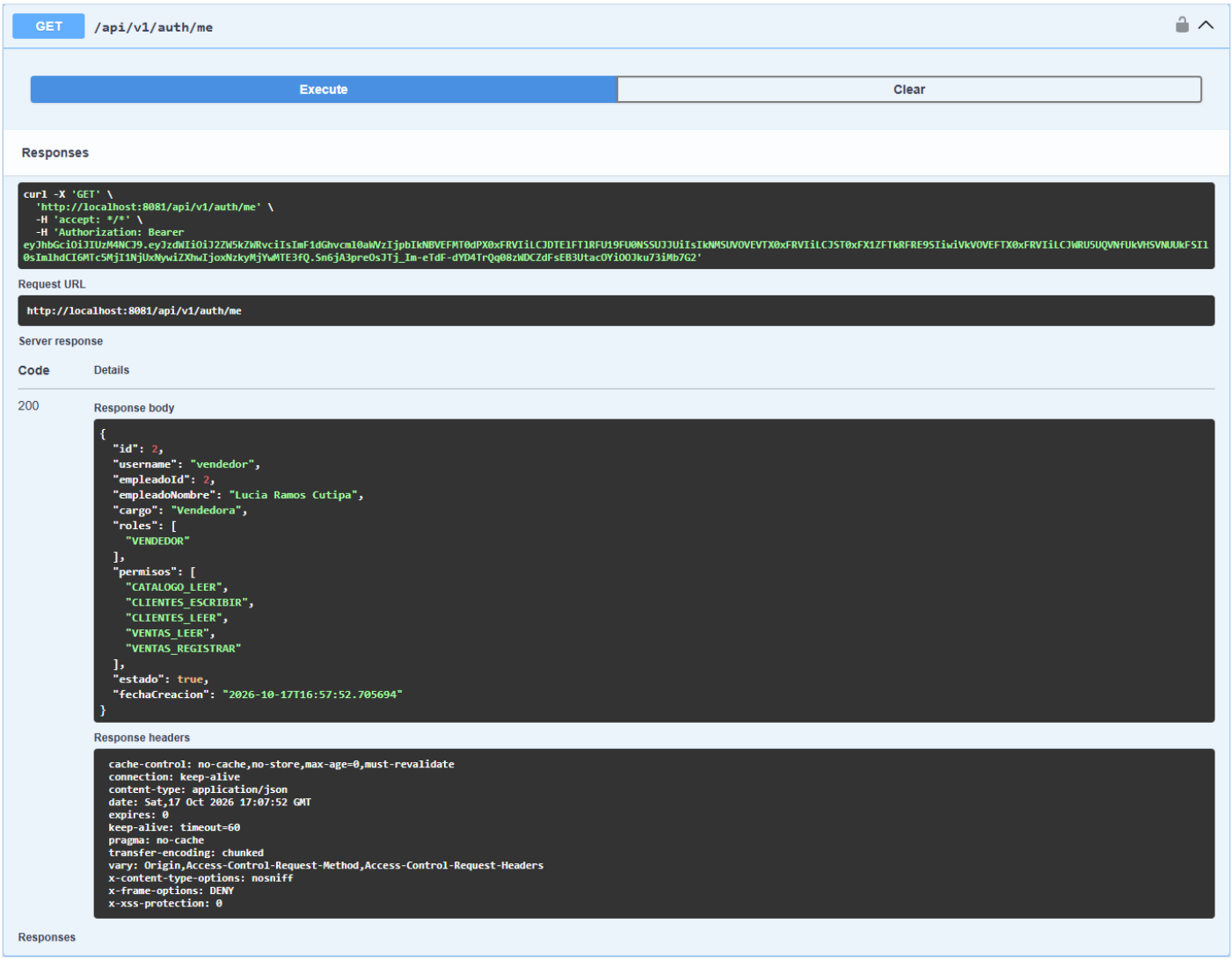
Mismo token tras cambiar contraseña

Usuario / token: vendedor / Bearer

Petición: GET http://localhost:8081/api/v1/auth/me

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - Usuario vendedor; roles VENDEDOR; respuesta sin contraseña



B-01_04_swagger.png

Registro del cambio de contraseña

Origen: log INFO real del backend; no registra las contraseñas enviadas.

2026-10-17T12:07:32.215-05:00 INFO 9948 --- [PharmaBackend] [nio-8081-exec-6] p.e.u.P.service.impl.AuthServiceImpl : Contraseña actualizada: usuario=vendedor

Verificación: las contraseñas de las peticiones no aparecen en el registro.

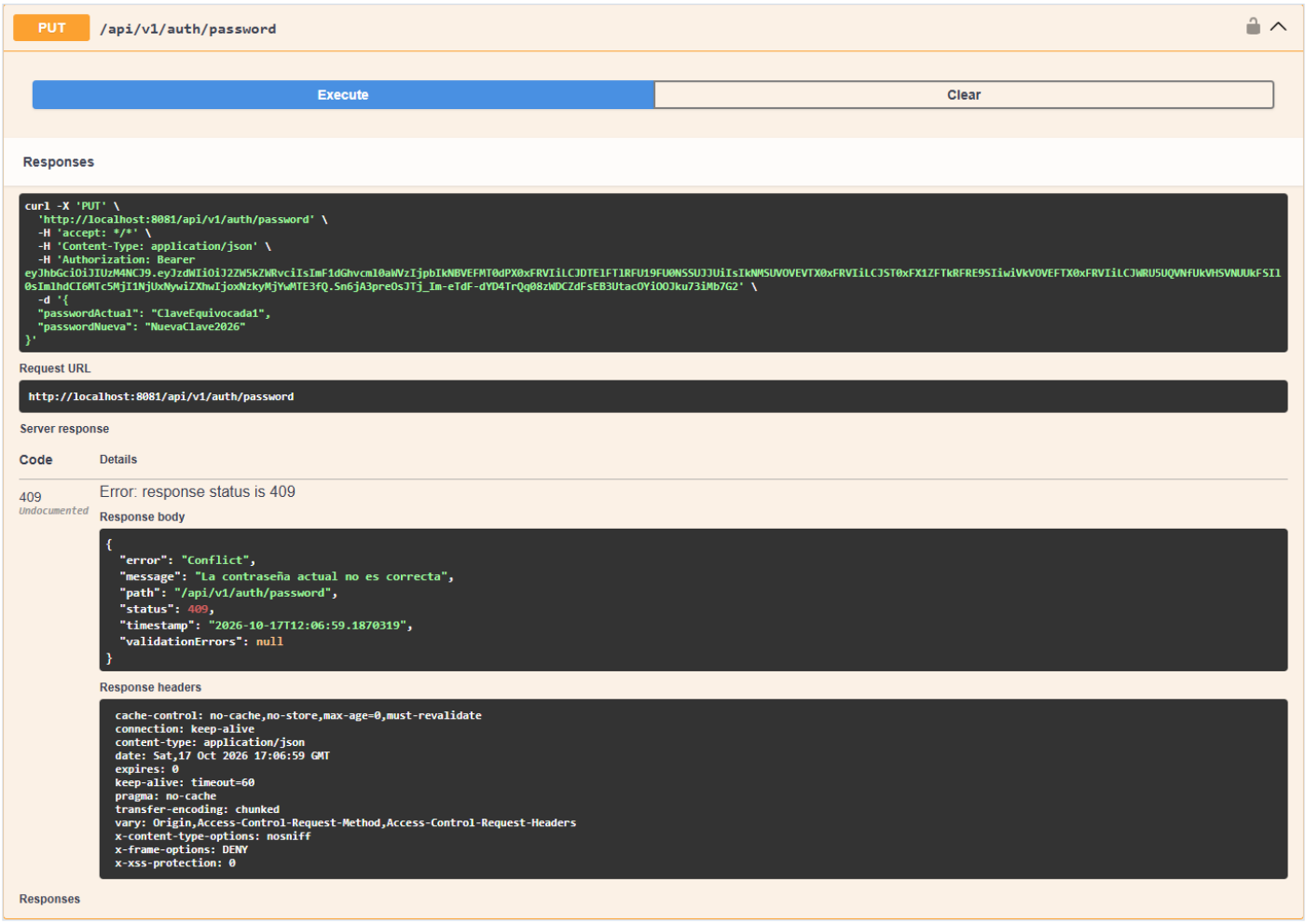
Contraseña actual incorrecta

Usuario / token: vendedor / Bearer

Petición: PUT http://localhost:8081/api/v1/auth/password

Esperado: 409 - La contraseña actual no es correcta

Obtenido: 409 - La contraseña actual no es correcta



B-02_01_swagger.png

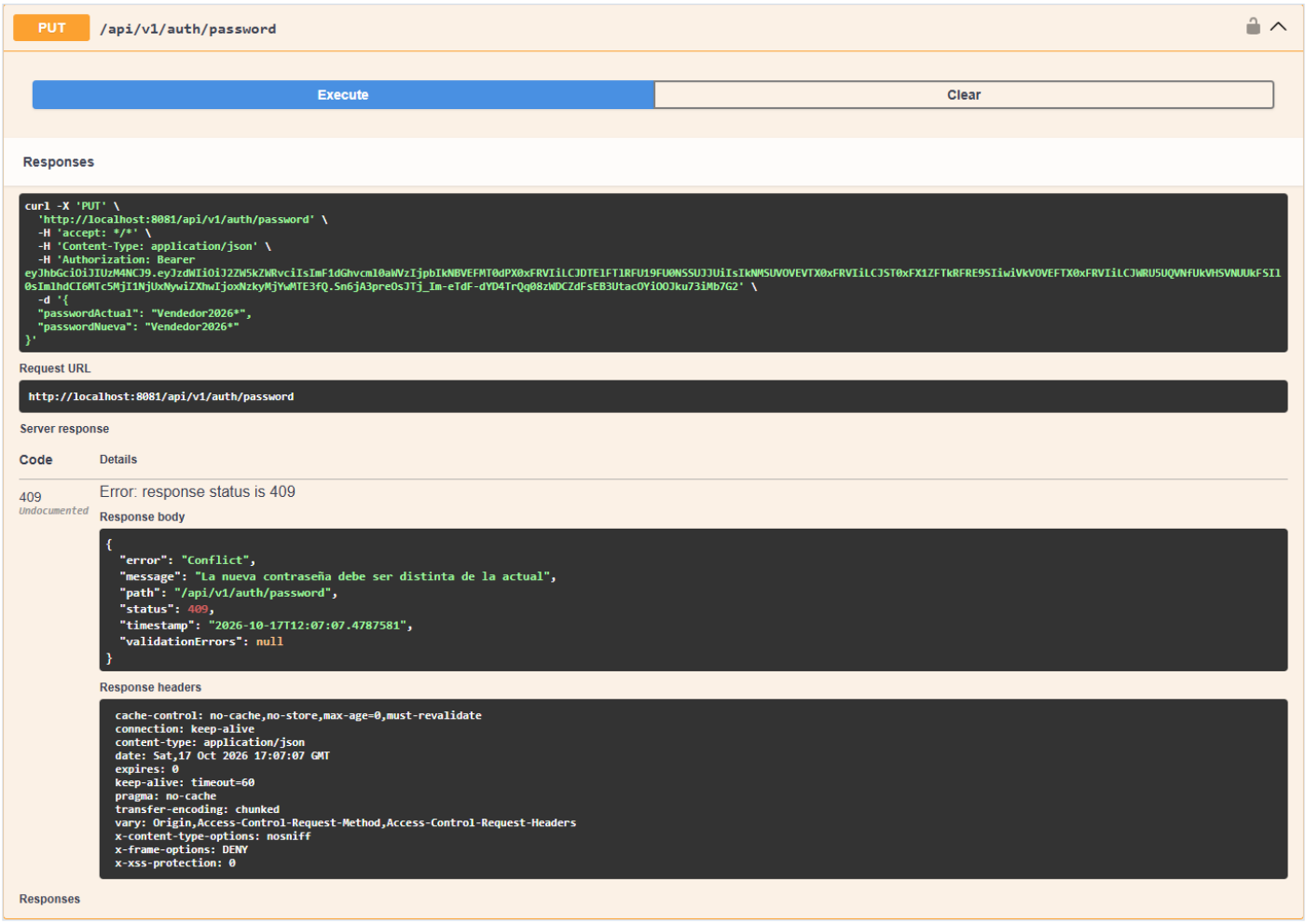
Nueva igual a actual

Usuario / token: vendedor / Bearer

Petición: PUT http://localhost:8081/api/v1/auth/password

Esperado: 409 - La nueva contraseña debe ser distinta de la actual

Obtenido: 409 - La nueva contraseña debe ser distinta de la actual



B-03_01_swagger.png

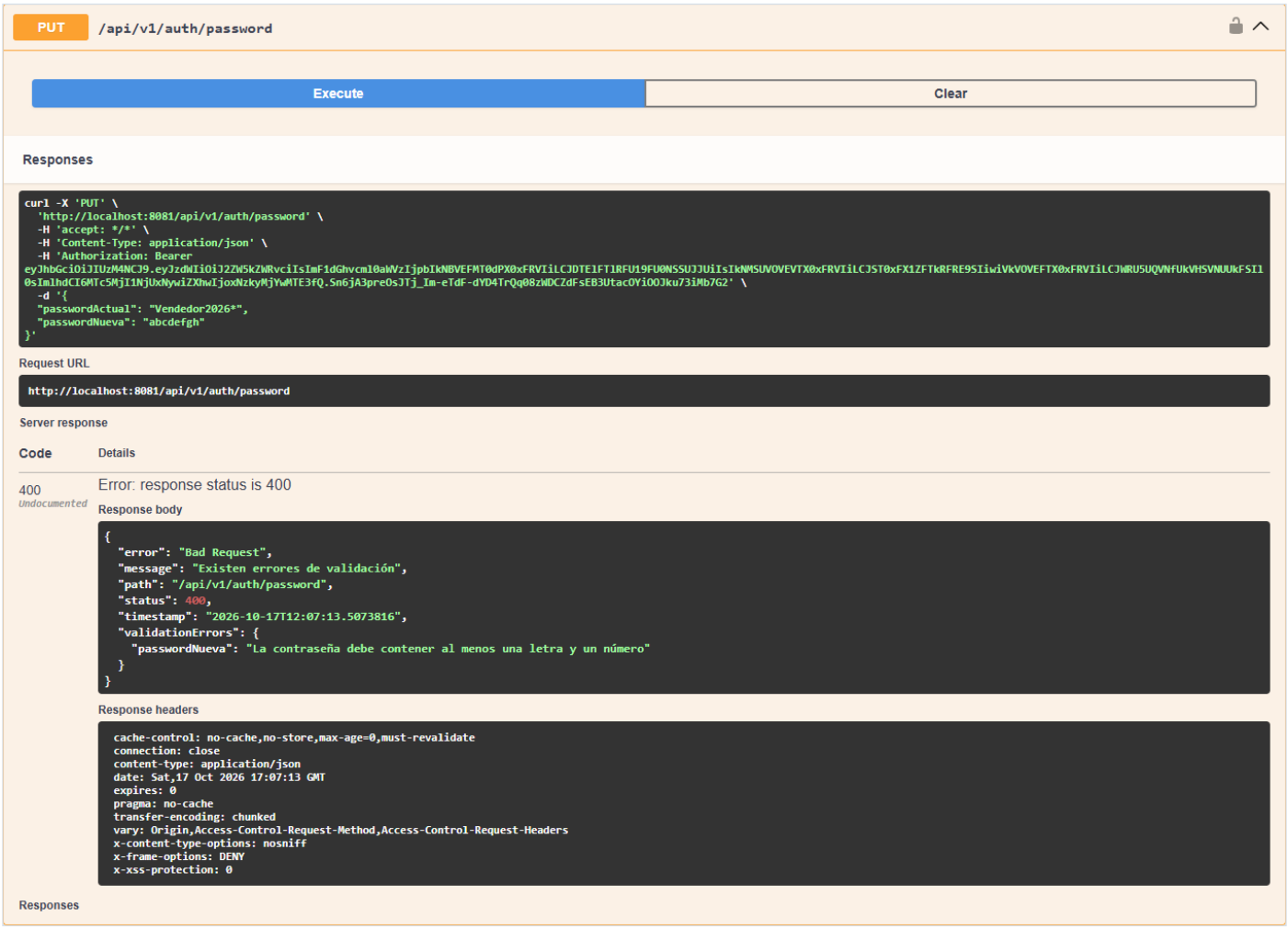
Validación de nueva contraseña

Usuario / token: vendedor / Bearer

Petición: PUT http://localhost:8081/api/v1/auth/password

Esperado: 400 - Rechazo de los datos enviados

Obtenido: 400 - Existen errores de validación / La contraseña debe contener al menos una letra y un número



B-04_01_swagger.png

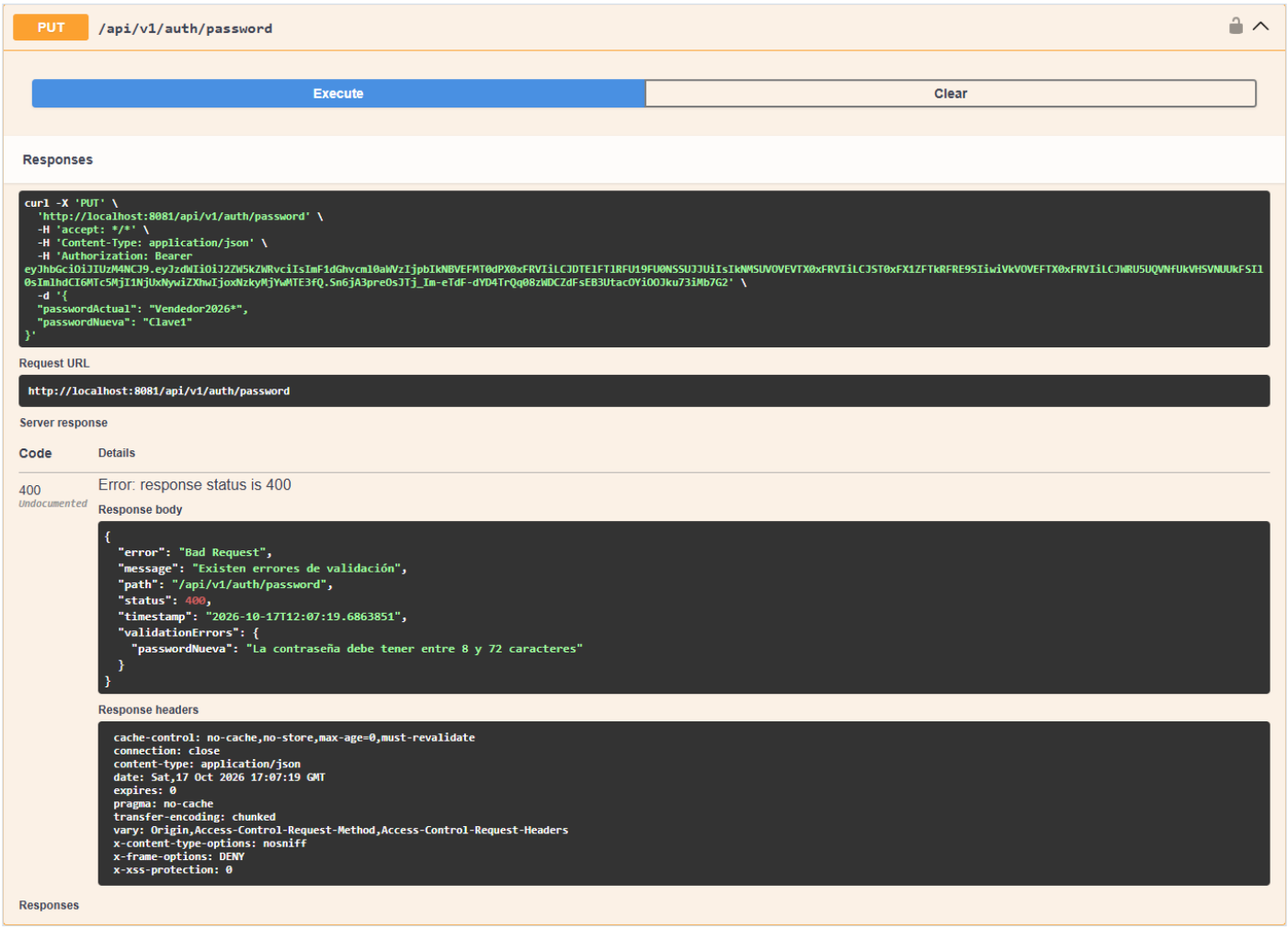
Validación de nueva contraseña

Usuario / token: vendedor / Bearer

Petición: PUT http://localhost:8081/api/v1/auth/password

Esperado: 400 - Rechazo de los datos enviados

Obtenido: 400 - Existen errores de validación / La contraseña debe tener entre 8 y 72 caracteres



B-04_02_swagger.png

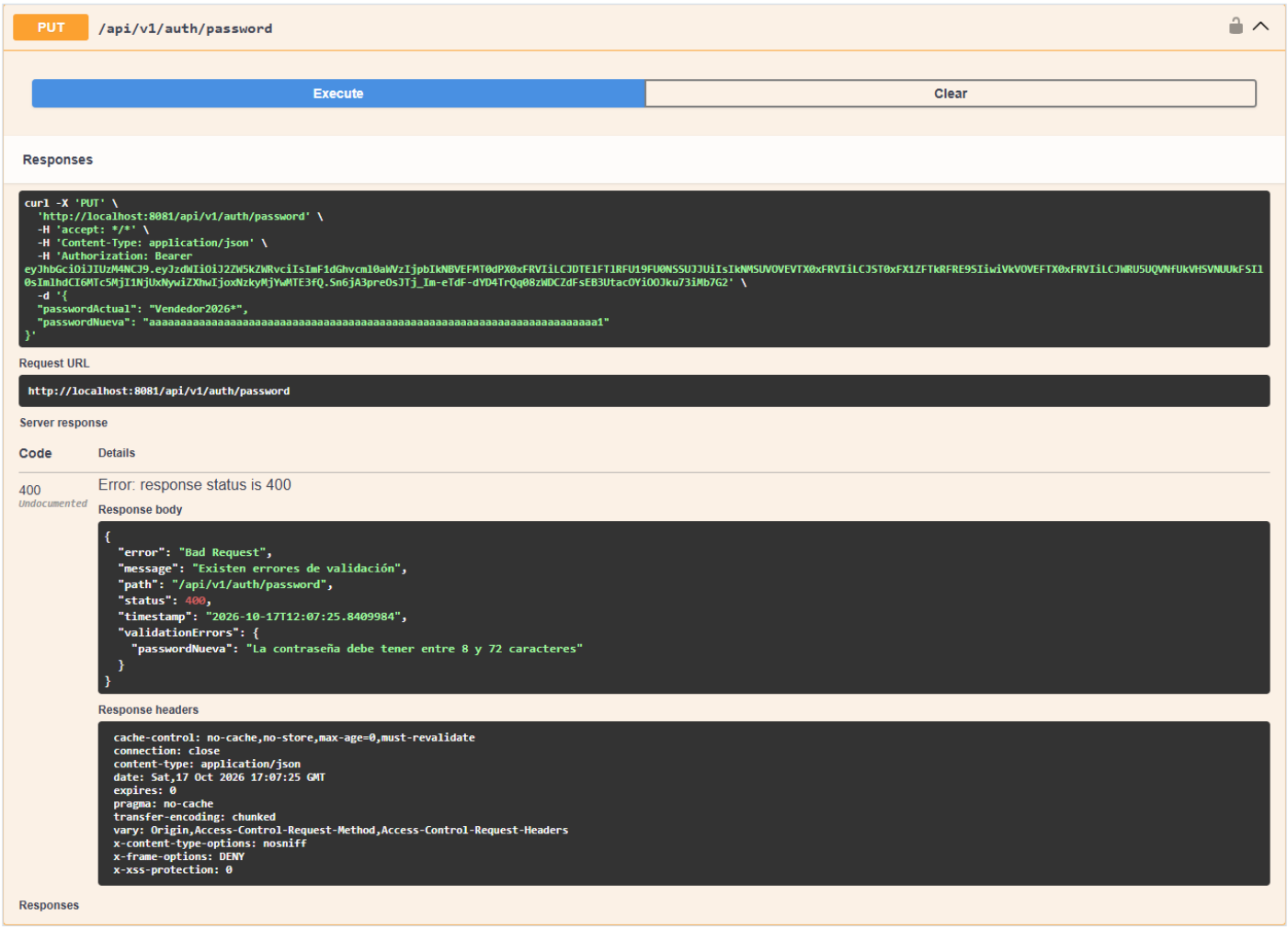
Validación de nueva contraseña

Usuario / token: vendedor / Bearer

Petición: PUT http://localhost:8081/api/v1/auth/password

Esperado: 400 - Rechazo de los datos enviados

Obtenido: 400 - Existen errores de validación / La contraseña debe tener entre 8 y 72 caracteres


PUT
/api/v1/auth/password
Execute
Clear
Responses
curl -X 'PUT' \
'http://localhost:8081/api/v1/auth/password' \
-H 'accept: */*' \
-H 'Content-Type: application/json' \
-H 'Authorization: Bearer
eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJ2ZW5kZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTE1FTlRFU19FU0NSSUJJUiIsIkNMSUVOVEVFTX0xFRVIiLCJST0xFX1ZFTkRFRE9SIiwiVkVOVEFTX0xFRVIiLCJWRU5UQVNFUkVHSVNVUUkFSI1
0sImlhdCI6MTc5MjI1NjUxNywiZXhwIjoxNzkyMjYwNTE3fQ.Sn6jA3preOsJTj_Im-eTdF-dYD4TrQq08zWDCZdFsEB3UtacOYiOOJku73iMb7G2' \
-d '{
"passwordActual": "Vendedor2026*",
"passwordNueva": "aaaa

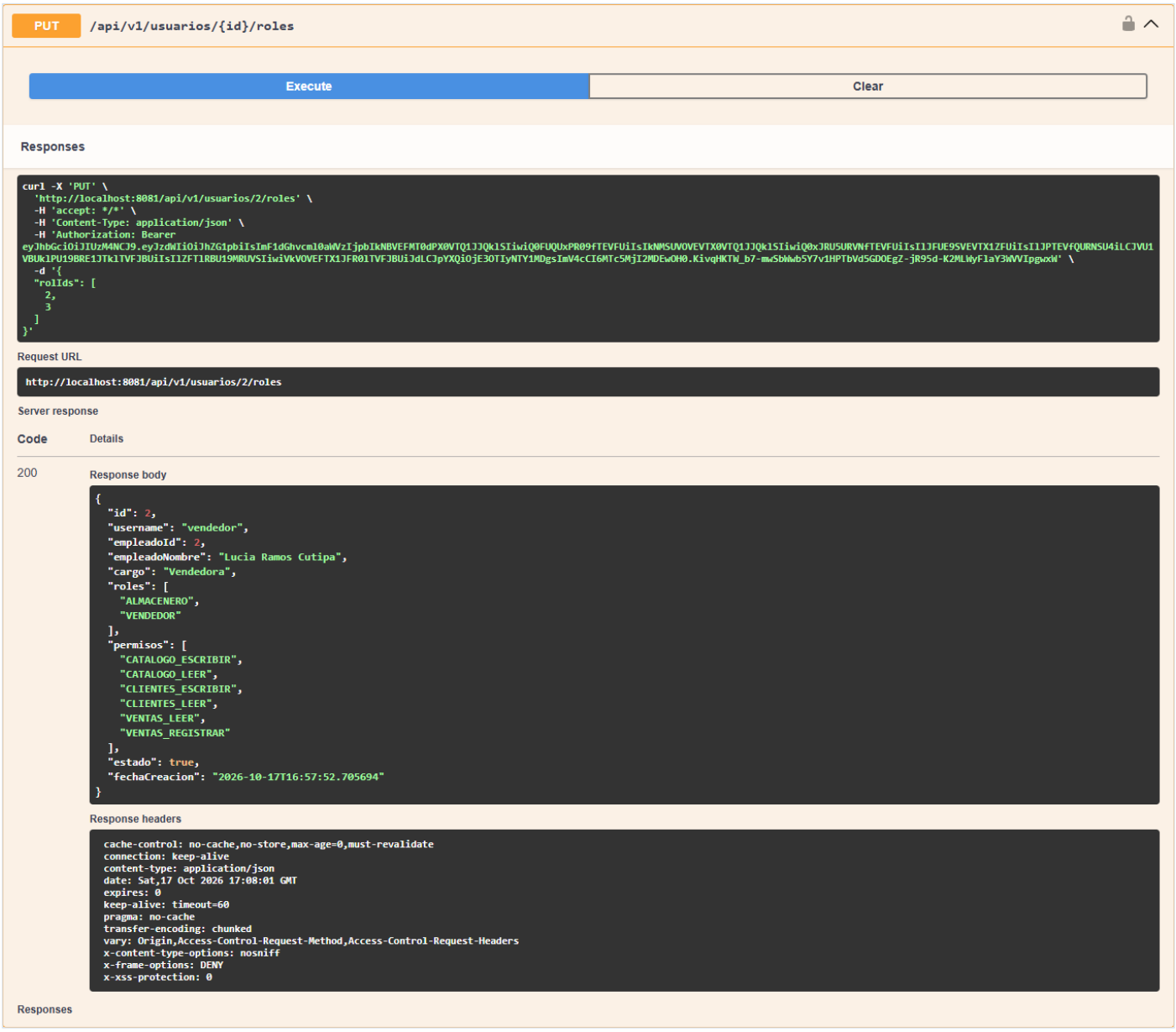
Admin asigna dos roles

Usuario / token: admin / Bearer

Petición: PUT http://localhost:8081/api/v1/usuarios/2/roles

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - Usuario vendedor; roles ALMACENERO, VENDEDOR; respuesta sin contraseña



B-05_01_swagger.png

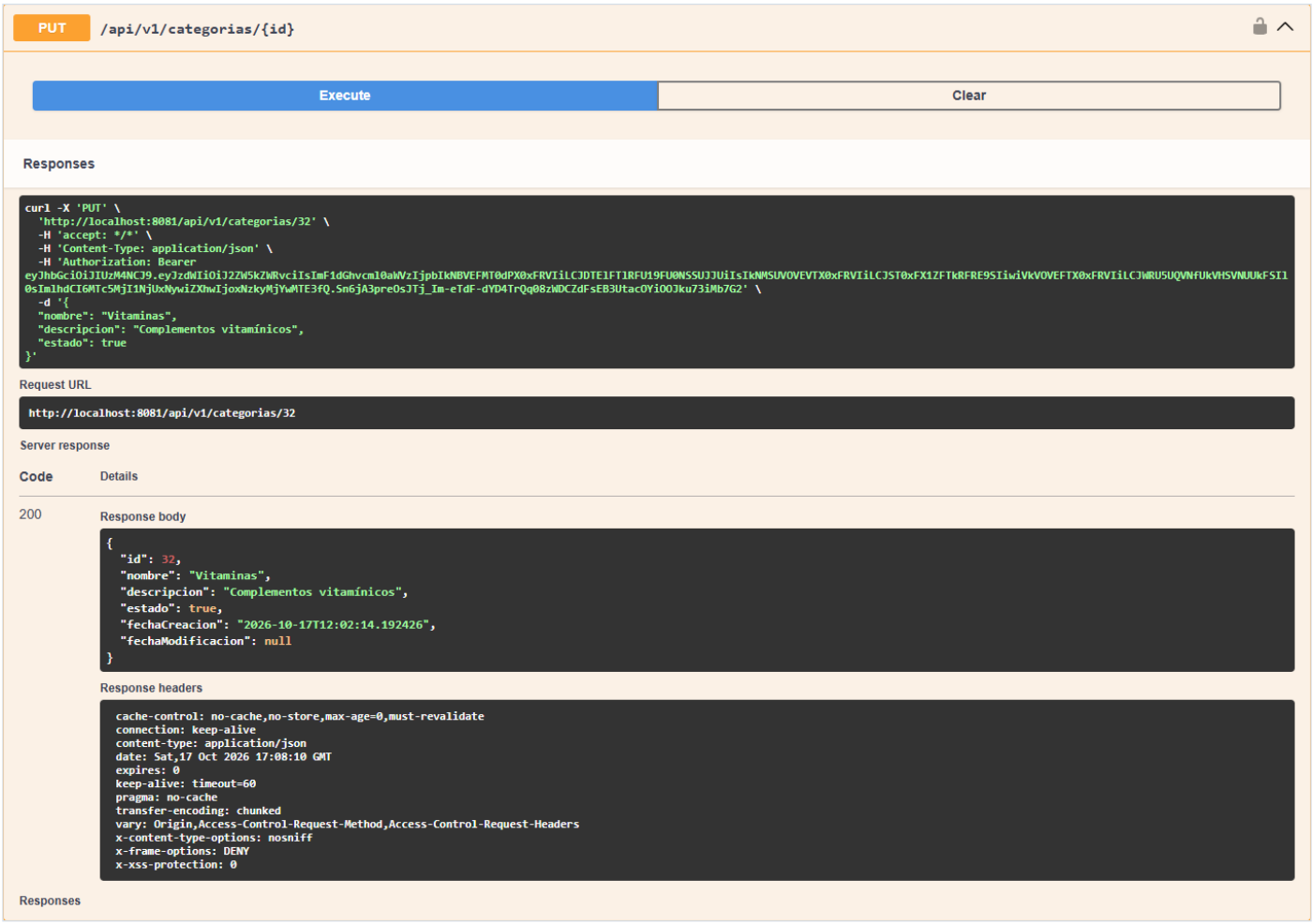
Mismo token obtiene permiso nuevo

Usuario / token: vendedor / Bearer

Petición: PUT http://localhost:8081/api/v1/categorias/32

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - JSON correcto del módulo solicitado



B-05_02_swagger.png

Relaciones de usuario y roles

Origen: consulta directa a Oracle mediante JDBC, reproducible en SQL Developer.

SELECT u.username,r.nombre AS rol FROM usuarios u JOIN usuario_roles ur ON ur.usuario_id=u.id JOIN roles r ON r.id=ur.rol_id WHERE u.username='vendedor' ORDER BY r.nombre

USERNAME | ROL

vendedor | ALMACENERO

vendedor | VENDEDOR

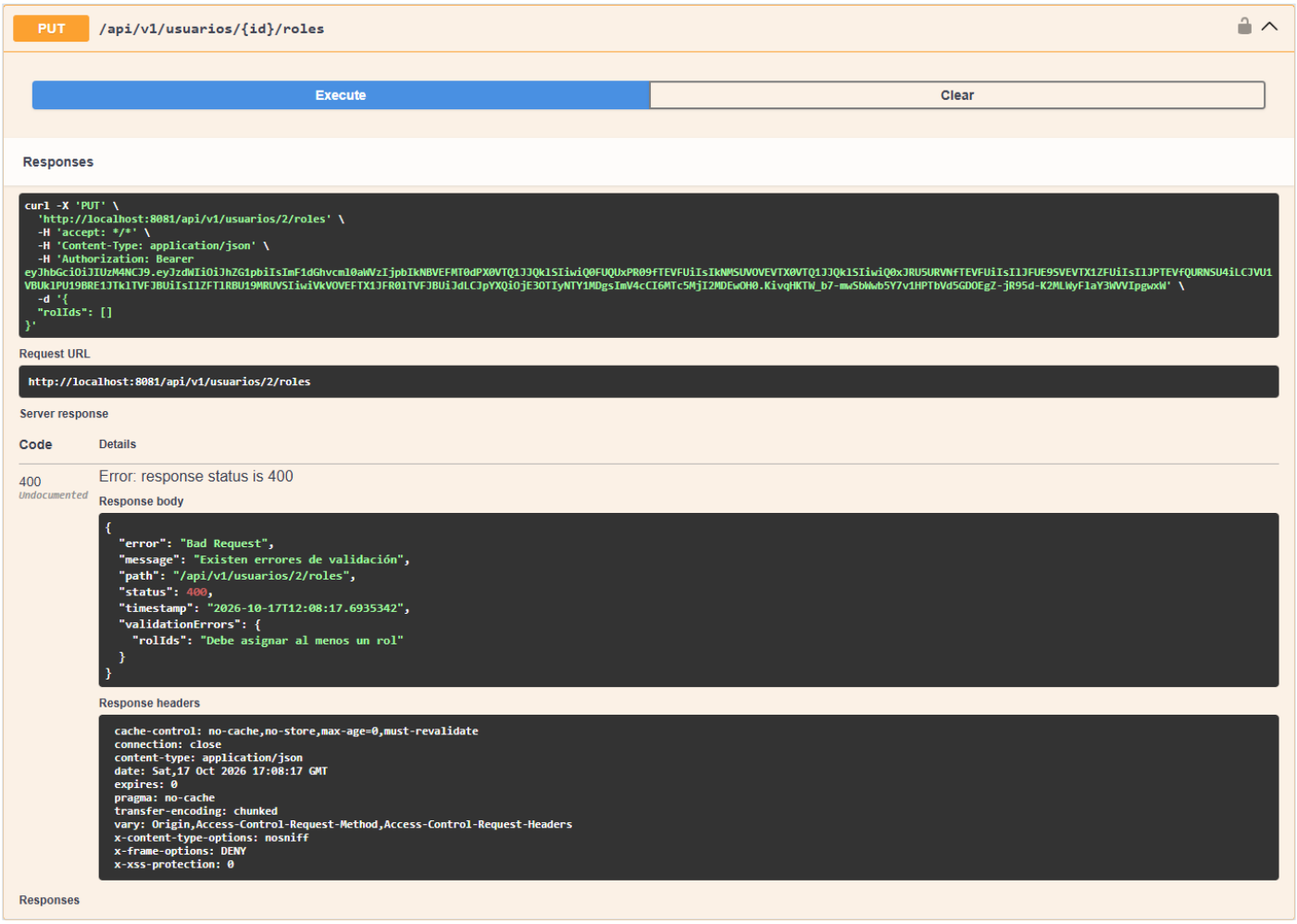
No permite roles vacíos

Usuario / token: admin / Bearer

Petición: PUT http://localhost:8081/api/v1/usuarios/2/roles

Esperado: 400 - Rechazo de los datos enviados

Obtenido: 400 - Existen errores de validación / Debe asignar al menos un rol



B-06_01_swagger.png

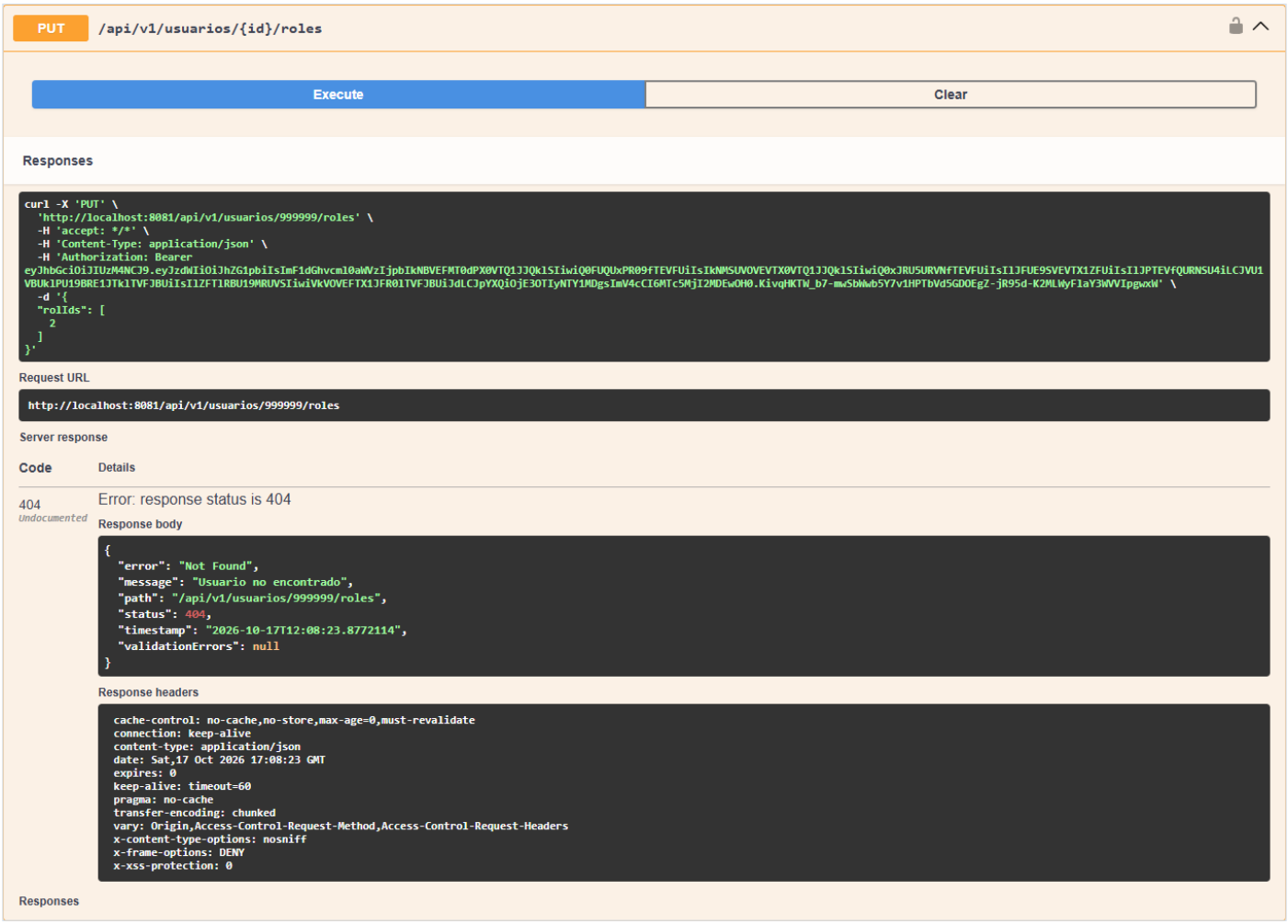
Usuario inexistente

Usuario / token: admin / Bearer

Petición: PUT http://localhost:8081/api/v1/usuarios/999999/roles

Esperado: 404 - Usuario no encontrado

Obtenido: 404 - Usuario no encontrado



B-06_02_swagger.png

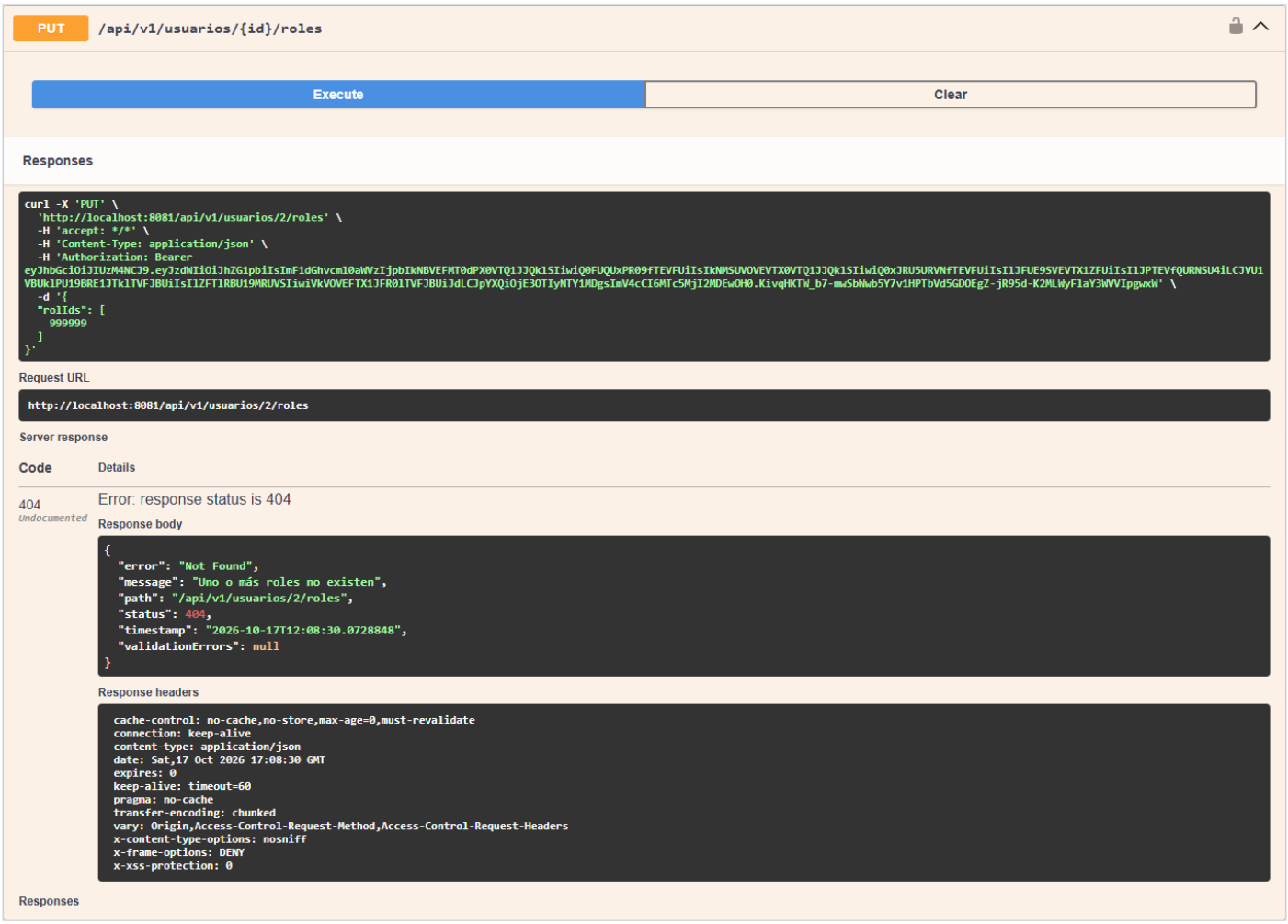
Rol inexistente

Usuario / token: admin / Bearer

Petición: PUT http://localhost:8081/api/v1/usuarios/2/roles

Esperado: 404 - roles no existen

Obtenido: 404 - Uno o más roles no existen



B-06_03_swagger.png

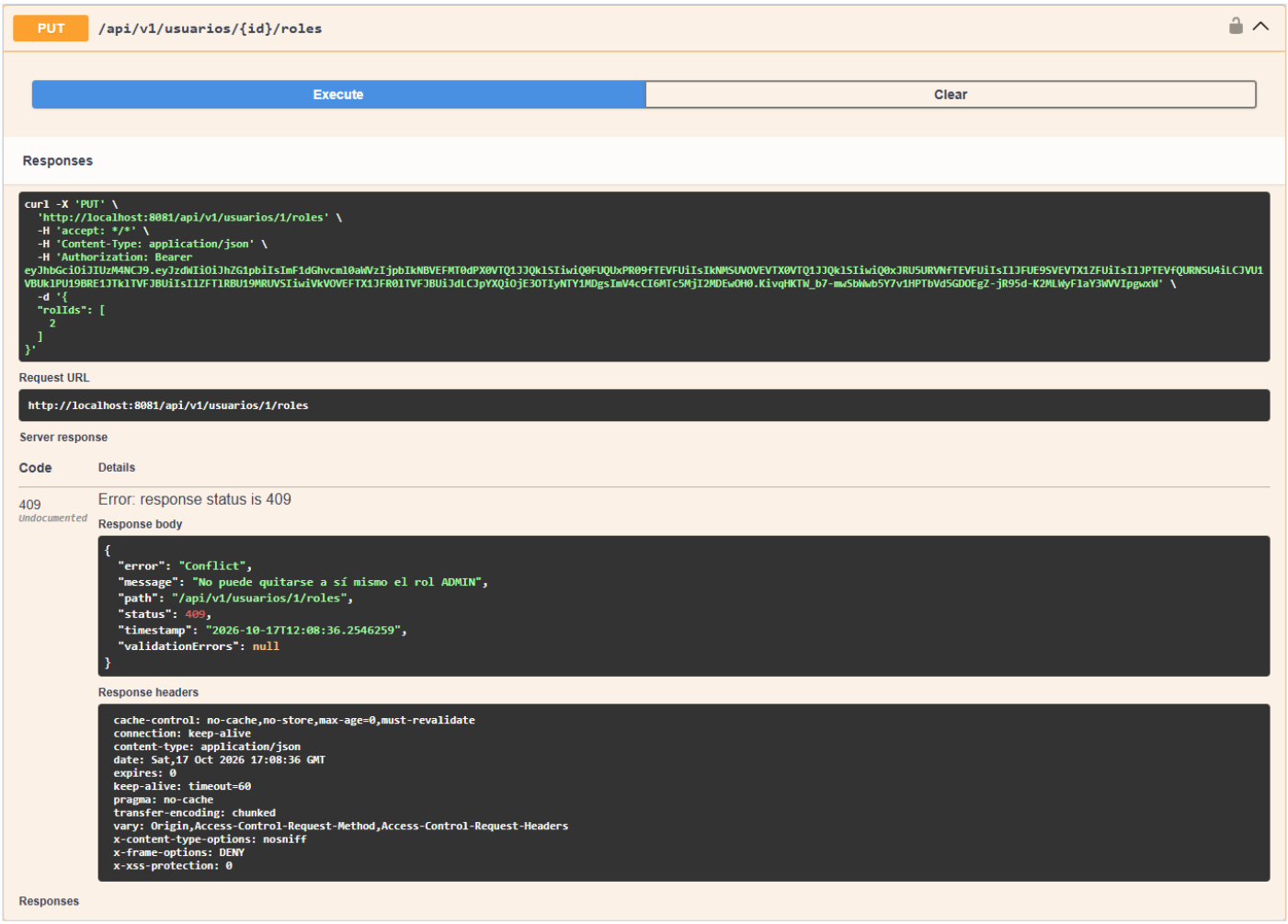
Admin conserva su propio rol

Usuario / token: admin / Bearer

Petición: PUT http://localhost:8081/api/v1/usuarios/1/roles

Esperado: 409 - No puede quitarse

Obtenido: 409 - No puede quitarse a sí mismo el rol ADMIN



B-06_04_swagger.png

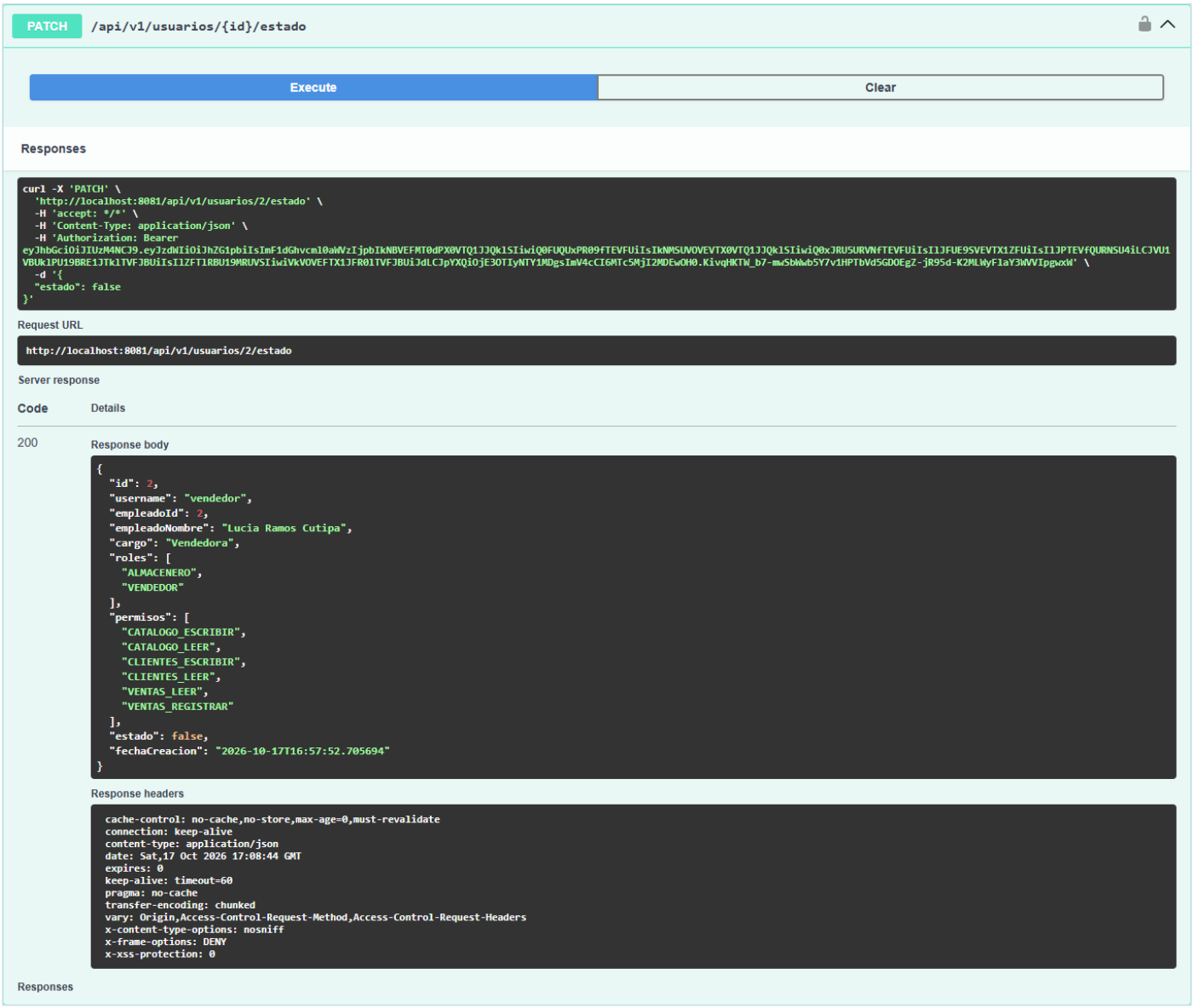
Admin desactiva vendedor

Usuario / token: admin / Bearer

Petición: PATCH http://localhost:8081/api/v1/usuarios/2/estado

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - Usuario vendedor; roles ALMACENERO, VENDEDOR; respuesta sin contraseña



B-07_01_swagger.png

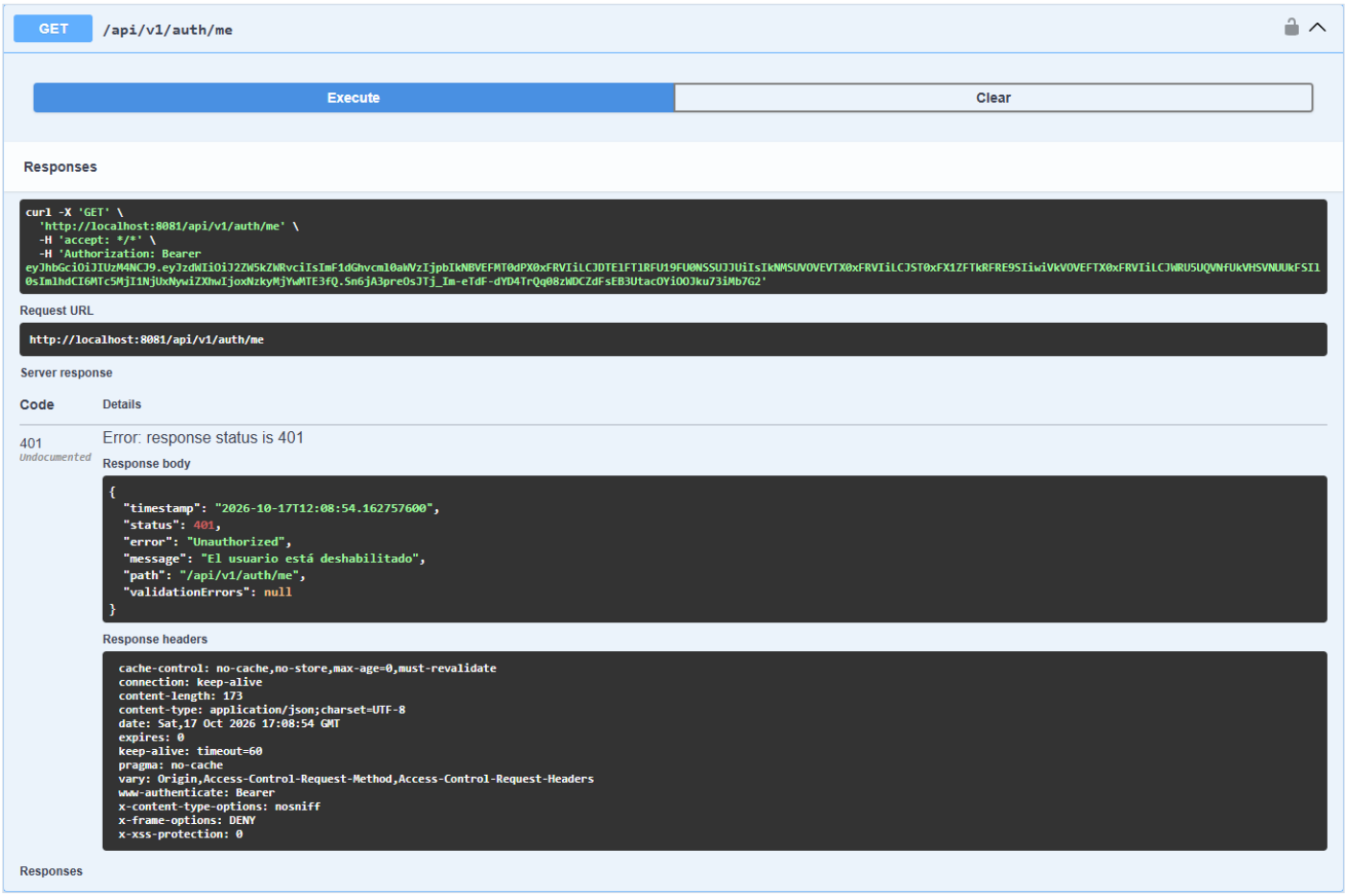
Token previo de cuenta desactivada

Usuario / token: vendedor / Bearer

Petición: GET http://localhost:8081/api/v1/auth/me

Esperado: 401 - El usuario está deshabilitado

Obtenido: 401 - El usuario está deshabilitado



B-07_02_swagger.png

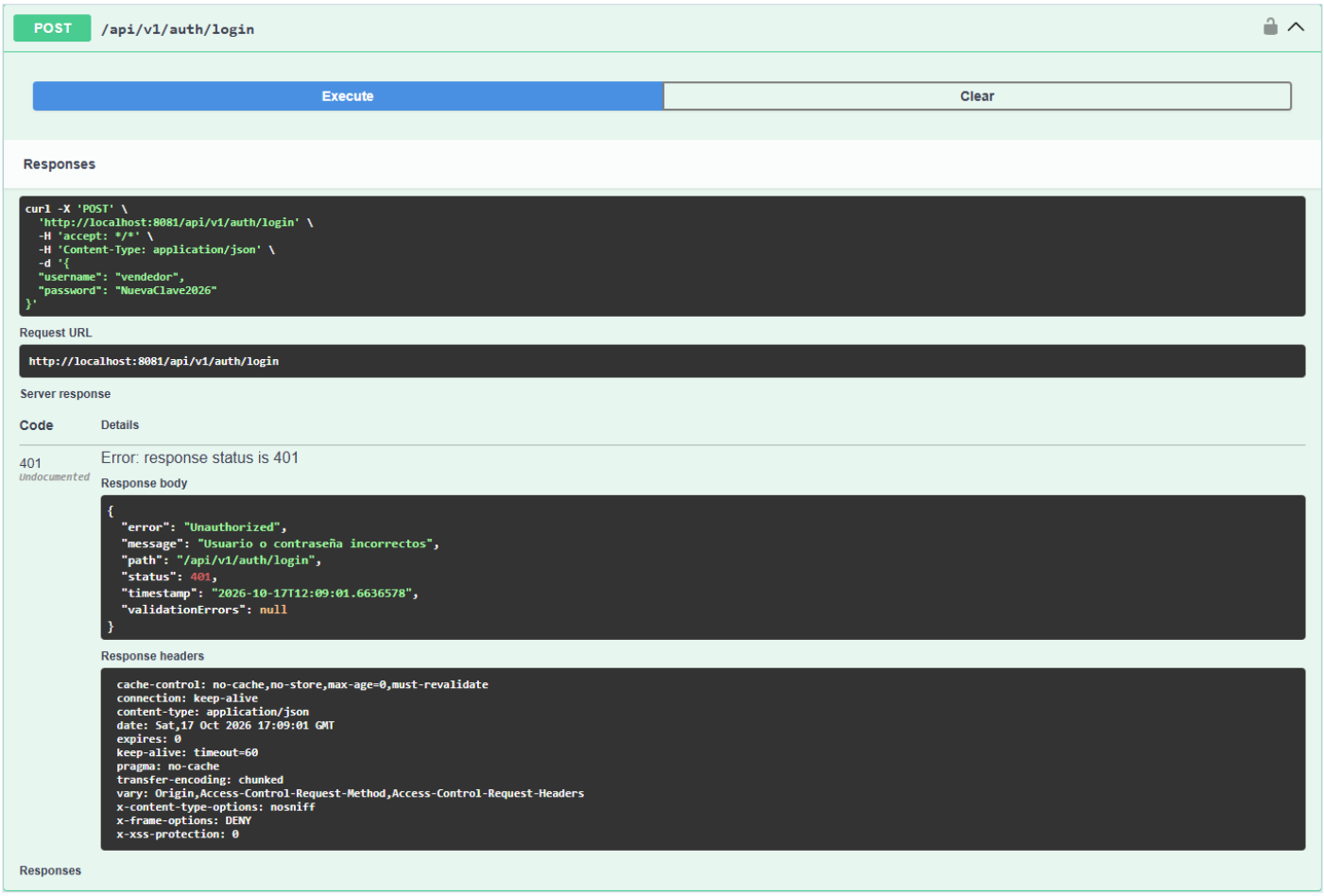
Cuenta desactivada no inicia sesión

Usuario / token: Público / Ausente

Petición: POST http://localhost:8081/api/v1/auth/login

Esperado: 401 - Usuario o contraseña incorrectos

Obtenido: 401 - Usuario o contraseña incorrectos



B-07_03_swagger.png

Admin reactiva vendedor

Usuario / token: admin / Bearer

Petición: PATCH http://localhost:8081/api/v1/usuarios/2/estado

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - Usuario vendedor; roles ALMACENERO, VENDEDOR; respuesta sin contraseña

PATCH /api/v1/usuarios/{id}/estado

Execute | Clear

Responses

```
curl -X 'PATCH' \
  'http://localhost:8081/api/v1/usuarios/2/estado' \
  -H 'accept: */*' \
  -H 'Content-Type: application/json' \
  -H 'Authorization: Bearer
eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJhZG1pbiIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0VTQ1JJQk1SIiwiQ0FUQUxPR09fTEVFUiIsIkNMSUVOVEVTX0VTQ1JJQk1SIiwiQ0xJRU5URVNfTEVFUiIsI1JFUE9SVEVTX1ZFUiIsI1JPTEVfQURNSU4iLCJVU1
VBUk1PU19BRE1JTk1VFJBUiIsI1ZFT1RBU19MRUVSIiwiVkVOVEFTX1JFR01TVFJBUiJdLCJpYXQiOjE3OTIyNTY1MDgsImV4cCI6MTc5MjI2MDEwOH0.KivqHKTW_b7-mwSbWwbSY7v1HPTbVd5GDOEgZ-jR95d-K2MLWyFlaY3WVVIpgwxW' \
  -d '{
  "estado": true
}'
```

Request URL

```
http://localhost:8081/api/v1/usuarios/2/estado
```

Server response

Code	Details
200	Response body

```
{
  "id": 2,
  "username": "vendedor",
  "empleadoId": 2,
  "empleadoNombre": "Lucia Ramos Cutipa",
  "cargo": "Vendedora",
  "roles": [
    "ALMACENERO",
    "VENDEDOR"
  ],
  "permisos": [
    "CATALOGO_ESCRIBIR",
    "CATALOGO_LEER",
    "CLIENTES_ESCRIBIR",
    "CLIENTES_LEER",
    "VENTAS_LEER",
    "VENTAS_REGISTRAR"
  ],
  "estado": true,
  "fechaCreacion": "2026-10-17T16:57:52.705694"
}
```

Response headers

```
cache-control: no-cache,no-store,max-age=0,must-revalidate
connection: keep-alive
content-type: application/json
date: Sat,17 Oct 2026 17:09:08 GMT
expires: 0
keep-alive: timeout=60
pragma: no-cache
transfer-encoding: chunked
vary: Origin,Access-Control-Request-Method,Access-Control-Request-Headers
x-content-type-options: nosniff
x-frame-options: DENY
x-xss-protection: 0
```

Responses

B-07_04_swagger.png

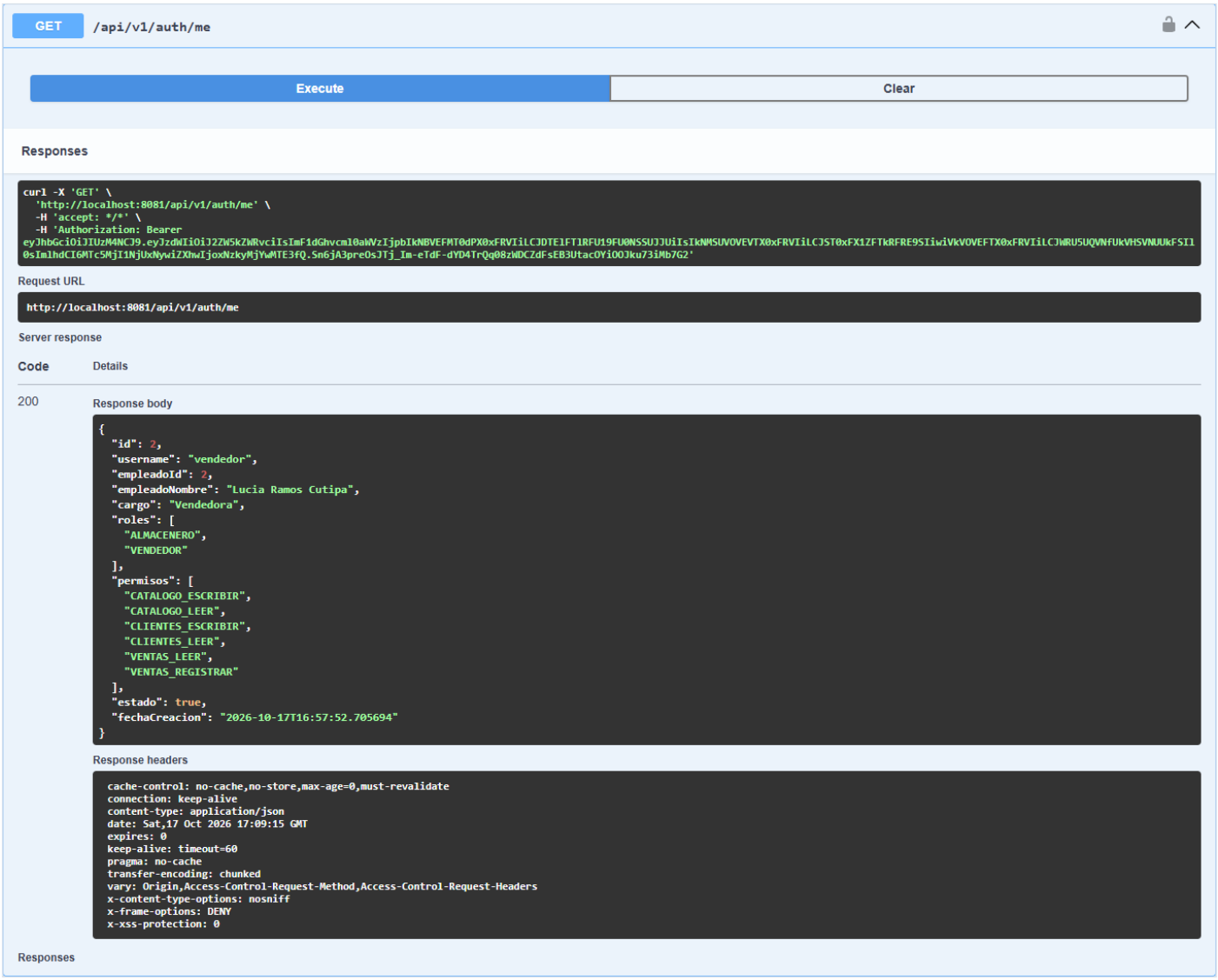
Token funciona al reactivar

Usuario / token: vendedor / Bearer

Petición: GET http://localhost:8081/api/v1/auth/me

Esperado: 200 - Respuesta JSON correcta

Obtenido: 200 - Usuario vendedor; roles ALMACENERO, VENDEDOR; respuesta sin contraseña



B-07_05_swagger.png

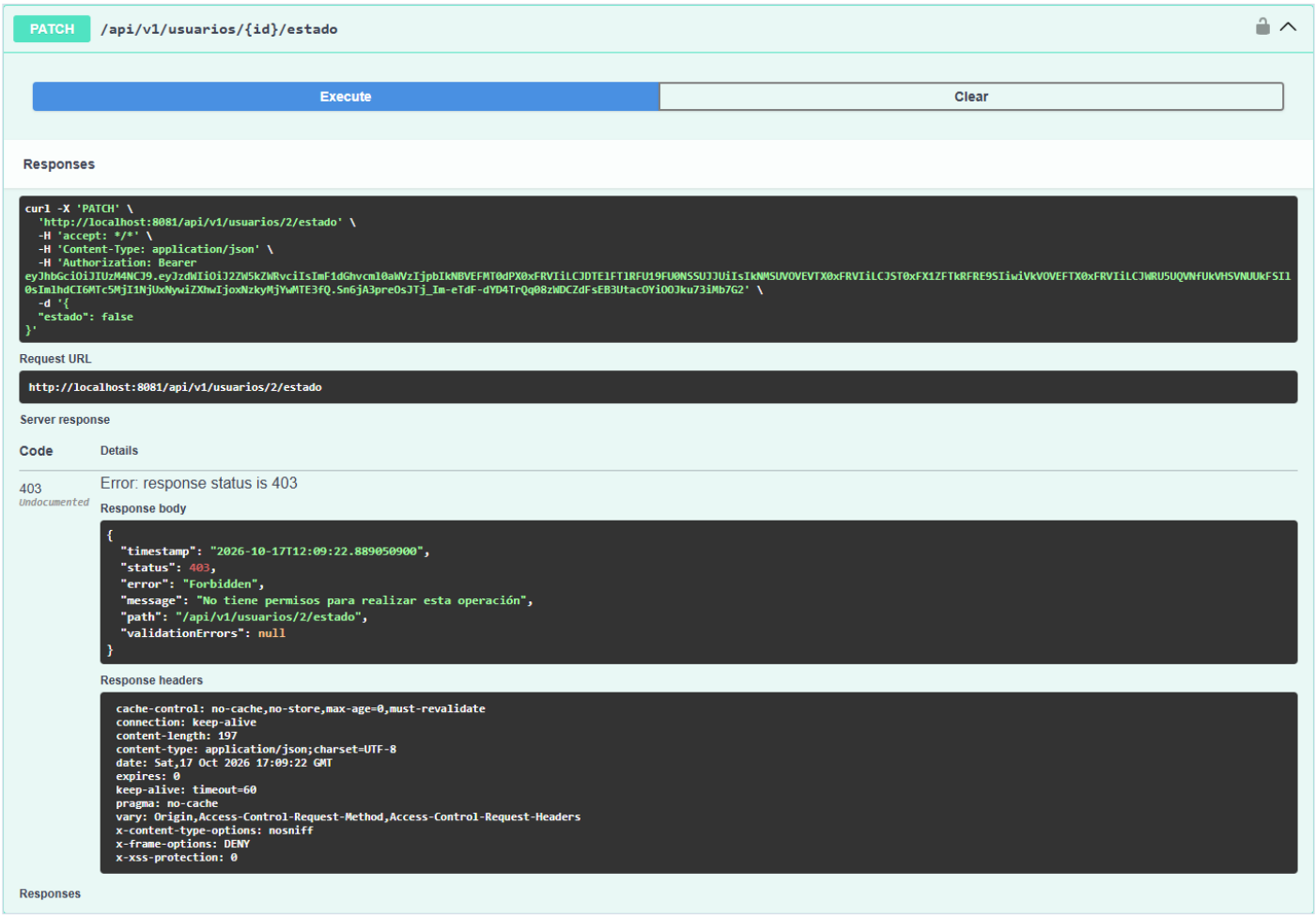
Vendedor no cambia estado

Usuario / token: vendedor / Bearer

Petición: PATCH http://localhost:8081/api/v1/usuarios/2/estado

Esperado: 403 - No tiene permisos

Obtenido: 403 - No tiene permisos para realizar esta operación



B-08_01_swagger.png

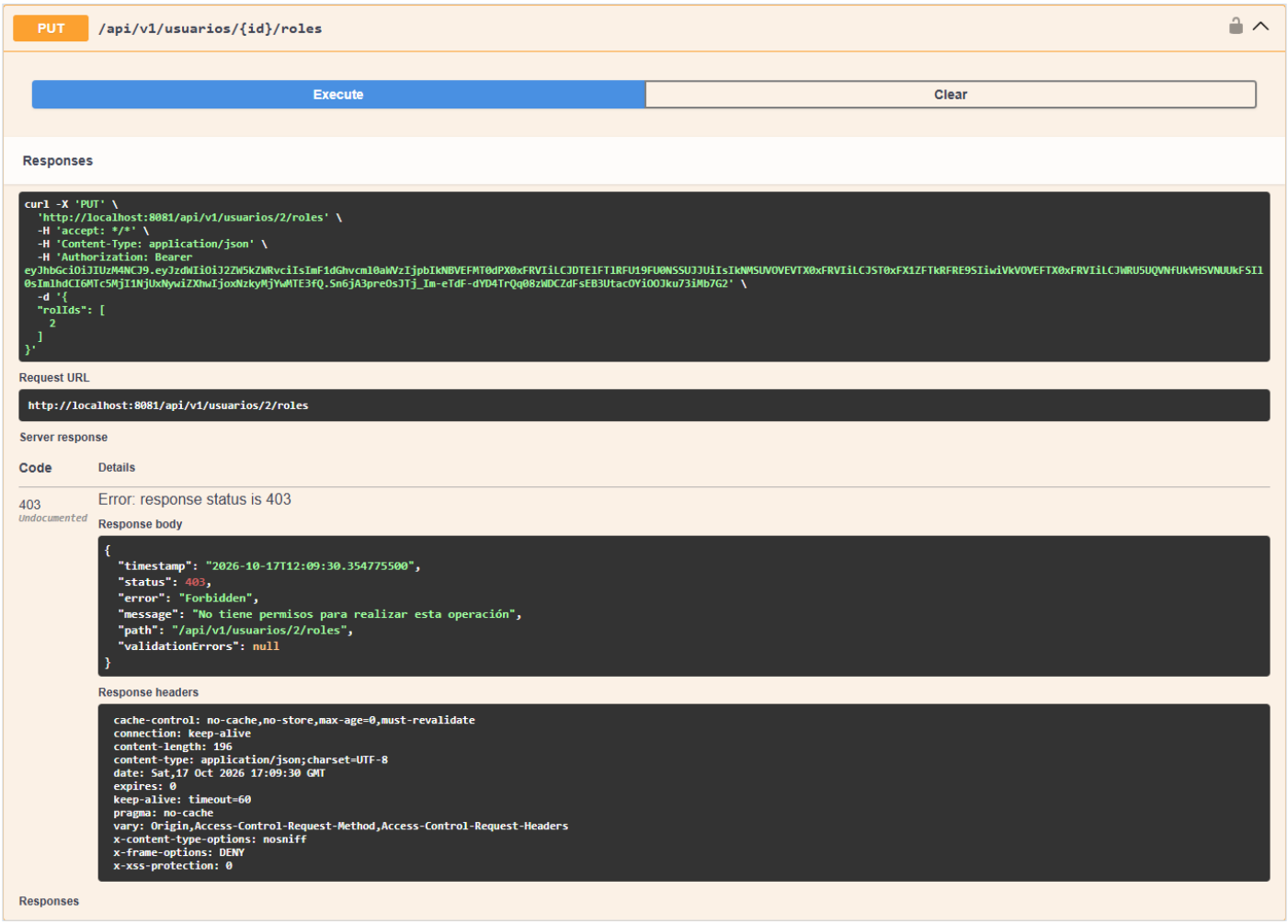
Vendedor no asigna roles

Usuario / token: vendedor / Bearer

Petición: PUT http://localhost:8081/api/v1/usuarios/2/roles

Esperado: 403 - No tiene permisos

Obtenido: 403 - No tiene permisos para realizar esta operación



B-08_02_swagger.png

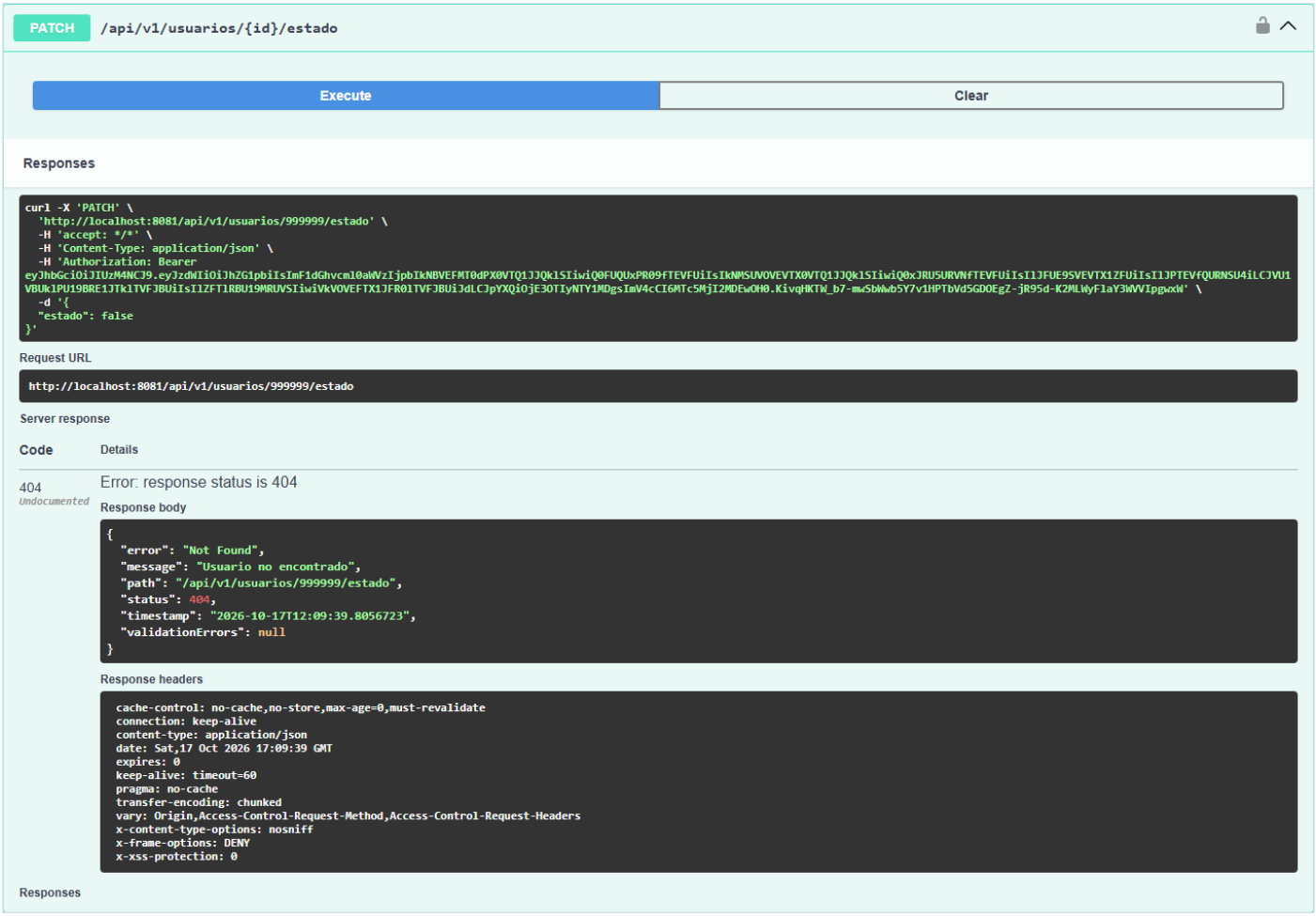
Estado de usuario inexistente

Usuario / token: admin / Bearer

Petición: PATCH http://localhost:8081/api/v1/usuarios/999999/estado

Esperado: 404 - Usuario no encontrado

Obtenido: 404 - Usuario no encontrado



B-08_03_swagger.png

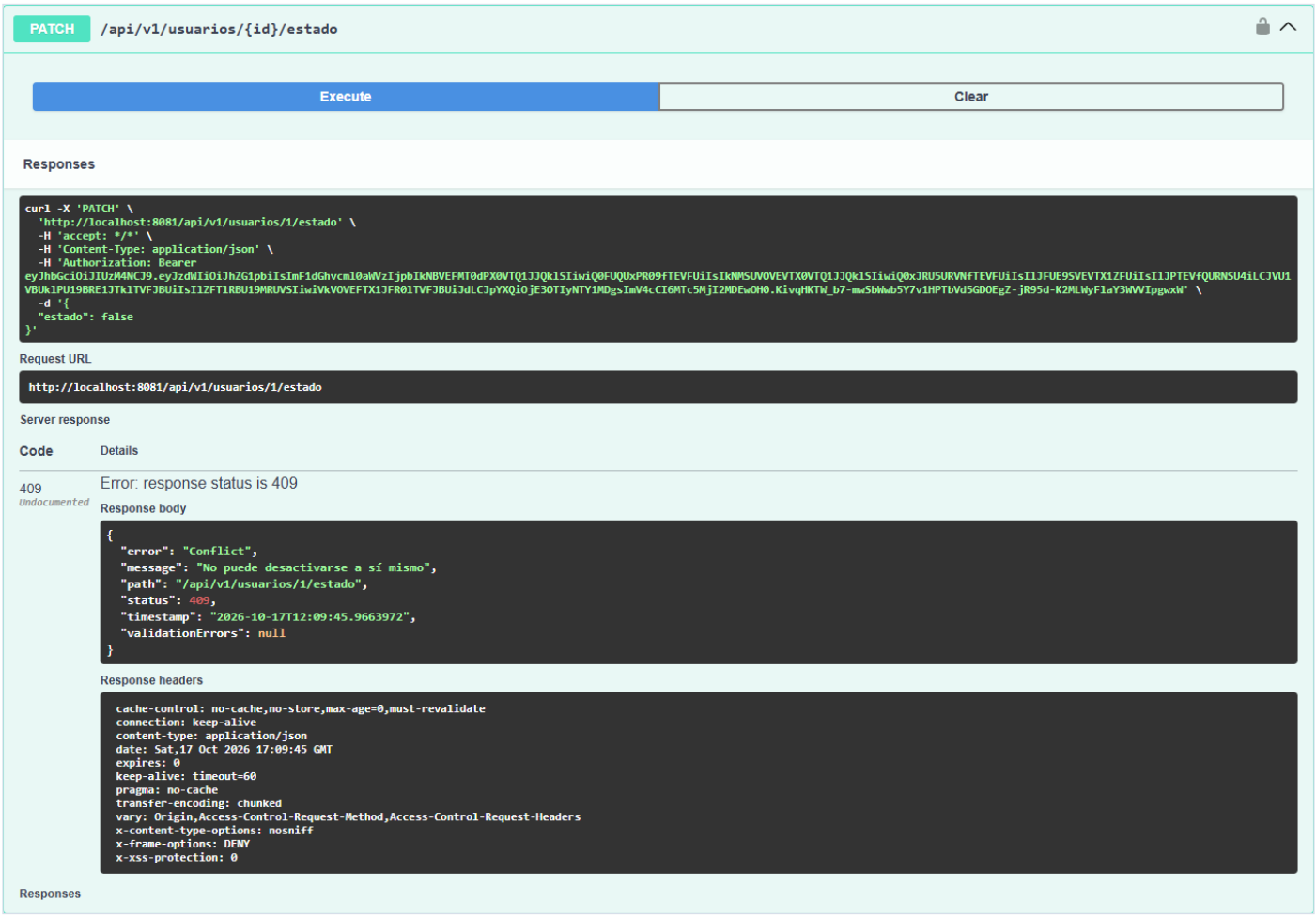
Admin no se desactiva

Usuario / token: admin / Bearer

Petición: PATCH http://localhost:8081/api/v1/usuarios/1/estado

Esperado: 409 - No puede desactivarse

Obtenido: 409 - No puede desactivarse a sí mismo



B-08_04_swagger.png